Bento

Manual técnico

Instalação, uso de cada módulo, personalização da interface em Tailwind CSS, TypeScript, API, permissões, tempo real, relatórios, integrações, configuração, operação e manutenção.

Versão 1.5.0
Novembro de 2026

Copyright (©) 2026 Erik Pimenta

Sumário

1.5 **O que há de novo na 1.5.0** **6**

N.1 Resumo da versão 6
N.2 Atualizando da 1.4.0 7
N.3 Verificação em duas etapas 8
N.4 Alertas de métricas 11
N.5 Previsão do mês 14
N.6 Insights 16
N.7 Visão geral personalizável 16
N.8 Outras mudanças 18
N.9 Testes da versão 18
N.10 Problemas comuns das novidades 18

01 **Apresentação** **20**

1.1 O que vem no projeto 20
1.2 Novidades da versão 1.4.0 21
1.3 Versões anteriores 22
1.4 Tecnologias 22
1.5 Estrutura de pastas 23
1.6 Como ler este manual 23

02 **Instalação** **25**

2.1 Requisitos 25
2.2 Com Docker 25
2.3 Sem Docker 26
2.4 Primeiro acesso 26
2.5 Primeiros passos no painel 27
2.6 Ambiente de desenvolvimento 28
2.7 Começando com o banco vazio 29
2.8 Em produção 29
2.9 Atualizando de uma versão anterior 30

03 **Usando o painel** **31**

3.1 Menu, cabeçalho e paleta de comandos 31
3.2 Visão geral 33
3.3 Analytics 34
3.4 Usuários 36
3.5 Importação de usuários 37

Copyright (©) 2026 Erik Pimenta

3.6 Transações 38
3.7 Auditoria 39
3.8 Notificações 40
3.9 Relatórios 41
3.10 Configurações 42
3.11 Preferências 45
3.12 Componentes, novidades e página não encontrada 46
3.13 No celular 48

04 **Interface em Tailwind CSS** **50**
4.1 Como o CSS é organizado 50
4.2 Identidade “caixa única” 50
4.3 Tokens de cor 51
4.4 Modo escuro 52
4.5 Paletas 52
4.6 Grade bento 53
4.7 Variantes personalizadas 54
4.8 Animações e movimento reduzido 54
4.9 Criando componentes 54

05 **TypeScript da interface** **56**
5.1 Organização 56
5.2 Ciclo de uma página 56
5.3 Falando com a API 57
5.4 Tabela de dados 58
5.5 Preferências, recentes e armazenamento 58
5.6 Gráficos 59
5.7 Gavetas, diálogos e avisos 59
5.8 Criando uma página nova 59

06 **API** **61**
6.1 Convenções 61
6.2 Autenticação e sessões 62
6.3 Rotas de saúde, sessão, visão geral, analytics e auditoria 62
6.4 Rotas de usuários e transações 63
6.5 Rotas de notificações e relatórios 65
6.6 Rotas de configurações e integrações 66
6.7 Rotas de sistema e operação 67
6.8 Exemplos 68
6.9 Adicionando uma rota 68

Copyright (©) 2026 Erik Pimenta

07 **Permissões** **70**

7.1 Papéis 70

7.2 Matriz de permissões 70

7.3 Exceções por pessoa 71

7.4 Criando uma permissão 71

08 **Tempo real** **73**

8.1 Eventos 73

8.2 Várias instâncias 73

8.3 Reconexão e indicador 74

8.4 Simulador de atividade 74

09 **Relatórios** **75**

9.1 Tipos e colunas 75

9.2 Formatos 75

9.3 Envios agendados 76

9.4 Criando um tipo de relatório 76

10 **Integrações** **77**

10.1 Provedores e campos 77

10.2 Eventos enviados 77

10.3 Webhook assinado 77

10.4 Histórico de entregas e novas tentativas 78

10.5 Segredos protegidos 79

11 **Configuração e segurança** **80**

11.1 Variáveis de ambiente 80

11.2 Validação da configuração 82

11.3 Dados da empresa 82

11.4 Segurança aplicada 82

11.5 Auditoria de segurança da versão 1.1.0 83

12 **Operação e manutenção** **84**

12.1 Diagnóstico 84

12.2 Modo de manutenção 85

12.3 Backup e restauração 86

12.4 Retenção de dados 87

12.5 Saúde e métricas 87

12.6 Logs e identificador de requisição 88

12.7 Tarefas automáticas 89

Copyright (©) 2026 Erik Pimenta

13 **Testes, build e CI** **90**
13.1 Comandos 90
13.2 O que os testes cobrem 91
13.3 Integração contínua 91
13.4 Versão e convenções 91

14 **Solução de problemas** **93**
14.1 Instalação e inicialização 93
14.2 Dados e acesso 94
14.3 Interface, tempo real e integrações 95
14.4 Operação 95

15 **Licenças** **97**
15.1 Componentes de terceiros 97
15.2 Licença do Bento 98

Copyright (©) 2026 Erik Pimenta

1.5

O que há de novo na 1.5.0

A 1.5.0 deixa o Bento mais seguro e mais atento ao negócio: verificação em duas etapas no login, alertas que vigiam as métricas sozinhos, previsão da receita do mês, insights sobre o que saiu do padrão e uma visão geral que cada pessoa organiza do seu jeito. Este capítulo reúne tudo o que mudou; os capítulos seguintes continuam valendo como estavam.

N.1 Resumo da versão

Área	O que mudou	Onde ler
Segurança	Verificação em duas etapas com aplicativo autenticador (TOTP), QR code, dez códigos de recuperação, regra obrigatória por papel e redefinição pelo administrador	N.3
Alertas	Página **Alertas**: regras sobre 9 métricas e 4 janelas, por valor ou por variação, com prévia, modelos, gravidade, silêncio, pausa, teste na hora e histórico	N.4
Previsão	Cartão **Previsão do mês**: projeção da receita, faixa provável, chance de bater a meta, ritmo necessário e MRR em 90 dias	N.5
Insights	Cartão **Insights**: dias fora do padrão em receita, pagamentos, falhas, reembolsos, cadastros, visitantes e conversão, mais destaques do negócio	N.6
Visão geral	Botão **Personalizar**: esconder, arrastar, mover pelo teclado e redimensionar cartões, com quatro layouts prontos salvos na conta	N.7
Interface	Primeiros passos com 8 etapas, novos comandos na paleta, atalho `g` `l` para Alertas e janela de novidades	N.8
Banco	Migração `007_dois_fatores_alertas.sql`; detalhes no manual do banco de dados	N.2
Operação	Variável `BENTO_RETENCAO_ALERTAS`, verificação do segundo fator no diagnóstico e avaliação dos alertas no agendador	N.8
Correções	Idioma padrão da empresa com códigos aceitos pela API; menus de ações que fechavam no mesmo clique	N.10

Copyright (©) 2026 Erik Pimenta

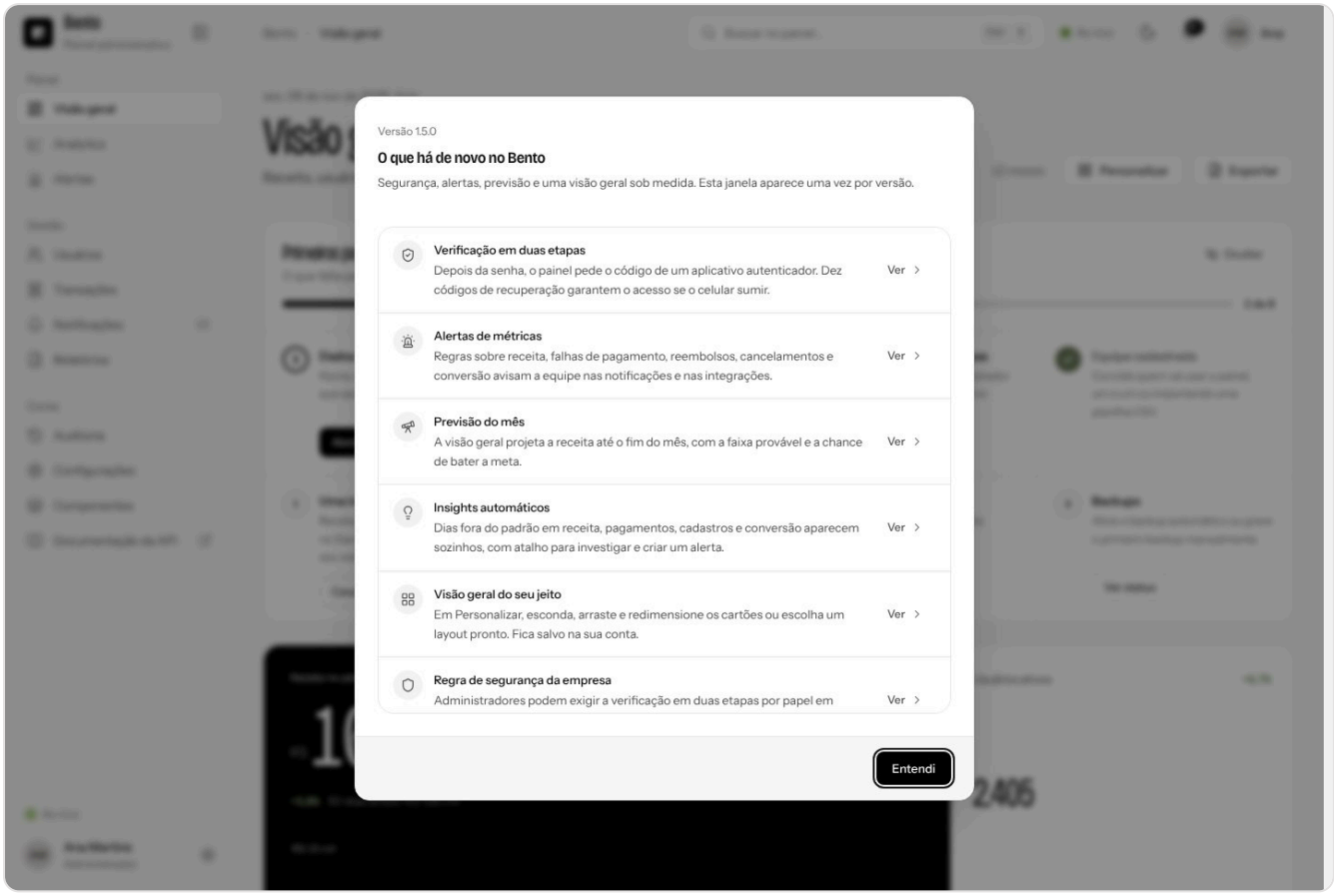


Figura N.1 A janela de novidades aparece uma vez por versão e leva direto a cada recurso.

N.2 Atualizando da 1.4.0

A atualização é igual às anteriores: faça um backup, troque o código e suba de novo. A migração 007 roda sozinha na inicialização, dentro de uma transação, e não altera nenhum dado existente.

```
npm run backup                  # com PGlite, com o servidor parado
git pull
npm install && npm run build
npm start                       # aplica 007_dois_fatores_alertas.sql
npm run diagnostico             # deve listar 7 migrações aplicadas
```

No Docker: `docker compose exec bento node api/dist/cli.js backup` e depois `docker compose up -d --build`. Não há variável obrigatória nova. Opcionalmente, defina `BENTO_RETENCAO_ALERTAS` (padrão 180 dias) para o histórico de disparos já resolvidos.

> O `BENTO_SEGREDO_JWT` passa a cifrar também os segredos dos aplicativos autenticadores. Se você trocar esse segredo, cada pessoa precisa configurar a verificação em duas etapas de novo (um administrador pode redefinir em Usuários).

Copyright (©) 2026 Erik Pimenta

N.3 Verificação em duas etapas

Com a verificação ativa, entrar no painel pede duas coisas: a senha e o código de 6 dígitos que um aplicativo autenticador mostra no celular (Google Authenticator, Microsoft Authenticator, 1Password, Authy e outros compatíveis com TOTP). Mesmo que a senha vaze, ninguém entra sem o celular.

Ativando a sua

1. Abra **Configurações › Segurança** e, em **Verificação em duas etapas**, clique em **Ativar**.
2. Confirme a senha atual. O painel gera um segredo novo, válido por 15 minutos.
3. No aplicativo, toque em adicionar conta e leia o QR code. Sem câmera, digite a chave mostrada ao lado (há um botão para copiar).
4. Digite o código que o aplicativo mostra. Com 6 dígitos o envio é automático.
5. Guarde os **dez códigos de recuperação**: copie, baixe em `.txt` ou imprima. Marque que guardou e conclua.

Ao ativar, as outras sessões da conta são encerradas, a ação entra na auditoria e você recebe uma notificação de segurança.

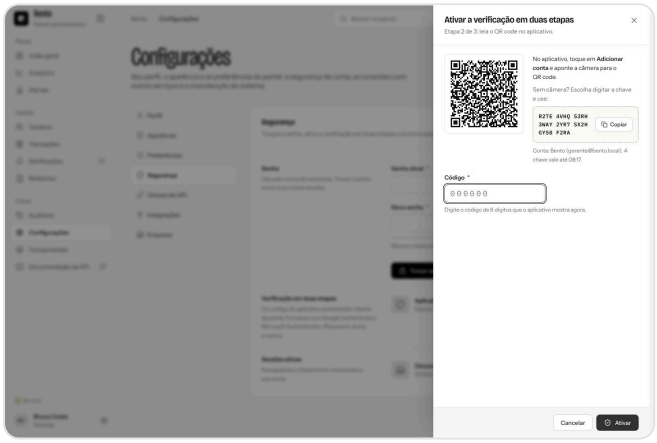


Figura N.2 Etapa 2 de 3: QR code, chave para digitar e o primeiro código.

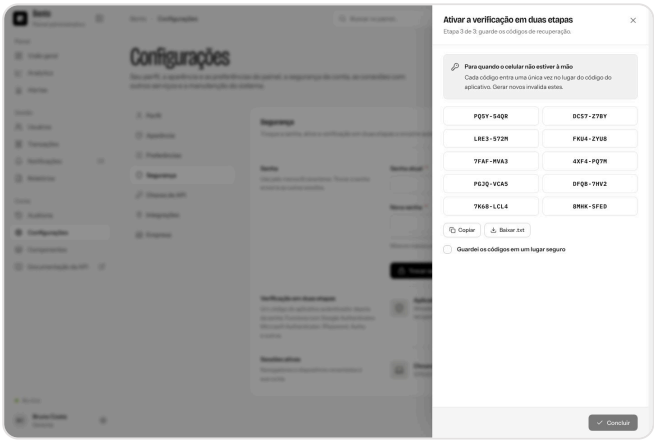


Figura N.3 Etapa 3 de 3: os dez códigos de recuperação aparecem uma única vez.

Entrando com o código

Depois da senha, a tela de entrada muda para a etapa do código. O painel guarda por 5 minutos, num cookie `httpOnly` próprio, a prova de que a senha estava certa; esse desafio não vale como sessão. Sem o celular, clique em **Usar um código de recuperação** e digite um dos códigos no formato `XXXX-XXXX`. Cada código vale uma vez; quando restam dois ou menos, o painel leva direto para a aba Segurança e avisa nas notificações.

Copyright (©) 2026 Erik Pimenta

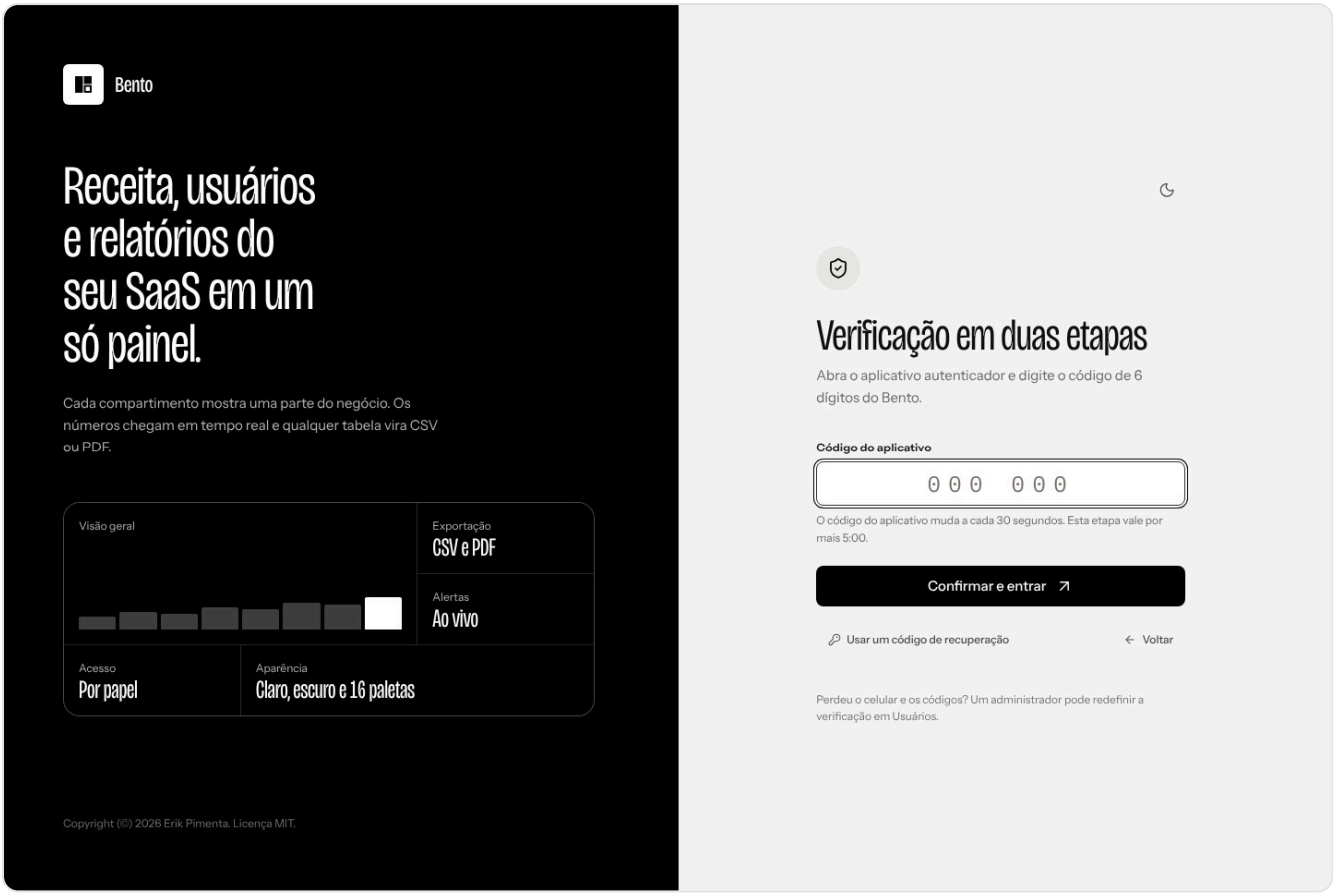


Figura N.4 Segunda etapa do login, com o atalho para os códigos de recuperação.

Gerenciando

- **Novos códigos**: com a senha atual e um código (do aplicativo ou de recuperação), troca os dez códigos de recuperação. Os anteriores deixam de valer e você recebe um aviso de segurança.
- **Desativar**: pede a senha e um código (do aplicativo ou de recuperação) e avisa nas notificações. Fica indisponível quando o seu papel exige a verificação.
- **Perdeu o celular e os códigos?** Quem tem `usuarios.editar` abre a pessoa em **Usuários** e usa **Redefinir 2 etapas**. O aplicativo é desvinculado, as sessões da pessoa são encerradas, ela recebe um aviso e entra só com a senha até configurar de novo. A mesma regra de hierarquia da senha temporária vale aqui: ninguém redefine contas de nível igual ou maior que o seu sem controlar permissões, e a própria conta só muda em Segurança.

Exigindo por papel

Em **Configurações › Empresa**, administradores marcam os papéis que precisam da verificação (Administradores, Gerentes, Analistas, Suporte). Quem tem um desses papéis e ainda não ativou continua entrando, mas só alcança a própria conta: perfil, preferências, a aba Segurança e a contagem de notificações. Qualquer outra rota responde `403` com o código `DOIS_FATORES` e a interface leva a pessoa para a aba Segurança com um aviso. Para não se trancar fora, a API recusa marcar o seu próprio papel antes de você ativar a sua verificação. Chaves de API não são afetadas pela regra.

Copyright (©) 2026 Erik Pimenta

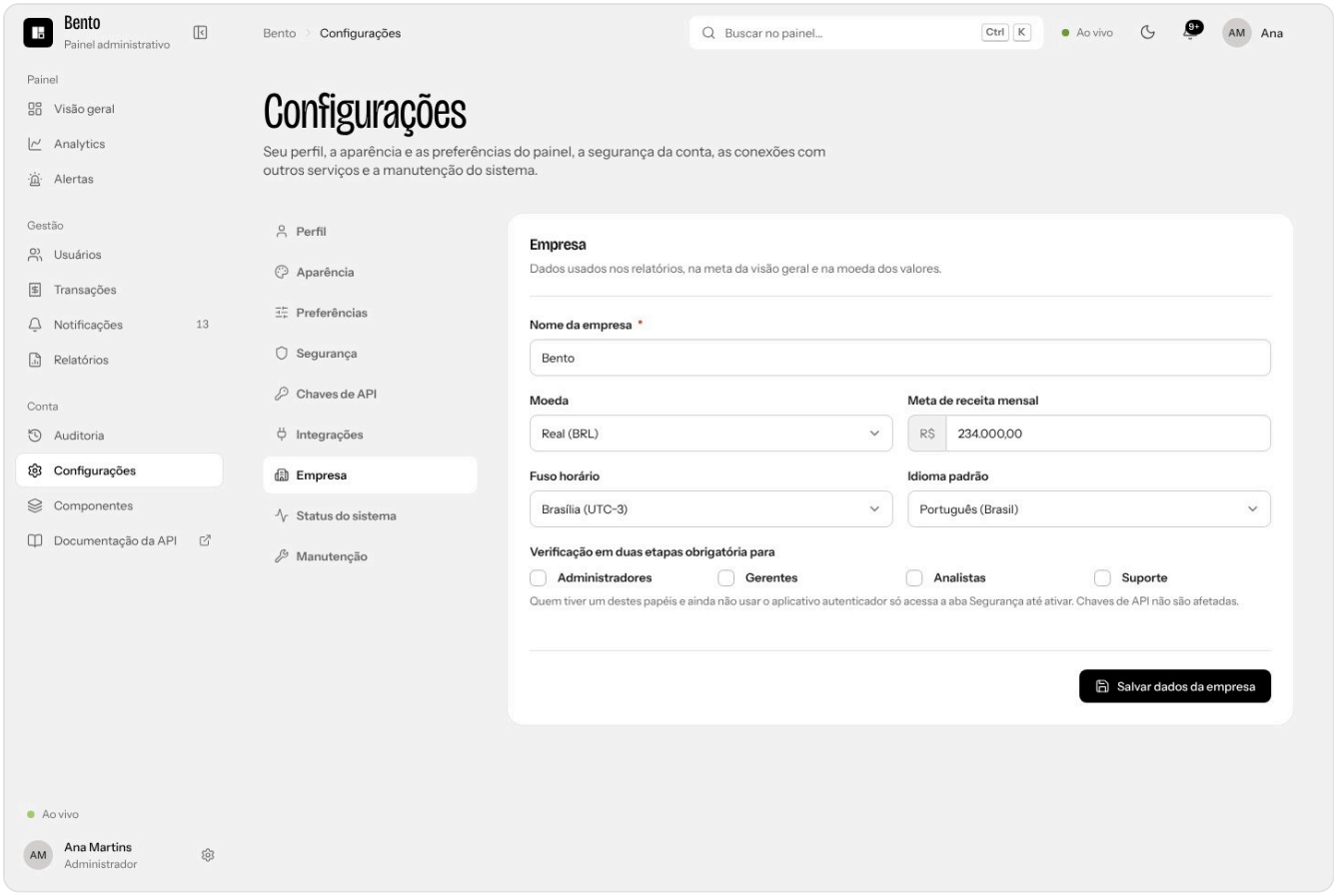


Figura N.5 Configurações › Empresa com a regra de verificação obrigatória por papel.

Como funciona por dentro

Peça	Detalhe
Algoritmo	TOTP da RFC 6238 com HMAC-SHA1, 6 dígitos e passo de 30 segundos, sem dependência externa (`api/src/util/totp.ts`). Os testes usam os vetores oficiais da RFC.
Tolerância	Aceita o passo anterior, o atual e o seguinte (±30 s) para relógios um pouco fora de hora.
Reuso	O último passo aceito fica gravado em `totp_ultimo_passo` ; um código já usado, ou mais antigo, é recusado mesmo dentro da janela.
Segredo	Gerado com 160 bits aleatórios e guardado cifrado com AES-256-GCM, com chave derivada do `BENTO_SEGREDO_JWT` . Nunca volta pela API depois de ativado.
Códigos de recuperação	Dez por pessoa, 8 caracteres sem letras ambíguas, guardados só como HMAC-SHA256 com chave do servidor e o id da pessoa, para que um backup vazado não permita descobri-los por força bruta. O uso marca `usado_em` numa única instrução, sem corrida.
Tentativas	Código errado conta na mesma trava da senha, com incremento atômico no banco (pedidos em paralelo não escapam da contagem): 5 erros suspendem o acesso por 15 minutos, com aviso de segurança para a equipe. A rota também tem limite de 10 pedidos por minuto.
QR code	Desenhado no navegador a partir do endereço `otpauth://` , sem enviar o segredo a serviços de terceiros.

Copyright (©) 2026 Erik Pimenta

Peça	Detalhe
Auditoria	`seguranca.dois_fatores_ativado`, `seguranca.dois_fatores_desativado`, `seguranca.codigos_gerados`, `usuario.dois_fatores_redefinido` e o login registra o método em `detalhes`.

Rotas

Rota	O que faz
`POST /api/v1/auth/entrar`	Com a verificação ativa, devolve `{"doisFatores": true, "expiraEm"}` e o cookie `bento_desafio`, sem abrir sessão
`POST /api/v1/auth/dois-fatores`	Corpo `{"codigo"}`: código do aplicativo ou de recuperação. Abre a sessão e devolve o contexto com `codigosRestantes` quando foi usado um código de recuperação
`GET /api/v1/configuracoes/seguranca/dois-fatores`	Estado: `ativo`, `ativadoEm`, `codigosRestantes`, `obrigatorio` e `pendente`
`POST …/dois-fatores/iniciar`	Com `senhaAtual`, gera o segredo pendente e devolve a chave e o endereço `otpauth://`
`POST …/dois-fatores/ativar`	Com o primeiro `codigo`, ativa e devolve os dez códigos de recuperação
`POST …/dois-fatores/desativar`	Com `senhaAtual` e `codigo`, desliga
`POST …/dois-fatores/codigos`	Com `senhaAtual` e `codigo`, troca os códigos de recuperação
`POST /api/v1/usuarios/{id}/redefinir-dois-fatores`	Remove o aplicativo de outra conta (`usuarios.editar` e hierarquia)
`PUT /api/v1/configuracoes/sistema`	Campo `doisFatoresPapeis`: lista de papéis do painel que precisam da verificação

N.4 Alertas de métricas

A página **Alertas** (menu Painel, ou `g` `l`) guarda regras que vigiam as métricas do negócio. O agendador mede cada regra ativa a cada 5 minutos; quando a condição é atendida, o alerta dispara: aparece nas notificações da equipe, na categoria **Alertas de métricas**, entra no histórico de disparos e, se marcado, segue para o Slack, o Discord ou o webhook ativos com o evento `alerta.disparado`. Quando a métrica volta ao normal, o disparo é encerrado e a equipe recebe um aviso de normalização.

Copyright (©) 2026 Erik Pimenta

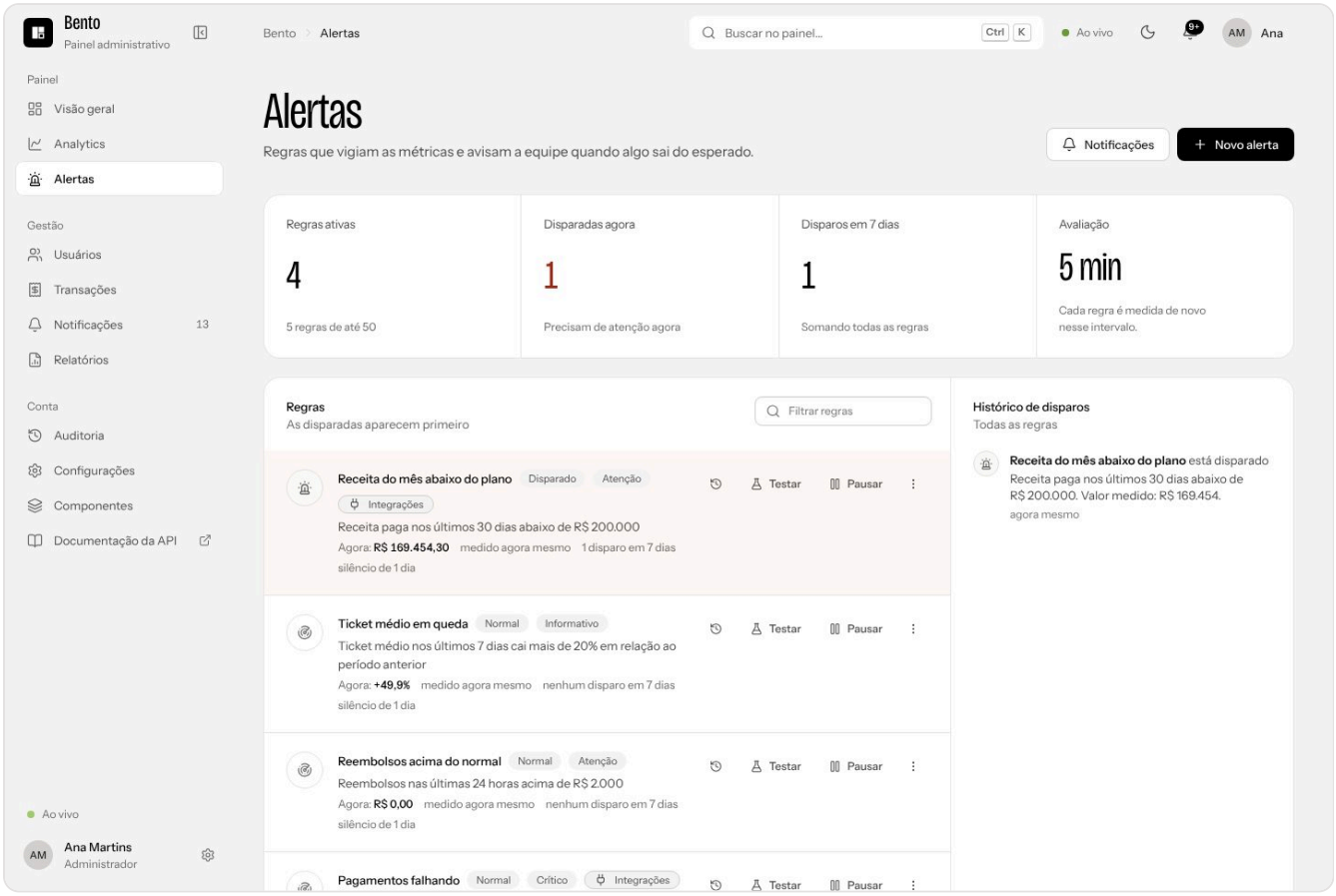


Figura N.6 Alertas: resumo, regras com o valor medido agora e histórico de disparos.

Métricas e janelas

Métrica	Unidade	Como é medida
Receita paga	Moeda	Soma das transações pagas na janela
Transações pagas	Número	Quantidade de cobranças pagas
Taxa de falha dos pagamentos	%	Falhas sobre pagas mais falhas
Reembolsos	Moeda	Valor devolvido, pela data do reembolso
Novos usuários	Número	Contas de clientes criadas
Cancelamentos	Número	Assinaturas pagas canceladas
Receita recorrente (MRR)	Moeda	MRR agora; a variação compara com o início da janela
Ticket médio	Moeda	Receita paga dividida pelas transações pagas
Conversão de visitantes	%	Novos usuários sobre visitantes, por dia completo no fuso do sistema

As janelas são **última hora**, **últimas 24 horas**, **últimos 7 dias** e **últimos 30 dias**, sempre contadas a partir do momento da medição. No modo **valor**, a regra compara o número da janela com o limite (acima de ou abaixo de). No modo

Copyright (©) 2026 Erik Pimenta

variação, compara com a janela imediatamente anterior, de mesmo tamanho: “sobe mais de 20%” ou “cai mais de 15%”. Sem base de comparação (período anterior zerado), a regra não dispara.

Criando uma regra

1. Clique em **Novo alerta** ou escolha um dos cinco modelos (pagamentos falhando, receita da semana em queda, reembolsos acima do normal, onda de cancelamentos e cadastros desacelerando).
2. Escolha a métrica, a janela e o modo, e informe o limite. Valores em moeda são digitados em reais (ou na moeda da empresa); percentuais, em pontos.
3. Acompanhe a **prévia**: o painel mede a métrica na hora e diz se, com aqueles números, a regra dispararia.
4. Defina a **gravidade** (Informativo, Atenção ou Crítico), o **silêncio** depois de disparar (15 minutos a 7 dias) e se o aviso também vai para as integrações.

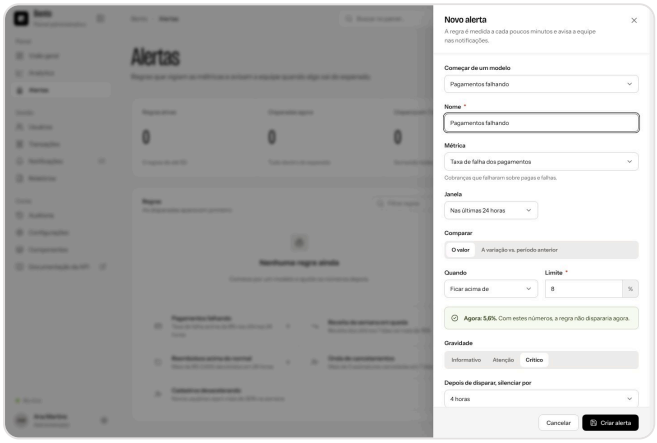


Figura N.7 Nova regra a partir de um modelo, com a prévia do valor de agora.

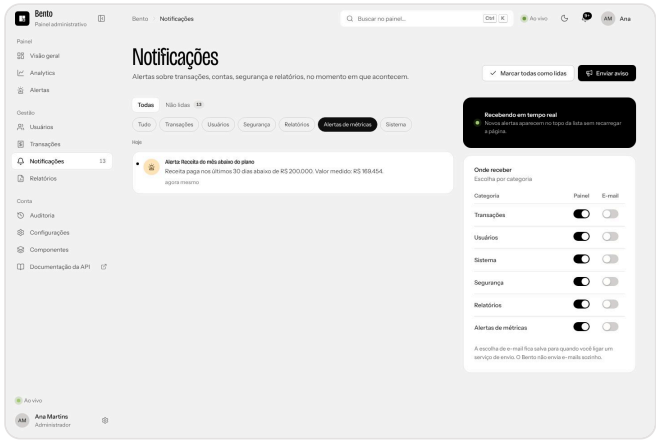


Figura N.8 Disparos na central de notificações, filtrados pela categoria.

No dia a dia

- **Testar** mede a regra na hora, com os mesmos efeitos de uma medição do agendador (inclusive o aviso, se disparar).
- **Pausar** e **Retomar**: pausada, a regra não é medida e um disparo aberto é encerrado.
- **Silêncio**: depois de disparar, a regra só volta a avisar quando o silêncio acabar, mesmo que a métrica oscile em volta do limite.
- Editar a métrica, a janela, o modo, o operador ou o limite reinicia o estado da regra.
- O ícone de histórico filtra os disparos de uma regra; o endereço `/alertas?alerta=<id>` abre a página com ela destacada, e é para lá que levam as notificações.
- Cada regra tem até 80 caracteres no nome e a empresa pode ter até 50 regras.

Permissões e auditoria

Há duas permissões novas: `alertas.ver` (página, catálogo, histórico e prévia) e `alertas.gerenciar` (criar, editar, pausar, testar e excluir). As duas vêm marcadas para Administrador, Gerente e Analista; o Suporte não vê a página, mas pode recebê-las como exceção individual. Criar, alterar, pausar, retomar e excluir entram na auditoria com as ações `alerta.*`.

Copyright (©) 2026 Erik Pimenta

Rotas

Rota	O que faz
`GET /api/v1/alertas`	Regras com estado, último valor, disparos em 7 dias e o resumo (total, ativas, disparadas, disparos em 7 dias)
`GET /api/v1/alertas/catalogo`	Métricas com unidade e descrição, janelas, intervalo de avaliação e limite de regras
`POST /api/v1/alertas/simular`	Corpo com `metrica`, `janela`, `modo`, `operador` e `limite`: valor atual, anterior, variação e se dispararia
`POST /api/v1/alertas`	Cria a regra (`nome`, regra, `severidade`, `notificarIntegracoes`, `silencioMinutos`, `ativo`)
`GET/PATCH/DELETE /api/v1/alertas/{id}`	Detalhe, alteração parcial (inclusive pausa) e exclusão com o histórico
`POST /api/v1/alertas/{id}/avaliar`	Mede agora e devolve quantos dispararam ou normalizaram e a regra atualizada
`GET /api/v1/alertas/disparos`	Histórico paginado, com filtro `alerta`

```
curl -b sessao.txt -H "X-Bento: 1" -H "Content-Type: application/json" \
     -d '{"nome":"Receita da semana em queda","metrica":"receita","janela":"7d",
          "modo":"variacao","operador":"menor","limite":15,"severidade":"alerta",
          "silencioMinutos":1440}' http://localhost:8080/api/v1/alertas
```

O webhook recebe o evento `alerta.disparado` assinado com HMAC-SHA256, como os demais, com a regra completa, o valor medido e a mensagem em `dados`. Slack e Discord recebem uma linha com o nome do alerta e o valor.

Como a avaliação funciona

A cada ciclo do agendador (1 minuto), uma única instrução `update … returning` reserva até 50 regras ativas cuja última avaliação tem mais de 5 minutos, gravando o horário da avaliação. Assim, com várias instâncias da API, cada regra é medida por uma só. Regras com a mesma métrica e janela compartilham a mesma medição no ciclo. A reserva usa `for update skip locked`, e as passagens entre `normal` e `disparado` são condicionadas ao estado anterior, à regra estar ativa e à data da última alteração da regra, o que impede avisos em dobro ou de uma regra recém-pausada. A medição continua durante o modo de manutenção, porque vigiar o negócio é justamente o que importa nessas horas.

N.5 Previsão do mês

O cartão **Previsão do mês**, na visão geral, projeta a receita paga até o último dia do mês corrente e compara com a meta (a do mês em `metas_mensais` ou a meta mensal da empresa). Ele mostra:

- **Projeção**: o realizado até agora mais o esperado para o resto de hoje e para cada dia que falta.
- **Faixa provável**: o intervalo de 80% em volta da projeção, que se estreita conforme o mês avança.

Copyright (©) 2026 Erik Pimenta

- **Chance de bater a meta**, em verde (70% ou mais), dourado (35% a 70%) ou vermelho (abaixo de 35%).
- **Ritmo atual por dia**, **quanto falta por dia** para a meta e o **MRR esperado em 90 dias**.
- O gráfico acumulado do mês: realizado (linha cheia), projeção e faixa (tracejadas) e o ritmo da meta.

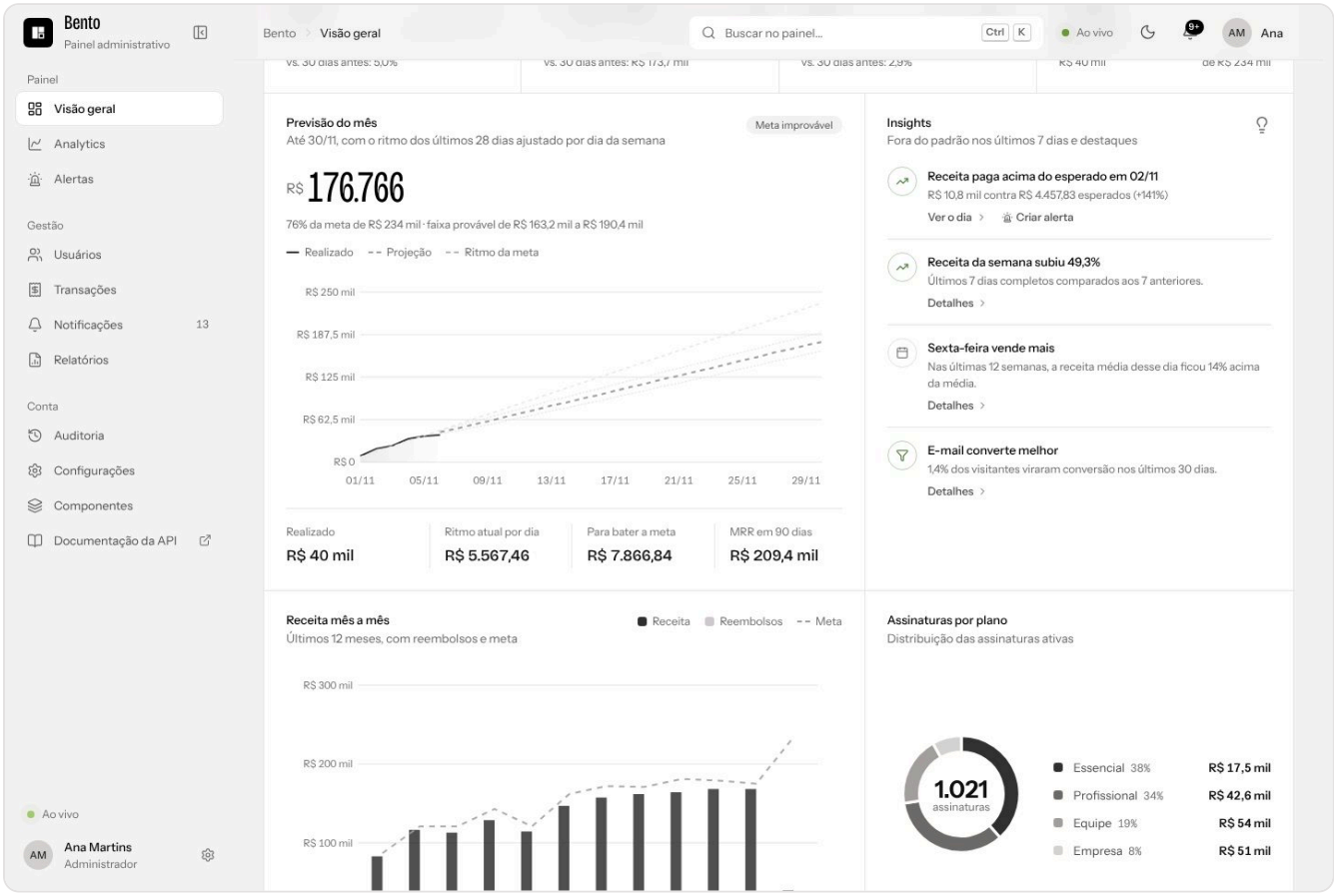


Figura N.9 Previsão do mês e Insights lado a lado na visão geral.

O método

O modelo é simples de propósito, para ser explicável e barato de calcular a cada visita. Com as últimas 12 semanas completas, o Bento calcula um fator para cada dia da semana (a média daquele dia sobre a média geral, entre 0,4 e 1,8). O nível é a média dos últimos 28 dias completos já sem o efeito do dia da semana. O esperado de um dia futuro é o nível vezes o fator do dia. Para hoje, entra só a fração do dia que ainda falta no fuso do sistema.

A incerteza vem do desvio padrão dos resíduos dos últimos 28 dias: a variância de cada dia que falta é somada, e a faixa usa ±1,2816 desvio (80%). A chance de bater a meta é a probabilidade, numa distribuição normal, de o total do mês ficar acima da meta. Com menos de 21 dias de histórico a previsão continua aparecendo, mas o subtítulo avisa que ela ainda é pouco confiável. A tendência do MRR é uma regressão linear sobre o MRR das últimas 12 semanas, projetada para 30 e 90 dias.

Tudo vem de `GET /api/v1/insights` (permissão `painel.ver`), calculado em `api/src/modulos/insights`; as funções puras ficam em `calculos.ts` e têm testes próprios.

Copyright (©) 2026 Erik Pimenta

N.6 Insights

O cartão **Insights** responde à pergunta “o que saiu do normal?” sem que ninguém precise abrir o Analytics. Ele lista até três anomalias dos últimos 7 dias completos e completa com destaques do negócio.

Anomalias

Para cada dia avaliado, a base é a dos 28 dias anteriores. Nas séries com efeito de dia da semana, os valores são divididos pelo fator do dia antes da comparação. O Bento calcula a mediana da base e a dispersão robusta (1,4826 vezes o desvio absoluto mediano), que não se deixa levar por um pico isolado. Um dia vira anomalia quando fica a 3 dispersões ou mais da mediana e pelo menos 20% longe do esperado; a partir de 4,5 dispersões, ela é marcada como forte. Taxas só contam em dias com volume mínimo, para que três cobranças não virem “33% de falha”.

Série	Ajuste semanal	Mínimo	Quando é boa notícia
Receita paga	Sim	R$ 10 esperados	Quando sobe
Transações pagas	Sim	5 esperadas	Quando sobe
Taxa de falha dos pagamentos	Não	20 cobranças no dia	Quando cai
Reembolsos	Não	R$ 50 esperados	Quando cai
Novos usuários	Sim	5 esperados	Quando sobe
Visitantes	Sim	50 esperados	Quando sobe
Conversão de visitantes	Não	200 visitantes no dia	Quando sobe

Cada anomalia mostra o valor, o esperado e o desvio, com **Ver o dia** (transações ou analytics já filtrados) e, para quem gerencia alertas, **Criar alerta**, que abre uma regra de variação pronta para aquela métrica.

Destaques

A receita dos últimos 7 dias contra os 7 anteriores, o dia da semana que mais vende nas últimas 12 semanas, o canal com a maior conversão em 30 dias e o plano cuja receita mais variou contra os 30 dias anteriores (a partir de 5%).

N.7 Visão geral personalizável

Cada pessoa pode montar a própria visão geral. O botão **Personalizar**, ao lado do seletor de período, entra no modo de edição: os cartões ganham uma barra com o nome, a alça de mover, o tamanho e o botão de ocultar, e uma faixa acima da grade reúne os cartões ocultos, os layouts prontos e as ações.

- **Mover**: arraste o cartão; ou foque a alça e use as setas (uma posição por vez) e `Home`/`End` (início ou fim). O menu de tamanho também tem “mover para o início” e “para o fim”.
- **Redimensionar**: o menu de tamanho lista só as larguras que fazem sentido para o cartão (de um quarto até a largura inteira) e, quando cabe, a altura alta, de duas linhas.
- **Ocultar** e **mostrar**: o cartão oculto vira um botão na faixa; um clique devolve ele ao lugar.

Copyright (©) 2026 Erik Pimenta

- **Layouts prontos**: Financeiro, Crescimento, Operação do dia e Enxuto. **Padrão** volta ao layout original.
- **Salvar layout** grava na conta (vale em qualquer navegador); **Cancelar** ou `Esc` desfaz o que não foi salvo.

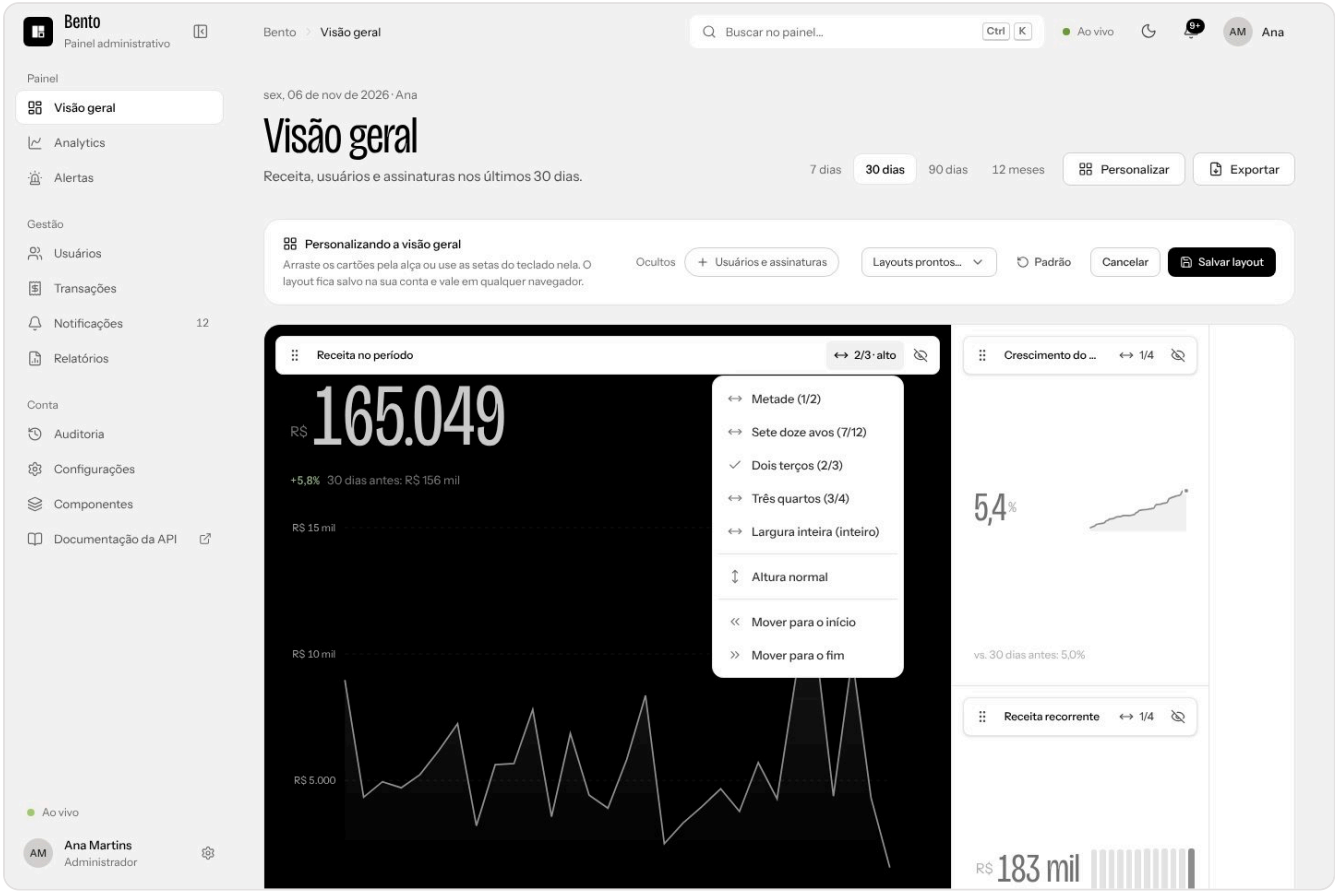


Figura N.10 Modo de edição: cartões com alça, tamanho e ocultar, e a faixa com ocultos e layouts.

O layout é guardado em `preferencias_usuario.layout_visao_geral` como uma lista de `{id, largura, altura, oculto}`, validada pela API (até 40 itens, identificadores únicos, larguras e alturas conhecidas). O layout igual ao padrão é salvo como vazio, para que mudanças futuras no padrão cheguem a todos. Cartões novos de versões futuras entram sozinhos ao lado do vizinho que vinham depois no padrão, e tamanhos que um cartão não aceita são corrigidos na hora. Quando o layout deixa espaços na grade, eles aparecem como compartimentos vazios da mesma caixa.

Para quem desenvolve

O componente `BentoPersonalizavel` (`web/src/ts/componentes/bento-personalizavel.ts`) serve para qualquer grade: recebe a grade, a faixa, o botão, as definições dos cartões (`id`, nome, larguras e alturas permitidas e o padrão), os modelos e uma função para salvar. As regras de ordenação e normalização ficam em `web/src/ts/nucleo/layout.ts`, com testes em `web/tests/layout.test.ts`. Na visão geral, os cartões ficam em `CARTOES` e os modelos em `MODELOS_LAYOUT` (`web/src/ts/paginas/visao-geral.ts`); cada cartão do HTML precisa do atributo `data-cartao`.

Copyright (©) 2026 Erik Pimenta

N.8 Outras mudanças

Onde	O que mudou
Primeiros passos	Duas etapas novas: verificação em duas etapas de um administrador e um alerta de métrica ativo. O guia passa a 8 etapas, em quatro colunas em telas largas
Paleta de comandos	Comandos para criar alerta, personalizar a visão geral e abrir a verificação em duas etapas; `g` `l` abre Alertas
Notificações	Categoria **Alertas de métricas** no filtro e nas preferências por categoria
Usuários	Emblema **Duas etapas** no perfil e a ação **Redefinir verificação em duas etapas**
Auditoria	Grupo **Alertas** e rótulos das novas ações de segurança
Integrações	Evento `alerta.disparado` no histórico de entregas
Diagnóstico	Verificação **Verificação em duas etapas**: avisa quando há administradores entrando só com a senha
Retenção	Disparos já resolvidos saem depois de `BENTO_RETENCAO_ALERTAS` dias (180 por padrão), na limpeza diária e na aba Manutenção
Agendador	Nova tarefa a cada minuto: avaliação dos alertas vencidos

N.9 Testes da versão

A suíte passou a 107 testes da API e 28 da interface. Os novos cobrem os vetores da RFC 6238 e a tolerância de passo, o fluxo completo do login em duas etapas (desafio, código repetido, código de recuperação usado uma vez, bloqueio após 5 erros, desligar e gerar novos códigos), a regra por papel fechando as outras rotas, a redefinição pelo administrador com hierarquia, permissões e validação dos alertas, disparo, normalização, silêncio, pausa, a fila do agendador, o limite de regras, a previsão sobre uma série conhecida, a detecção de anomalias com ruído e picos, a regressão linear, o layout da visão geral na API e a normalização do layout na interface.

```
npm test                          # 107 testes da API e 28 da interface
node --import tsx --test api/test/dois-fatores.test.ts
node --import tsx --test api/test/alertas-insights.test.ts
```

N.10 Problemas comuns das novidades

Sintoma	O que fazer
“Código incorreto” com o código certo	O relógio do celular está fora de hora. Deixe data e hora automáticas e tente o código seguinte.
Perdi o celular e os códigos	Um administrador abre a sua conta em Usuários e usa **Redefinir 2 etapas**.

Copyright (©) 2026 Erik Pimenta

Sintoma	O que fazer
Todos precisam reconfigurar a verificação	O `BENTO_SEGREDO_JWT` mudou. Volte o segredo anterior ou redefina a verificação de cada pessoa.
Só consigo abrir Configurações	O seu papel exige a verificação. Ative em Segurança; o resto do painel volta na hora.
O alerta não dispara	Confira se está ativo, se o silêncio ainda está correndo, se há base no período anterior (modo variação) e use **Testar** para ver o valor medido.
Avisos de alerta não chegam no Slack	Marque “Avisar também nas integrações” e confira a integração e o histórico de entregas.
“Pouco histórico ainda” na previsão	Há menos de 3 semanas de vendas. A projeção melhora sozinha com o tempo.
Erro ao salvar o idioma padrão da empresa	Corrigido na 1.5.0: as opções agora são `pt-BR`, `en-US` e `es-ES`, as mesmas que a API aceita.

Copyright (©) 2026 Erik Pimenta

01

Apresentação

O Bento é um painel administrativo para produtos SaaS. Este manual mostra como instalar, usar, adaptar, operar e estender cada parte do projeto, da interface em Tailwind CSS à API e ao banco de dados.

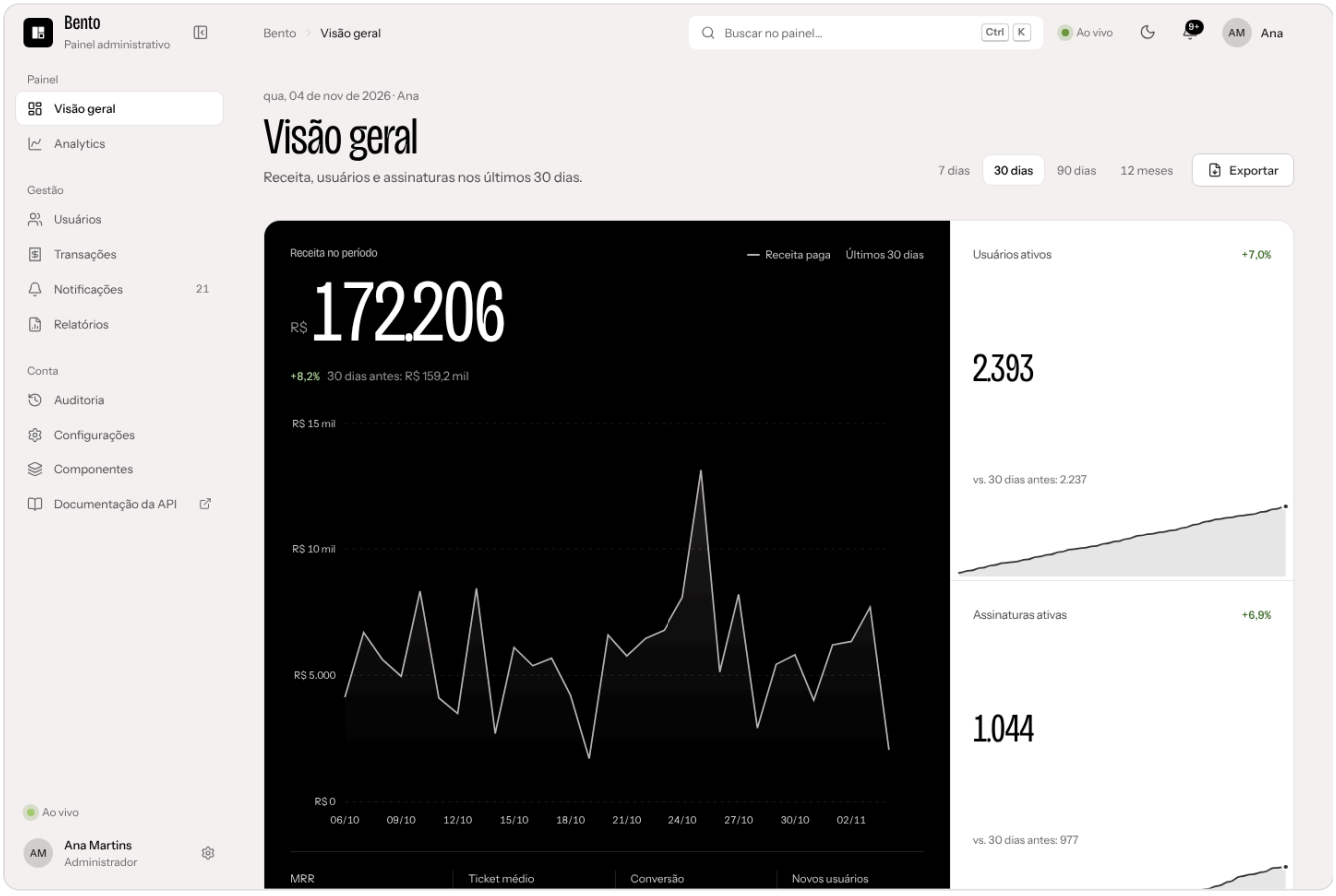


Figura 1.1 Visão geral: a receita do período na tampa escura e os indicadores nos compartimentos da caixa.

1.1 O que vem no projeto

O repositório traz uma aplicação completa, pronta para rodar com um comando e organizada para ser lida, copiada e modificada. As partes conversam por uma API REST documentada, então você pode trocar qualquer uma delas sem reescrever as outras.

- **Interface em TypeScript** com onze páginas: visão geral, analytics, usuários, transações, auditoria, notificações, relatórios, configurações, componentes, entrada e página não encontrada. Modo escuro, 16 paletas, densidade compacta, menu recolhível, paleta de comandos com itens recentes, atalhos de teclado, colunas configuráveis e preferências por pessoa.

Copyright (©) 2026 Erik Pimenta

- **Biblioteca de componentes em Tailwind CSS** com mais de 45 grupos: botões, formulários, tabelas, gavetas, kanban, calendário, fatura, preços, páginas de erro, modelos de grade bento e os componentes de operação (faixa de manutenção, verificações, entregas, importação e backups).
- **API REST em TypeScript** com autenticação por sessão, permissões por papel, notificações em tempo real, reembolsos auditados, registro de atividades, importação de usuários por CSV, relatórios em CSV e PDF, agendador, integrações com histórico de entregas, modo de manutenção, backups, retenção de dados, sondas de saúde, métricas do Prometheus e documentação interativa.
- **Banco PostgreSQL** com migrações versionadas e dados de demonstração. Sem PostgreSQL instalado, a API usa o PGlite, o mesmo PostgreSQL embutido no processo.
- **Ferramentas de operação**: diagnóstico do ambiente, backup e restauração completos, limpeza pela política de retenção, script de versão, scripts de inicialização para Windows, Linux e macOS, imagem Docker, Docker Compose, testes automatizados, cobertura, Dependabot e integração contínua no GitHub Actions.

1.2 Novidades da versão 1.4.0

A 1.4.0 é uma versão de qualidade de uso, de configuração e de manutenção: o painel ficou mais fácil de ajustar para cada pessoa, mais seguro de colocar no ar e mais simples de operar no dia a dia. A paleta de cores, as fontes e a identidade continuam as mesmas.

Área	O que mudou	Onde ler
Preferências	Página inicial depois do login, linhas por página das tabelas, animações reduzidas e atalhos de uma tecla que podem ser desligados	3.11, 5.5
Tabelas	Botão **Colunas** em Usuários, Transações e Auditoria para esconder colunas, guardado no navegador	3.4, 5.4
Paleta de comandos	Grupo **Abertos recentemente** com os últimos usuários e transações abertos, e o comando de novidades	3.1, 5.5
Usuários	Importação por planilha CSV com prévia linha a linha, modelo para baixar e filtros na URL	3.5, 6.4
Visão geral	Guia de **Primeiros passos** para administradores, com o que falta para o painel ficar pronto	2.5, 3.2
Integrações	Histórico de entregas com código HTTP, tempo de resposta e tentativas; novas tentativas automáticas e reenvio manual	10.4
Manutenção	Aba nova com verificações do ambiente, modo somente leitura, backups e retenção de dados	3.10, 12
Operação	`npm run diagnostico`, `backup`, `restaurar`, `limpar` e `versao`; sondas `/saude/vivo` e `/saude/pronto`; métricas do Prometheus	12
Configuração	Variáveis validadas com avisos claros, segredo de exemplo recusado em produção, novas variáveis de backup, retenção e métricas	11.1, 11.2
Erros	Cabeçalho `X-Request-Id` em toda resposta e código curto do erro nas mensagens da interface	12.6
Interface	Página 404 própria, janela de novidades da versão e faixa de manutenção ao vivo	3.12, 12.2

Copyright (©) 2026 Erik Pimenta

Área	O que mudou	Onde ler
Banco	Migração `006_operacao_preferencias.sql`: preferências novas, tabela `entregas_integracao`, permissão `usuarios.importar` e índice de sessões	7.2 e o documento do banco
Engenharia	Versão lida de um arquivo só, comentários removidos do código, Dependabot, `.nvmrc`, auditoria de dependências e teste de backup contra PostgreSQL na CI	13

1.3 Versões anteriores

Versão	O que mudou	Onde ler
1.3.0	Notas internas na gaveta de cada usuário, com fixar no topo, edição e remoção; visões salvas de filtros em Transações e Auditoria; permissão `usuarios.anotar`	3.4, 3.6, 7.2
1.2.0	Identidade “caixa única”, tipografia fina e condensada, status como ponto de cor e variações com sinal; nenhuma mudança na API ou no banco	4.2
1.1.0	Página Transações com reembolso auditado, página Auditoria, paleta de comandos e atalhos, aba Status do sistema e auditoria de segurança com testes	3.6, 3.7, 11.5
1.0.0	Primeira versão: visão geral, analytics, usuários, notificações, relatórios, configurações, componentes e API completa	3

1.4 Tecnologias

Camada	Tecnologia	Função
Estilos	Tailwind CSS 4	Tokens de tema, variantes, componentes e utilitários escritos direto no CSS
Interface	TypeScript 5.9 (strict) e HTML5	Páginas e controladores tipados, sem framework, fáceis de ler e portar
Gráficos	ApexCharts 4.7.0	Áreas, barras, rosca, radial, mapa de calor e mini gráficos
Ícones	Lucide	Ícones em SVG embutidos sob demanda
Fontes	Instrument Sans, Bricolage Grotesque, IBM Plex Mono	Texto e rótulos; títulos e números finos e condensados; códigos
Build	Vite 7	Servidor de desenvolvimento com recarga e build multipágina
API	Node.js 22, TypeScript 5.9, Fastify 5	Servidor HTTP, rotas, plugins e documentação OpenAPI
Validação	Zod 4	Esquemas de entrada e saída de cada rota
Banco	PostgreSQL 18 ou PGlite 0.5	Mesmo SQL nos dois: servidor externo ou embutido
Arquivos	PDFKit, zlib	Relatórios em PDF paginados e backups compactados

Copyright (©) 2026 Erik Pimenta

Camada	Tecnologia	Função
Infraestrutura	Docker Compose, GitHub Actions, Dependabot	Execução com um comando, verificação a cada envio e atualização das dependências

1.5 Estrutura de pastas

O projeto usa workspaces do npm: a pasta `web` guarda a interface e a pasta `api` guarda o servidor. Os comandos da raiz chamam os dois.

```
Data-Driven-Admin-Panel/
  web/                          interface
    *.html                      uma página por módulo, mais a 404
    src/css/
      tema/                     cores, paletas, tipografia, medidas e variantes
      base/                     documento, tipografia, formulários e impressão
      layout/                   casca, grade bento, página e autenticação
      componentes/              componentes do painel e de operação
      kit/                      kit de interface
      paginas/                  ajustes de cada página
      identidade.css            identidade “caixa única”
    src/ts/
      nucleo/                   tipos, API, sessão, tema, tempo real, recentes e colunas
      componentes/              tabela, gráficos, gavetas, diálogos, avisos e importação
      layout/                   menu, cabeçalho, comandos, atalhos, manutenção e novidades
      paginas/                  controlador de cada página
    public/                     favicon, logo e script de tema
    tests/                      testes do núcleo
  api/                          API em TypeScript
    src/modulos/                auth, visão geral, usuários, transações, sistema...
    src/operacao/               backup, diagnóstico, manutenção, métricas e retenção
    src/banco/                  conexão, migrações, semente e administrador inicial
    src/relatorios/             geração de CSV e PDF
    src/tempo-real/             barramento de eventos
    src/cli.ts                  comandos de linha: migrar, diagnostico, backup...
    migracoes/                  esquema SQL (001 a 006)
    test/                       testes da API
  scripts/                      desenvolvimento, versão e .env no Windows
  docs/                         manuais em PDF e imagens
  .github/                      CI e Dependabot
  VERSION                       versão única do projeto
  iniciar.cmd, iniciar.sh       inicialização com um comando
  Dockerfile, docker-compose.yml
```

1.6 Como ler este manual

Os capítulos seguem a ordem em que você vai precisar deles. Para colocar o painel no ar, leia os capítulos 2, 11 e 12. Para conhecer as telas, o capítulo 3. Para mudar o visual ou criar páginas, os capítulos 4 e 5. Para integrar outro sistema, os capítulos 6 a 10. O capítulo 14 reúne os problemas mais comuns e como resolvê-los.

Copyright (©) 2026 Erik Pimenta

A arquitetura do banco de dados tem um documento próprio, `Banco-de-Dados-Bento.pdf`, com o diagrama de relacionamentos e todas as tabelas, campos, índices e restrições. O código está em https://github.com/ravelroot/Data-Driven-Admin-Panel.

Copyright (©) 2026 Erik Pimenta

02

Instalação

O Bento roda de duas formas: com Docker, que sobe o painel, a API e o PostgreSQL juntos, ou só com o Node.js, usando o banco embutido. As duas usam os mesmos scripts.

2.1 Requisitos

Para rodar com	Você precisa de	Observação
Docker	Docker com Docker Compose v2	Sobe o PostgreSQL 18 em um contêiner e guarda os dados e os backups em volumes
Node.js	Node.js 22 ou mais novo, com npm	Usa o PGlite: nada mais para instalar. O arquivo `.nvmrc` indica a versão para o nvm e o fnm
Navegador	Chrome, Edge, Firefox ou Safari atuais	O painel usa diálogos nativos, módulos ES e Server-Sent Events

Por padrão o painel usa a porta `8080`. Em desenvolvimento, o Vite usa também a `5173`.

2.2 Com Docker

1. Baixe o projeto pelo botão **Code › Download ZIP** do GitHub e descompacte, ou clone com `git clone https://github.com/ravelroot/Data-Driven-Admin-Panel.git`.
2. No Windows, dê dois cliques em `iniciar.cmd`. No Linux ou no macOS, abra um terminal na pasta e rode `./iniciar.sh`.
3. Na primeira vez, o script cria o arquivo `.env` a partir do `.env.example`, com uma senha aleatória para o banco e um segredo aleatório para as sessões.
4. O script roda `docker compose up -d --build`, espera a rota `/api/v1/saude` responder e abre o navegador em http://localhost:8080.

Comandos úteis depois da primeira vez:

Comando	O que faz
`docker compose up -d --build`	Subir ou atualizar depois de mudar o código
`docker compose logs -f bento`	Acompanhar os logs da API
`docker compose ps`	Ver se os contêineres estão saudáveis (a verificação usa `/api/v1/saude/pronto`)

Copyright (©) 2026 Erik Pimenta

Comando	O que faz
`docker compose exec bento node api/dist/cli.js diagnostico`	Conferir ambiente, configuração, banco e segurança
`docker compose exec bento node api/dist/cli.js backup`	Gravar um backup no volume de dados
`docker compose down`	Parar, mantendo os dados
`docker compose down -v`	Parar e apagar o banco e os backups (volta aos dados de demonstração)

Onde ficam os dados

O PostgreSQL guarda tudo no volume `bento_dados-postgres`, e a pasta `dados/` do Bento (backups automáticos) fica no volume `bento_dados-bento`. Os dois sobrevivem a `docker compose down` e a atualizações da imagem; só `down -v` apaga.

2.3 Sem Docker

Se o Docker não estiver instalado ou não estiver rodando, os mesmos scripts usam o Node.js: instalam as dependências, constroem a interface e a API e iniciam o servidor. Para fazer isso à mão:

```
git clone https://github.com/ravelroot/Data-Driven-Admin-Panel.git
cd Data-Driven-Admin-Panel
npm install
npm run build
npm start
```

Sem a variável `DATABASE_URL`, a API usa o PGlite e guarda o banco na pasta `dados/pglite`. Na primeira vez ela cria as tabelas e os dados de demonstração em poucos segundos. Se `BENTO_SEGREDO_JWT` não estiver definido, um segredo aleatório é gerado e salvo em `dados/segredo`.

Para usar um PostgreSQL que você já tem, crie um banco vazio e defina a conexão antes de iniciar:

```
DATABASE_URL=postgres://usuario:senha@servidor:5432/bento npm start
```

As migrações rodam sozinhas a cada inicialização. Para rodá-las sem subir o servidor, use `npm run migrar`. Para conferir se está tudo certo antes de abrir o painel, rode `npm run diagnostico` (capítulo 12).

2.4 Primeiro acesso

Abra http://localhost:8080 e entre com uma das contas de demonstração. Todas usam a senha `bento123`.

E-mail	Papel	O que vê
admin@bento.local	Administrador	Tudo, inclusive dados da empresa, status do sistema, manutenção e permissões

Copyright (©) 2026 Erik Pimenta

E-mail	Papel	O que vê
gerente@bento.local	Gerente	Tudo, menos dados da empresa, status do sistema, manutenção, exclusão de usuários e permissões; pode reembolsar, importar usuários e ver a auditoria
analista@bento.local	Analista	Visão geral, analytics, transações, usuários (só leitura) e relatórios
suporte@bento.local	Suporte	Visão geral, transações e usuários (ver, editar, bloquear e anotar)

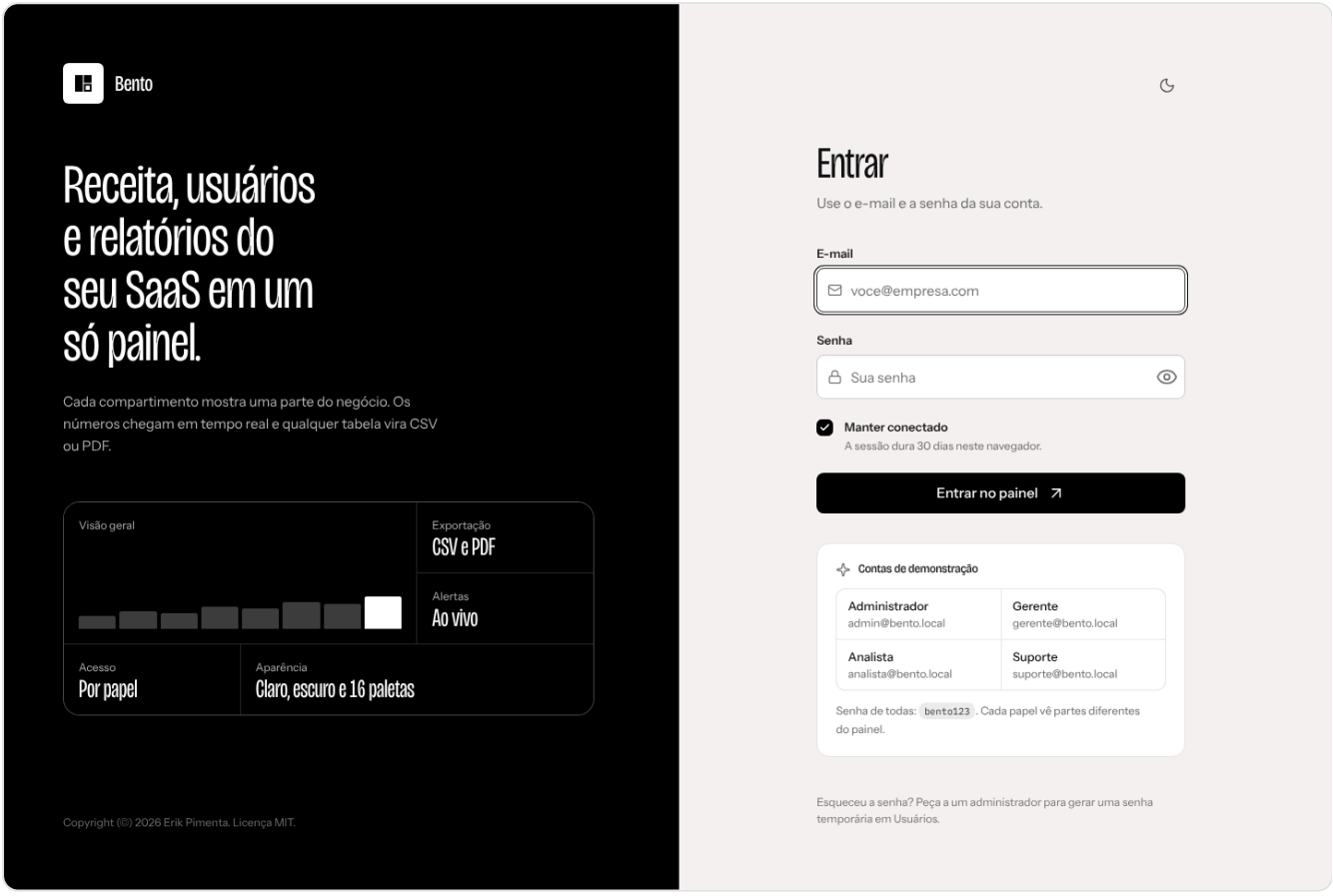


Figura 2.1 Tela de entrada com as contas de demonstração.

Antes de publicar

As contas de demonstração existem só para conhecer o painel. Em um servidor público, comece com o banco vazio (seção 2.7) ou bloqueie e exclua essas contas em Usuários. O diagnóstico avisa enquanto alguma conta da equipe usar a senha `bento123`, e em produção isso conta como erro.

2.5 Primeiros passos no painel

Quem tem a permissão `configuracoes.sistema` vê, no topo da visão geral, o guia **Primeiros passos**: uma lista do que falta para o painel ficar pronto para a equipe, com a barra de progresso e um botão que leva direto à tela certa.

Passo	Fica pronto quando	Botão
Dados da empresa	O nome da empresa deixa de ser “Bento”	Abrir Empresa

Passo	Fica pronto quando	Botão
Senhas de demonstração	Nenhuma conta da equipe usa a senha `bento123`	Revisar contas
Equipe cadastrada	Há mais de uma conta ativa com acesso ao painel	Cadastrar
Uma integração ativa	Pelo menos uma integração está ligada	Conectar
Um relatório agendado	Existe um envio recorrente ativo	Agendar
Backups	O backup automático está ligado ou já existe um backup gravado	Ver status

O guia some quando tudo está pronto. O botão **Ocultar** esconde o guia para você; para mostrá-lo de novo, ligue a opção em Configurações › Preferências.

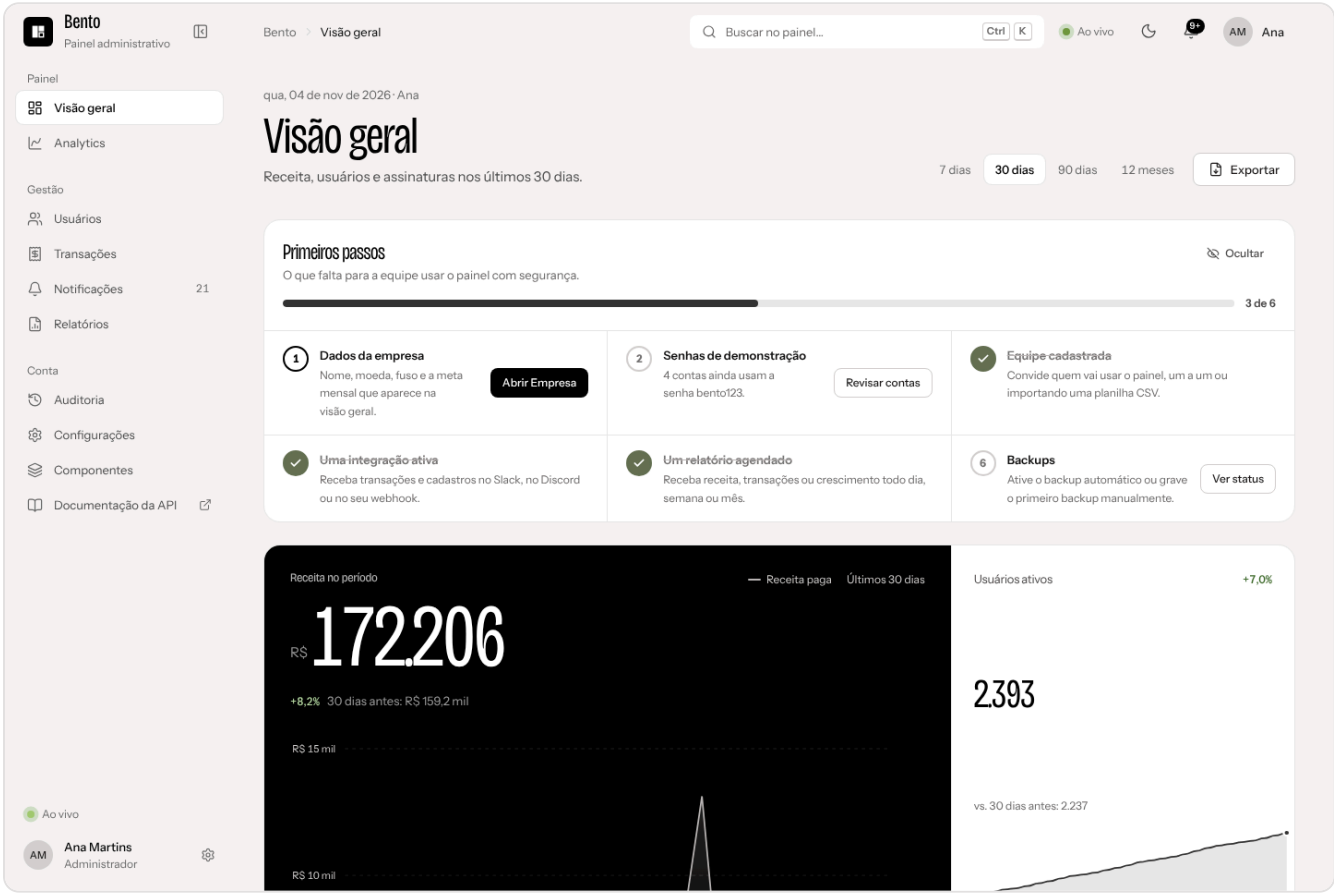


Figura 2.2 Primeiros passos no topo da visão geral, com o passo atual destacado.

2.6 Ambiente de desenvolvimento

```
npm run dev
```

O comando sobe a API na porta 8080 com recarga automática quando o TypeScript muda, e o Vite em http://localhost:5173. O Vite recarrega a página a cada mudança no TypeScript, no Tailwind CSS ou no HTML e encaminha tudo que começa com `/api` para a API.

Copyright (©) 2026 Erik Pimenta

Abra o endereço do Vite durante o desenvolvimento. O endereço da porta 8080 serve a versão construída por `npm run build`.

2.7 Começando com o banco vazio

Para usar o Bento com os seus próprios dados, desligue a semente e o simulador e peça à API para criar o primeiro administrador. No `.env`:

```
BENTO_SEMEAR=nao
BENTO_SIMULADOR=false
BENTO_ADMIN_EMAIL=voce@suaempresa.com
BENTO_ADMIN_SENHA=uma-senha-com-8-ou-mais-caracteres
BENTO_ADMIN_NOME=Seu Nome
```

Na inicialização, se ainda não existir uma conta com esse e-mail, a API cria um administrador ativo e registra o evento nas atividades. Se o e-mail já existir, nada muda. Depois de entrar, cadastre a equipe em Usuários (uma a uma ou importando uma planilha, seção 3.5) e apague as três variáveis `BENTO_ADMIN_*`.

Em desenvolvimento, `npm run admin` cria a mesma conta sem subir o servidor. Com Docker, as variáveis passam do `.env` para o contêiner automaticamente.

Já usou com dados de demonstração?

A semente só roda em banco vazio. Para recomeçar, apague a pasta `dados/` (PGlite) ou rode `docker compose down -v` (PostgreSQL) antes de mudar o `.env`.

2.8 Em produção

A imagem Docker já roda a versão construída, com usuário sem privilégios e verificação de saúde pela sonda de prontidão. Antes de abrir o painel na internet, confira:

- **Segredo próprio.** Defina `BENTO_SEGREDO_JWT` com pelo menos 32 caracteres aleatórios. Ele assina as sessões e cifra os segredos das integrações. Com `NODE_ENV=production` (o padrão da imagem), a API se recusa a subir com o valor de exemplo `troque-esta-chave` ou com menos de 32 caracteres.
- **HTTPS.** Coloque o Bento atrás de um proxy reverso com certificado (Caddy, Nginx, Traefik ou o balanceador da sua nuvem) e defina `BENTO_HTTPS=true` para cookies seguros e HSTS.
- **Proxy confiável.** Com proxy reverso, defina `BENTO_PROXY=true` para que limites de requisição, sessões e atividades registrem o IP real.
- **Sem demonstração.** Use `BENTO_SEMEAR=nao`, `BENTO_SIMULADOR=false` e o administrador inicial da seção anterior.
- **Backups.** Deixe `BENTO_BACKUP_AUTOMATICO=diario` (padrão do `.env.example` e do Docker Compose) e copie a pasta de backups para fora do servidor de tempos em tempos (seção 12.3).
- **Monitoramento.** Aponte o orquestrador para `/api/v1/saude/pronto` e, se usar Prometheus, defina `BENTO_METRICAS_TOKEN` (seção 12.5).
- **Diagnóstico.** Rode `npm run diagnostico` (ou o comando equivalente no contêiner) e resolva os itens marcados como erro ou aviso.

Exemplo de proxy reverso com Caddy, que obtém o certificado sozinho:

Copyright (©) 2026 Erik Pimenta

```
painel.suaempresa.com {
  reverse_proxy localhost:8080 {
    flush_interval -1
  }
}
```

O `flush_interval -1` entrega os eventos em tempo real sem atraso. No Nginx, o equivalente é `proxy_buffering off` na rota `/api/v1/notificacoes/fluxo`.

2.9 Atualizando de uma versão anterior

1. Faça um backup antes: `npm run backup` (com o servidor parado, se usar PGlite) ou o botão **Fazer backup agora** em Configurações › Manutenção.
2. Baixe a versão nova com `git pull` ou um ZIP novo, mantendo o seu `.env` e a pasta `dados/`.
3. Rode `npm install` e `npm run build`, ou `docker compose up -d --build` com Docker.
4. Inicie o servidor. A migração `006_operacao_preferencias.sql` roda sozinha, em uma transação: se falhar, nada muda e a API não sobe.
5. Rode `npm run diagnostico` e confira os avisos novos da 1.4.0, como as senhas de demonstração e o backup automático.

A 1.4.0 não muda nenhuma rota existente de forma incompatível: as rotas novas e os campos novos só se somam aos anteriores.

Copyright (©) 2026 Erik Pimenta

03

Usando o painel

Cada página do Bento cuida de uma parte do negócio. Este capítulo passa por todas, na ordem em que aparecem no menu, e termina com as preferências de cada pessoa e o uso no celular.

3.1 Menu, cabeçalho e paleta de comandos

O menu lateral, no mesmo tom do fundo, agrupa as páginas em Painel, Gestão e Conta. O item ativo aparece como um compartimento branco. Em telas grandes, o botão ao lado da marca recolhe o menu para só ícones, e a escolha fica salva no navegador. No celular, o menu vira uma gaveta aberta pelo botão do cabeçalho. Itens que a pessoa não tem permissão para ver não aparecem.

O cabeçalho mostra a trilha de navegação, a paleta de comandos, o indicador de conexão em tempo real, a troca de tema claro e escuro, a central de notificações com o número de não lidas e o menu da conta. Quando o modo de manutenção está ligado, uma faixa logo abaixo do cabeçalho avisa todo mundo (seção 12.2).

Paleta de comandos

A paleta encontra usuários por nome ou e-mail e transações pelo código ou pelo cliente, e lista comandos: ir para cada página, cadastrar ou importar usuários, exportar transações, enviar aviso, ver o status do sistema, abrir a manutenção, ajustar a aparência e as preferências, ver as novidades da versão, abrir a documentação da API e sair. Comandos que a pessoa não pode usar não aparecem.

Com o campo vazio, o grupo **Abertos recentemente** mostra os últimos oito usuários e transações que você abriu neste navegador, para voltar a eles com um Enter. A lista é separada por pessoa e tem o comando **Limpar a lista de recentes**.

Copyright (©) 2026 Erik Pimenta

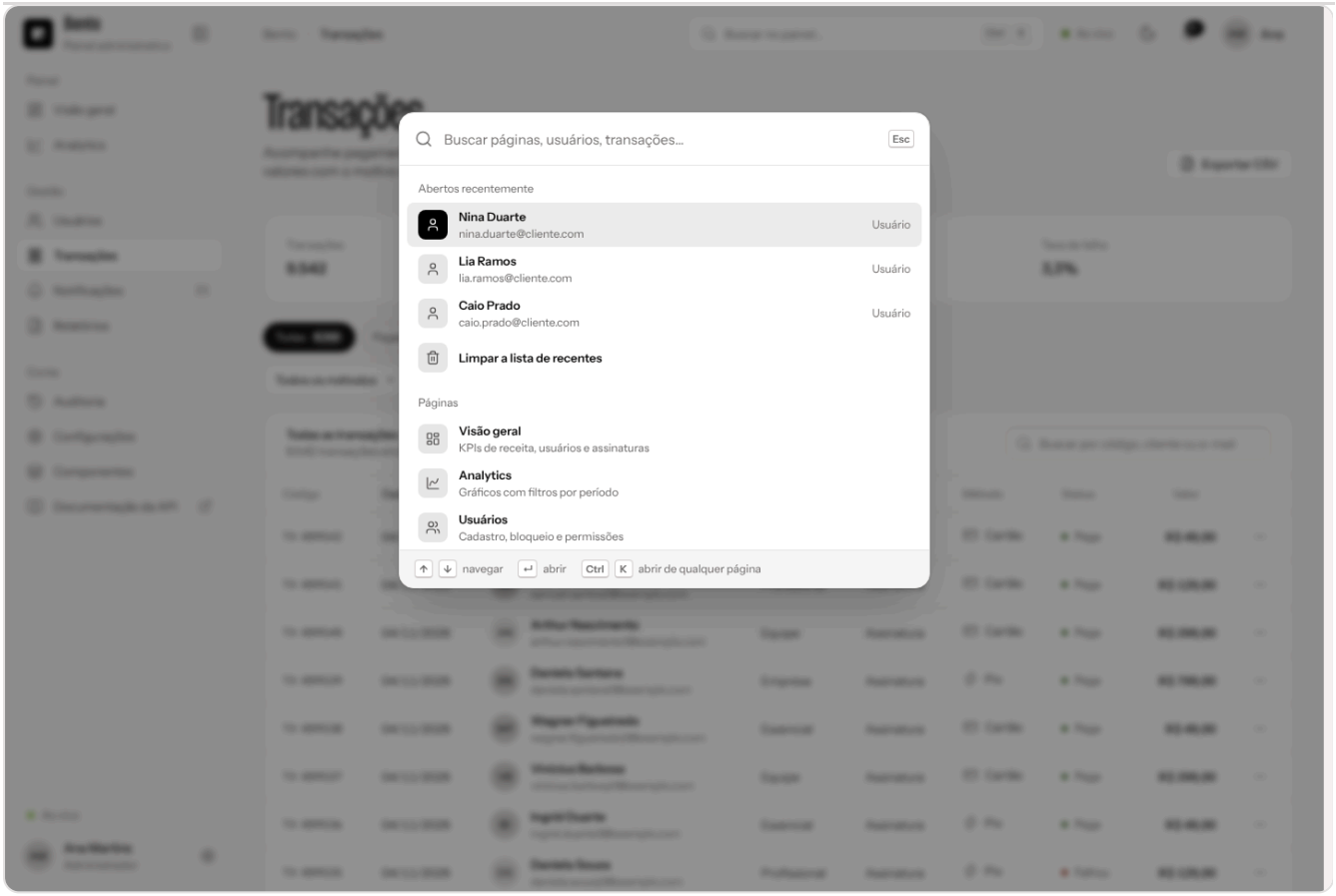


Figura 3.1 Paleta de comandos com os itens abertos recentemente.

Atalhos de teclado

Os atalhos de uma tecla só valem quando nenhum campo está em edição e podem ser desligados em Configurações › Preferências; `Ctrl` + `K` funciona sempre. `?` abre a folha com todos eles.

Atalho	O que faz
`Ctrl` `K` ou `⌘` `K`	Abre a paleta de comandos de qualquer página, mesmo com um campo em edição
`/`	Abre a paleta de comandos
`?`	Abre a folha de atalhos
`g` `v` · `g` `a` · `g` `u`	Visão geral, Analytics e Usuários
`g` `t` · `g` `n` · `g` `r`	Transações, Notificações e Relatórios
`g` `d` · `g` `c` · `g` `k`	Auditoria, Configurações e Componentes
`↑` `↓`	Percorre os resultados da paleta
`Enter`	Abre o resultado ou executa o comando selecionado
`Esc`	Fecha a paleta, a folha de atalhos, gavetas, menus e diálogos

Nos atalhos com `g`, aperte `g`, solte e aperte a letra logo em seguida.

Copyright (©) 2026 Erik Pimenta

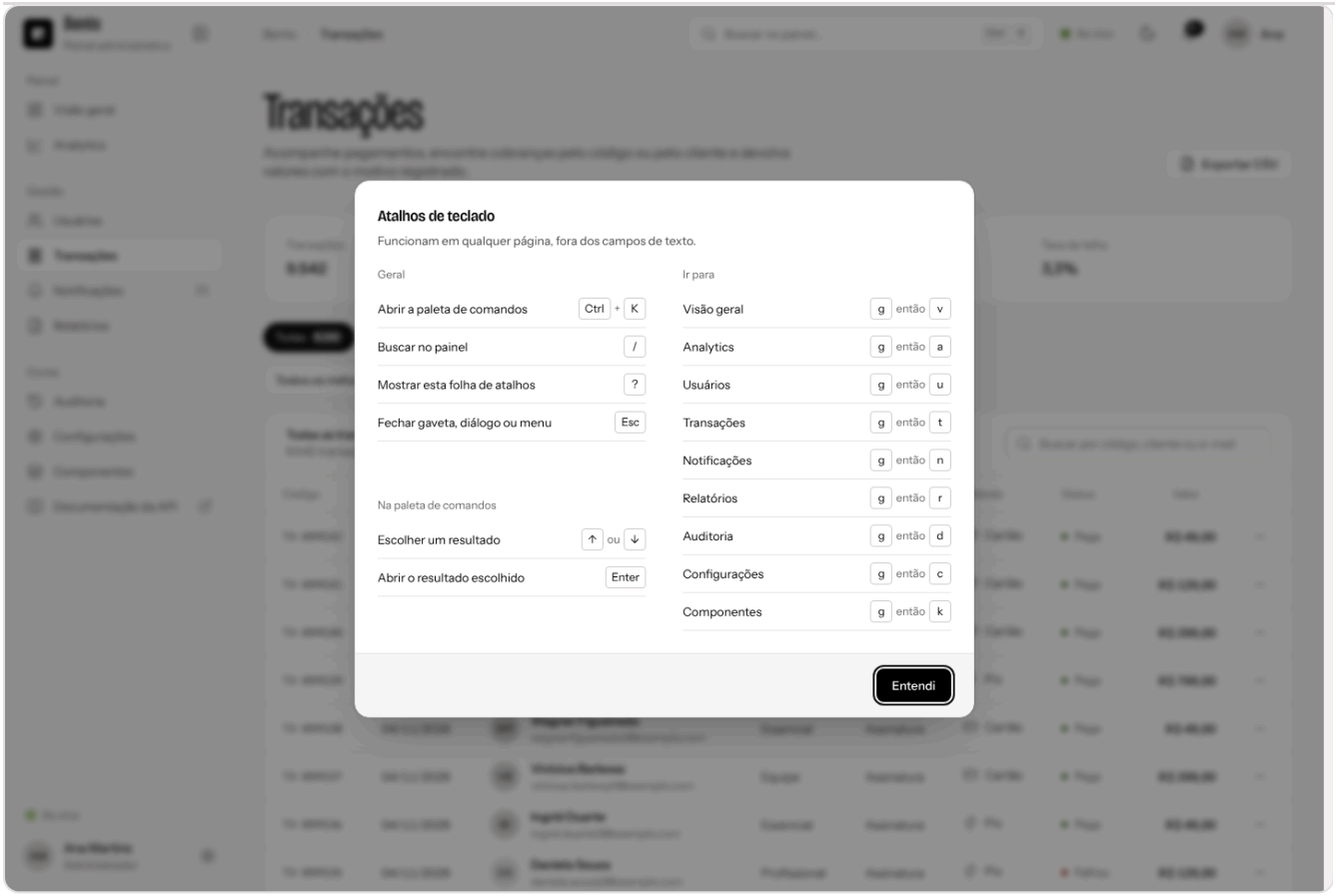


Figura 3.2 Folha de atalhos aberta com a tecla ?.

3.2 Visão geral

A página inicial resume o negócio no período escolhido no seletor do topo: 7 dias, 30 dias, 90 dias ou 12 meses. O cartão principal mostra a receita paga com o gráfico do período e, embaixo, MRR, ticket médio, conversão e usuários novos.

- **Indicadores com tendência**: usuários ativos, assinaturas ativas, crescimento do MRR, cancelamentos e outros. A variação aparece com o sinal + ou −, o percentual e a cor verde ou vermelha, comparando com o período anterior de mesmo tamanho (em cancelamentos, a lógica se inverte).
- **Receita mês a mês** nos últimos 12 meses, com reembolsos e a linha da meta.
- **Assinaturas por plano**, tráfego por canal e o medidor da meta do mês.
- **Transações recentes e atividades da equipe**, atualizadas ao vivo. Cada transação abre uma gaveta com os detalhes e a assinatura ligada a ela.
- **Primeiros passos** no topo, para administradores, enquanto houver algo a configurar (seção 2.5).

O botão **Exportar** leva à página de relatórios, para gerar o arquivo do período que você quiser. A visão geral é a página inicial padrão; cada pessoa pode escolher outra em Preferências.

Copyright (©) 2026 Erik Pimenta

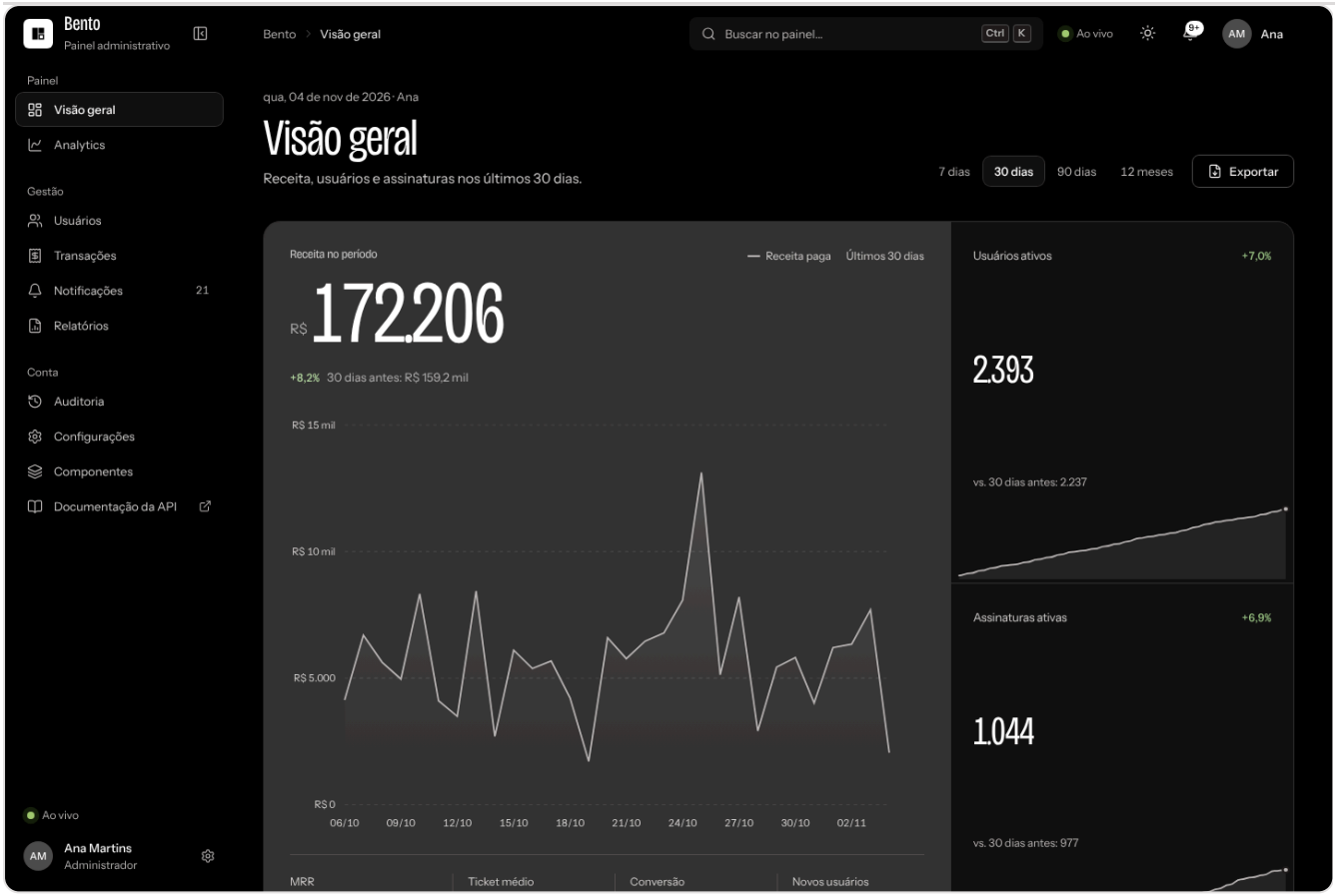


Figura 3.3 A mesma página no tema escuro.

3.3 Analytics

Analytics aprofunda os números com filtros de intervalo de datas, períodos prontos e agrupamento por dia, semana ou mês. Os filtros ficam na URL, então um link copiado abre a mesma análise.

- **Resumo** com receita, transações, usuários novos, visitantes, conversão, ticket médio, cancelamentos e MRR, cada um com a variação.
- **Receita e reembolsos**, usuários novos e ativos, assinaturas novas e cancelamentos ao longo do tempo.
- **Funil de conversão** (visitantes, cadastros, em teste, assinantes), dispositivos, canais com taxa de conversão e os oito países com mais visitantes.
- **Receita por plano**, mapa de calor das compras por dia da semana e hora, e retenção mensal por coorte dos últimos seis meses.

Copyright (©) 2026 Erik Pimenta

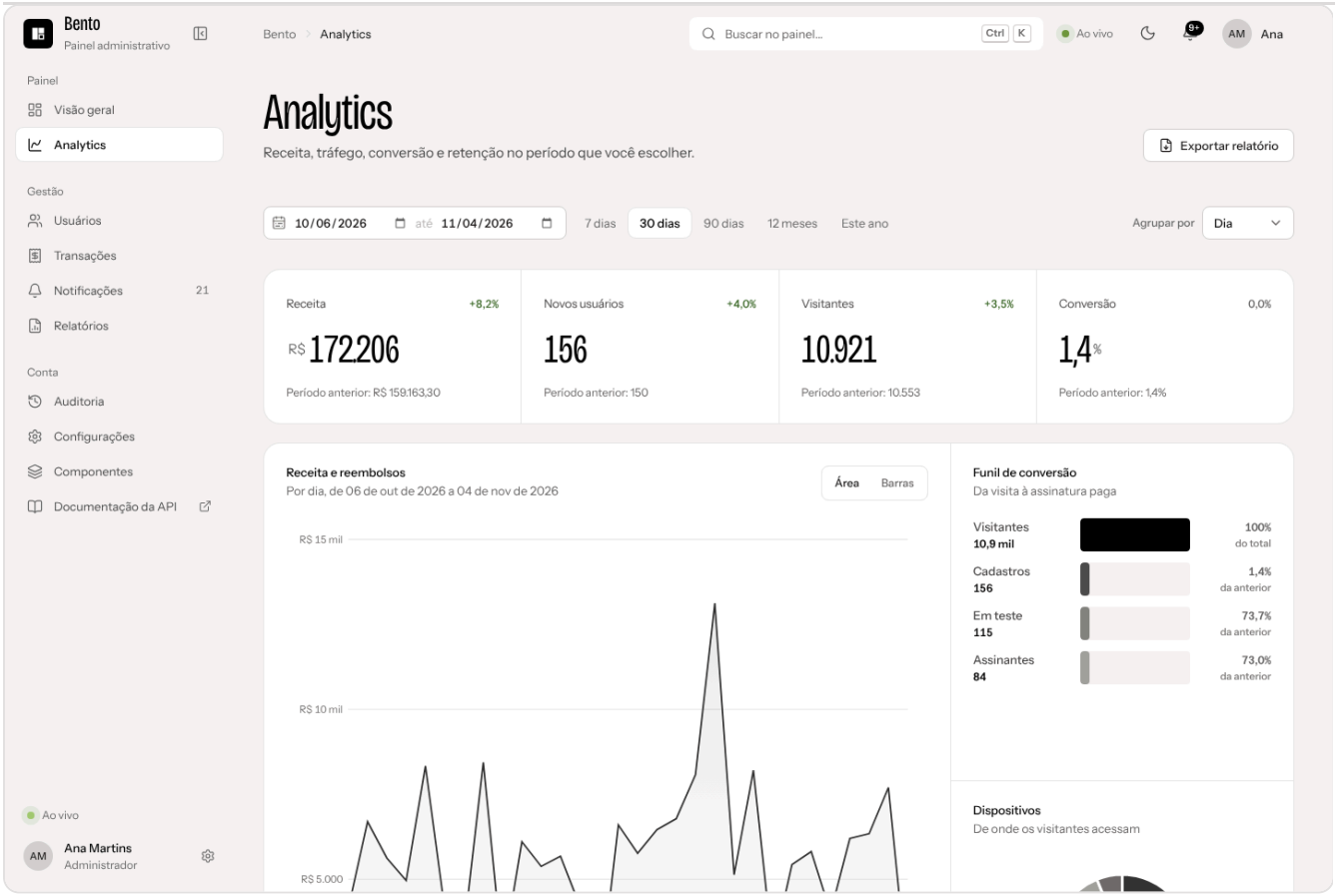


Figura 3.4 Analytics com filtros de período, funil e dispositivos.

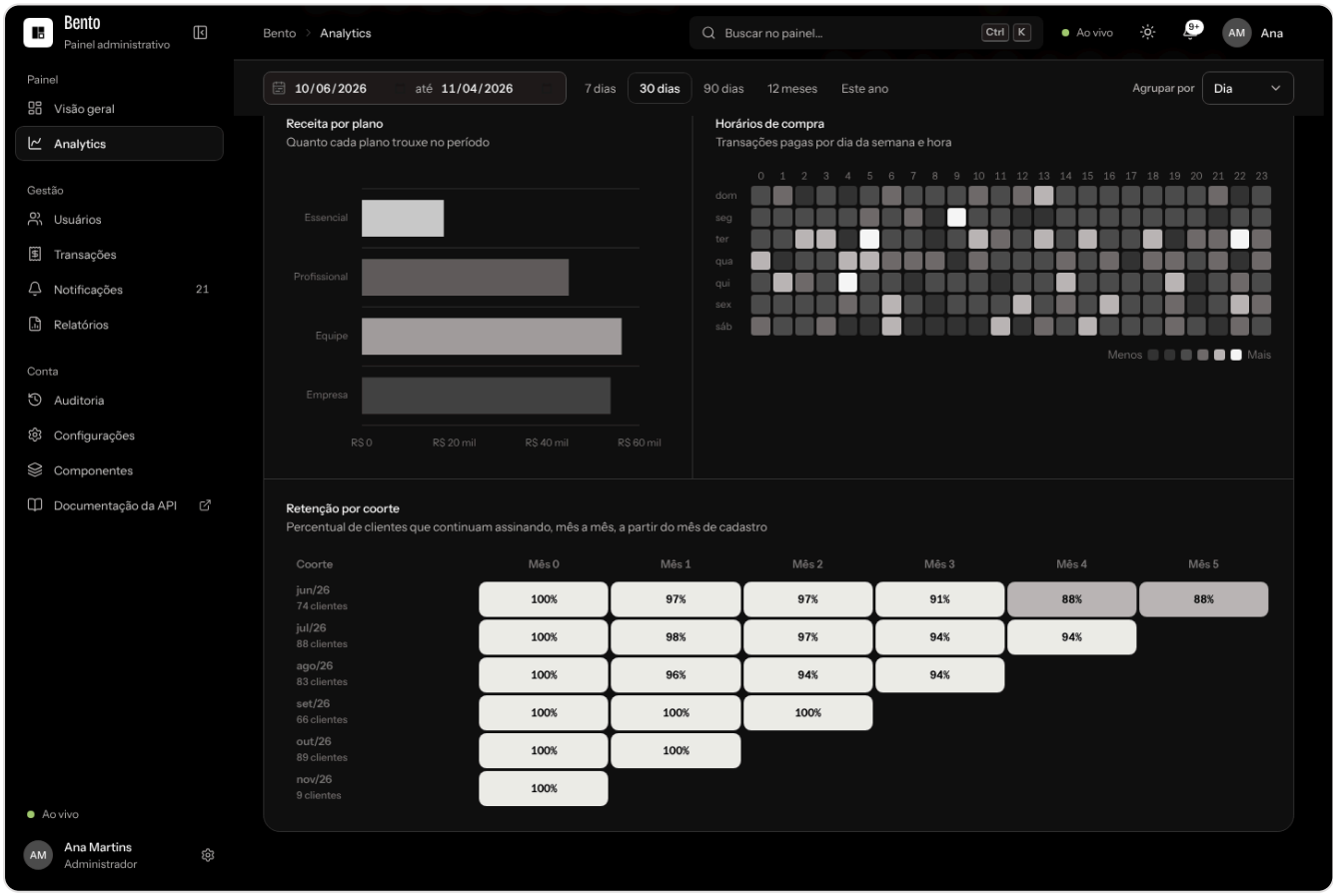


Figura 3.5 Mapa de calor e retenção por coorte no tema escuro.

Copyright (©) 2026 Erik Pimenta

3.4 Usuários

A lista de usuários tem busca instantânea por nome e e-mail, filtros por status, papel e plano, contagens por status, colunas ordenáveis e paginação. Um link como `/usuarios?papel=admin`, `?status=bloqueado` ou `?q=ana` já abre a lista filtrada.

- **Cadastrar**: o botão **Novo usuário** abre uma gaveta com nome, e-mail, papel, cargo, empresa, telefone, país e cidade. Sem senha informada, o Bento gera uma senha temporária de 12 caracteres e mostra uma única vez para você copiar.
- **Importar**: o botão **Importar CSV** cadastra várias contas de uma vez (seção 3.5).
- **Detalhes**: clicar em uma linha abre a gaveta com as abas Resumo (dados, assinatura, últimas transações, atividades e sessões ativas), Editar, Permissões e Notas.
- **Notas internas**: na aba Notas, a equipe registra combinados e contexto de atendimento, fixa as importantes no topo e edita ou remove as próprias. `Ctrl` + `Enter` salva.
- **Bloquear e desbloquear**: o bloqueio pede um motivo, encerra as sessões da pessoa na hora e gera uma notificação de segurança.
- **Redefinir senha**: gera uma nova senha temporária.
- **Ações em massa**: selecione várias linhas para bloquear, desbloquear, ativar ou excluir de uma vez.
- **Colunas**: o botão no rodapé da tabela esconde ou mostra Papel, Plano, Status, Último acesso e Criado em. A escolha fica salva neste navegador; **Restaurar o padrão** volta ao original.
- **Exportar**: baixa a lista filtrada em CSV.

Na aba Permissões, quem tem a permissão de controlar permissões muda o papel da pessoa e marca exceções: permissões concedidas além do papel ou negadas mesmo que o papel tenha. O capítulo 7 explica as regras.

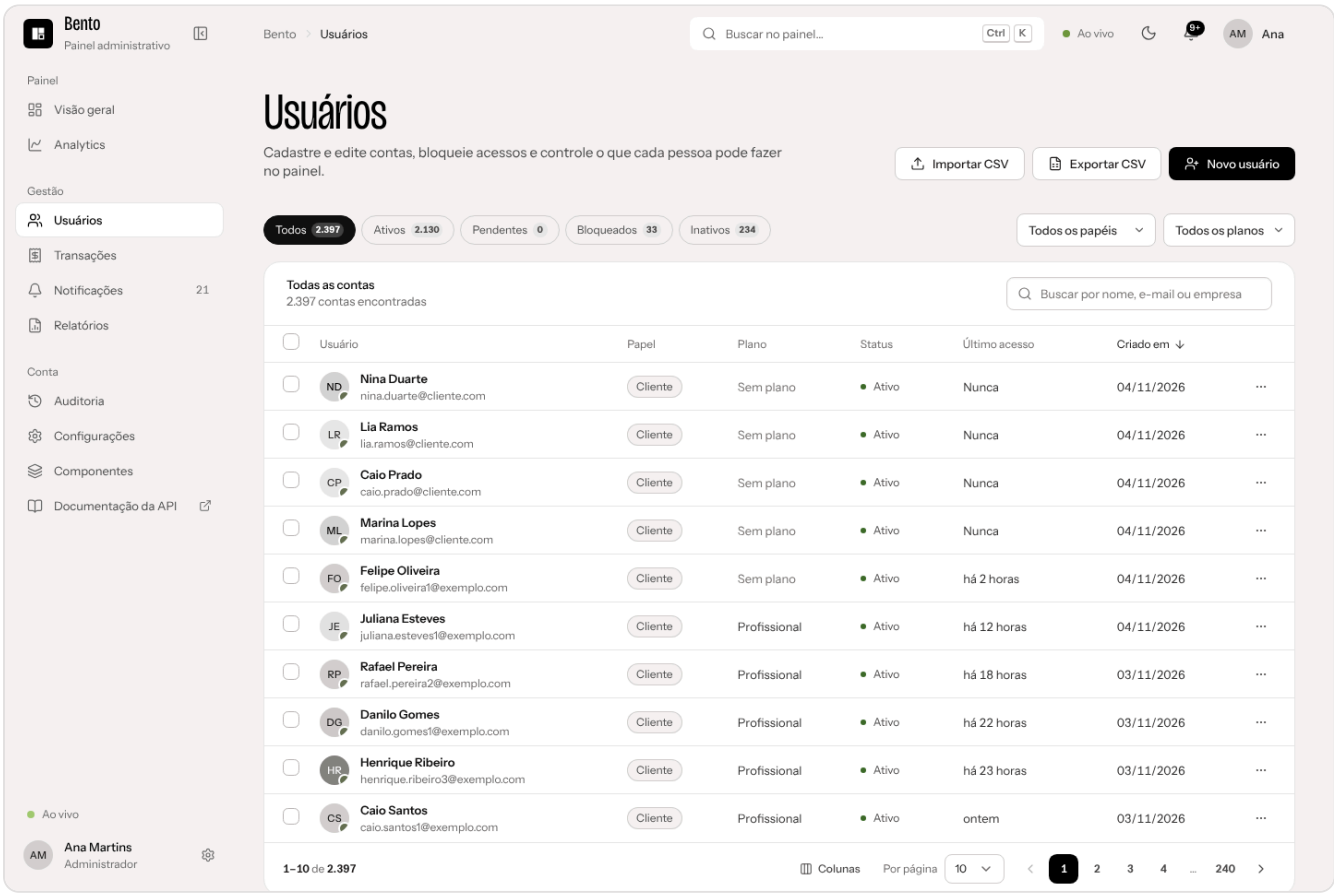


Figura 3.6 Usuários com filtros por status, papel e plano e os botões de importar e exportar.

Copyright (©) 2026 Erik Pimenta

3.5 Importação de usuários

O botão **Importar CSV**, para quem tem `usuarios.criar` e `usuarios.importar` (administradores e gerentes), abre uma gaveta em dois passos.

1. **Planilha**: escolha ou arraste um arquivo CSV de até 900 KB e 2.000 contas, ou cole o conteúdo no campo. Vírgula, ponto e vírgula e tabulação funcionam, e arquivos salvos pelo Excel em ANSI são lidos sem perder os acentos. Escolha o papel e o status para as linhas em que essas colunas vierem vazias. **Baixar modelo** entrega uma planilha de exemplo.
2. **Prévia**: o Bento confere cada linha sem gravar nada e mostra quantas contas serão criadas, quantas ficam de fora e quantas têm erro, com o motivo de cada uma, os erros primeiro. **Importar** grava as contas válidas de uma vez.

Coluna	Aceita
`nome` e `email`	Obrigatórias. Também reconhece “Nome completo”, “E-mail” e os nomes em inglês
`papel`	O código (`analista`) ou o nome (“Analista”) de um papel existente
`status`	`ativo` , `pendente` ou `inativo`
`cargo` , `empresa` , `telefone` , `cidade` , `pais`	Texto livre, com os mesmos limites do cadastro
`canal`	Orgânico, Direto, Pago, Social, Indicação ou E-mail

Linhas com e-mail já cadastrado ou repetido na planilha são ignoradas; colunas desconhecidas aparecem na prévia como ignoradas. As contas entram sem senha: use **Redefinir senha** para quem vai acessar o painel. Só quem controla permissões importa administradores e gerentes. A importação entra na auditoria como `usuario.importados` e avisa a equipe com uma notificação.

Copyright (©) 2026 Erik Pimenta

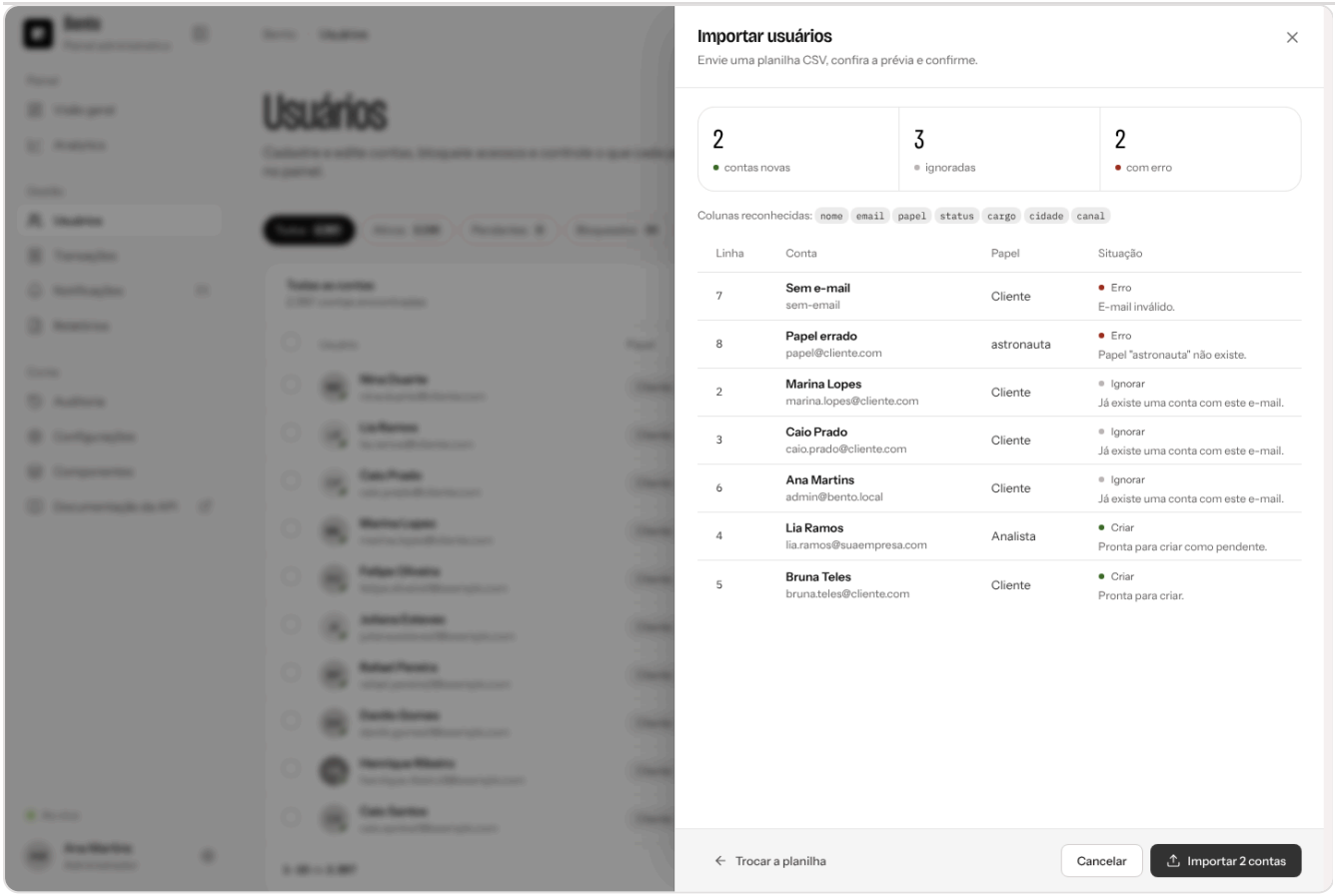


Figura 3.7 Prévia da importação com os números do resumo e o motivo de cada linha.

3.6 Transações

A página Transações, no grupo Gestão, reúne todas as cobranças, upgrades, vendas avulsas e reembolsos. Ela exige a permissão `transacoes.ver`.

- **Busca** por código (`TX-000123`), nome do cliente ou e-mail.
- **Filtros** por status (paga, pendente, falhou, reembolsada), método (cartão, Pix, boleto), tipo (assinatura, upgrade, avulsa, reembolso) e período. Os filtros e a ordenação ficam na URL.
- **Resumo do filtro** acima da tabela: total de transações, valor pago, valor reembolsado e taxa de falha do que está filtrado.
- **Visões salvas**: a combinação atual de filtros, busca e ordenação vira um atalho com nome, reaplicado com um clique (até 12 por página).
- **Colunas** configuráveis no rodapé da tabela, como em Usuários.
- **Gaveta de detalhe** com cliente, plano, método, assinatura ligada e a linha do tempo: criada, paga e reembolsada.
- **Exportar CSV** com exatamente os filtros aplicados.

Reembolso

Na gaveta de uma transação paga, quem tem a permissão `transacoes.reembolsar` (administradores e gerentes) vê o botão **Reembolsar**. O diálogo pede o motivo, de 3 a 300 caracteres, e confirma a ação. Ao reembolsar:

- o status muda para `reembolsada`, e a transação guarda quando, por quem e o motivo;
- a ação entra na auditoria como `transacao.reembolsar`, com o motivo nos detalhes;
- o evento é publicado em tempo real, e as telas abertas se atualizam;

Copyright (©) 2026 Erik Pimenta

- uma notificação da categoria transações avisa a equipe.

Transações pendentes, com falha ou já reembolsadas não podem ser reembolsadas; a API responde 409.

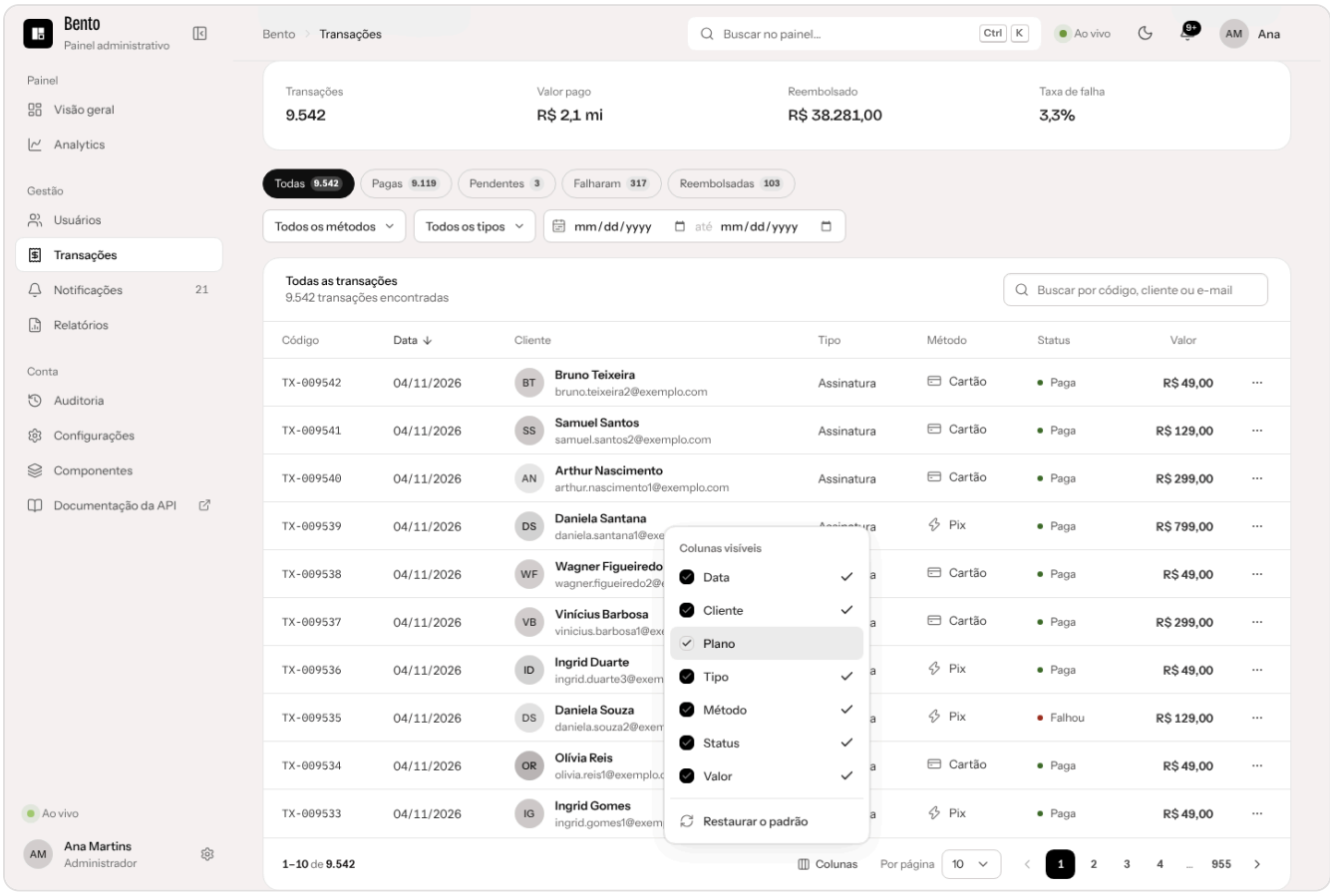


Figura 3.8 Transações com o menu de colunas aberto no rodapé da tabela.

3.7 Auditoria

A página Auditoria mostra o registro de atividades de toda a equipe, do mais recente ao mais antigo. Ela exige a permissão `auditoria.ver` (administradores e gerentes).

- **Filtros** por pessoa, tipo de ação (usuários, transações, sessões, relatórios, configurações, integrações, chaves de API e sistema), período e busca no texto da descrição.
- **Visões salvas** e **colunas** configuráveis, como em Transações.
- **Gaveta de detalhes** com a descrição, a ação, a entidade e o identificador afetados, o IP de origem e os dados em JSON.
- **Exportar CSV** com os mesmos filtros, pela rota `GET /api/v1/atividades/exportar`.

A auditoria é só de inserção e sobrevive à exclusão de contas: o autor vira nulo, mas a descrição pronta continua legível. As ações de operação da 1.4.0 também entram aqui: importação de usuários, reenvio de eventos, modo de manutenção, backups criados e baixados e limpezas pela retenção. Por padrão a auditoria não expira; um prazo pode ser definido com `BENTO_RETENCAO_AUDITORIA`.

Copyright (©) 2026 Erik Pimenta

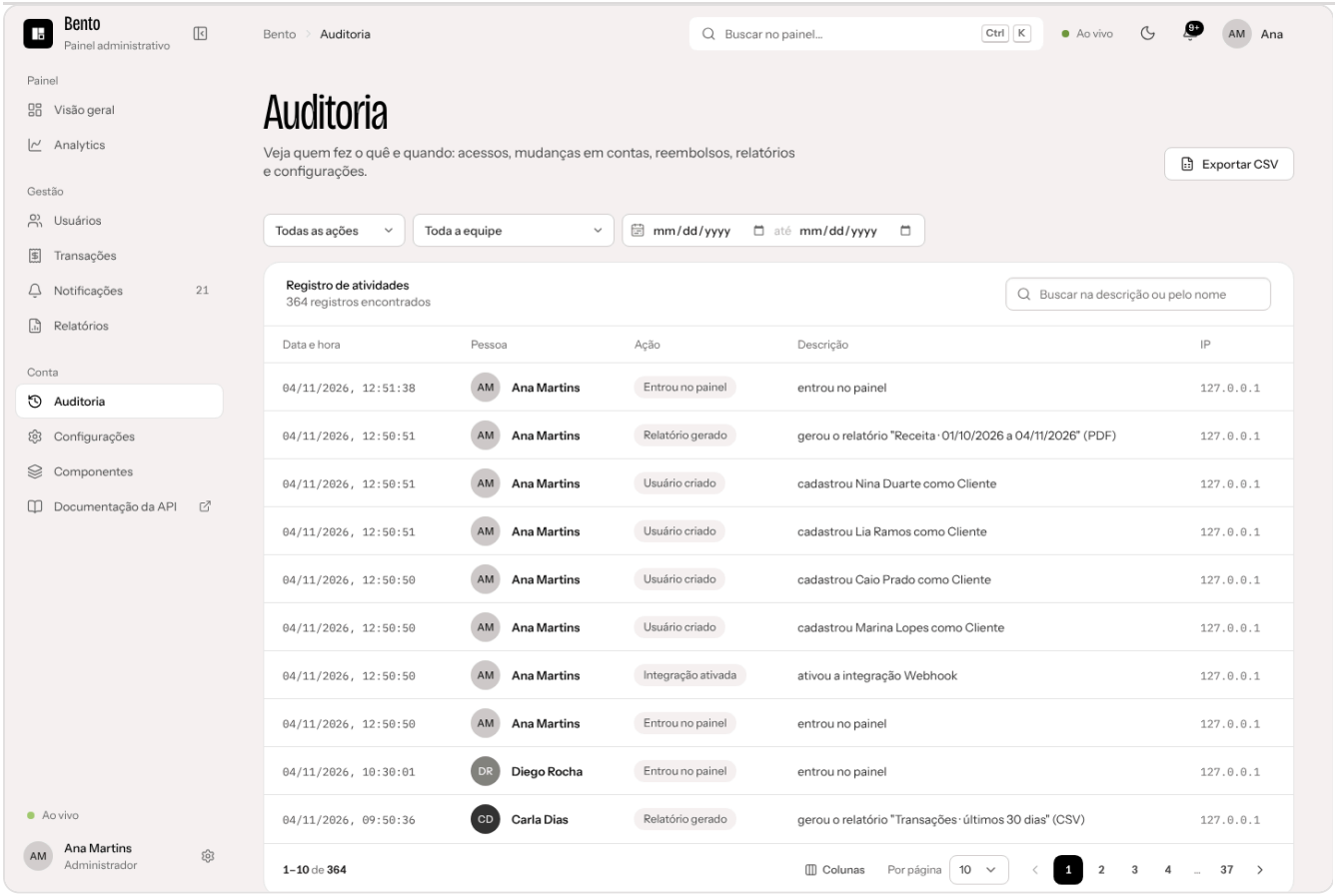


Figura 3.9 Auditoria com filtros por ação, pessoa e período.

3.8 Notificações

Notificações chegam em tempo real pelo cabeçalho e ficam guardadas nesta página, com filtros por categoria (transações, usuários, sistema, segurança e relatórios) e por lidas ou não lidas. Você pode marcar uma ou todas como lidas e dispensar as que não interessam; dispensar vale só para você.

Em Preferências, cada pessoa escolhe quais categorias quer receber. Quem tem a permissão de enviar avisos publica mensagens para toda a equipe ou para uma pessoa, com tipo informativo, sucesso, alerta ou erro. Notificações mais antigas que o prazo de `BENTO_RETENCAO_NOTIFICACOES` (180 dias por padrão) são removidas pela limpeza diária.

Copyright (©) 2026 Erik Pimenta

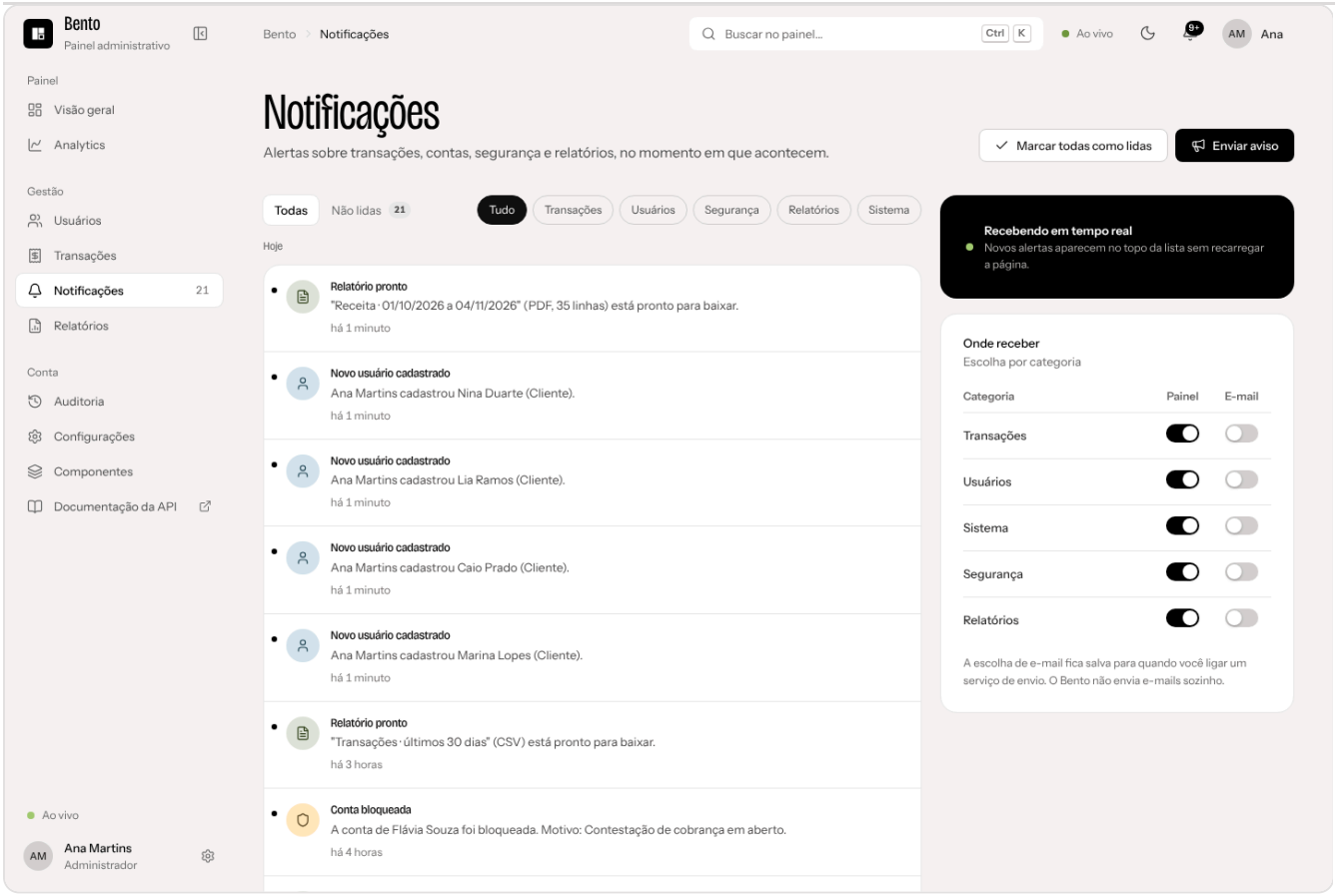


Figura 3.10 Notificações com filtros, preferências e envio de avisos.

3.9 Relatórios

Escolha o tipo (receita, transações, usuários, assinaturas ou crescimento), o período e o formato. A prévia mostra as primeiras linhas e o resumo antes de gerar. O arquivo pronto entra no histórico, de onde pode ser baixado de novo por qualquer pessoa com acesso aos relatórios.

Os envios agendados geram o mesmo relatório todo dia, toda semana ou todo mês, sempre às 7h no fuso configurado, e avisam quem criou o agendamento. Durante o modo de manutenção os agendamentos esperam e rodam assim que ele termina. O capítulo 9 detalha as colunas e os formatos.

Copyright (©) 2026 Erik Pimenta

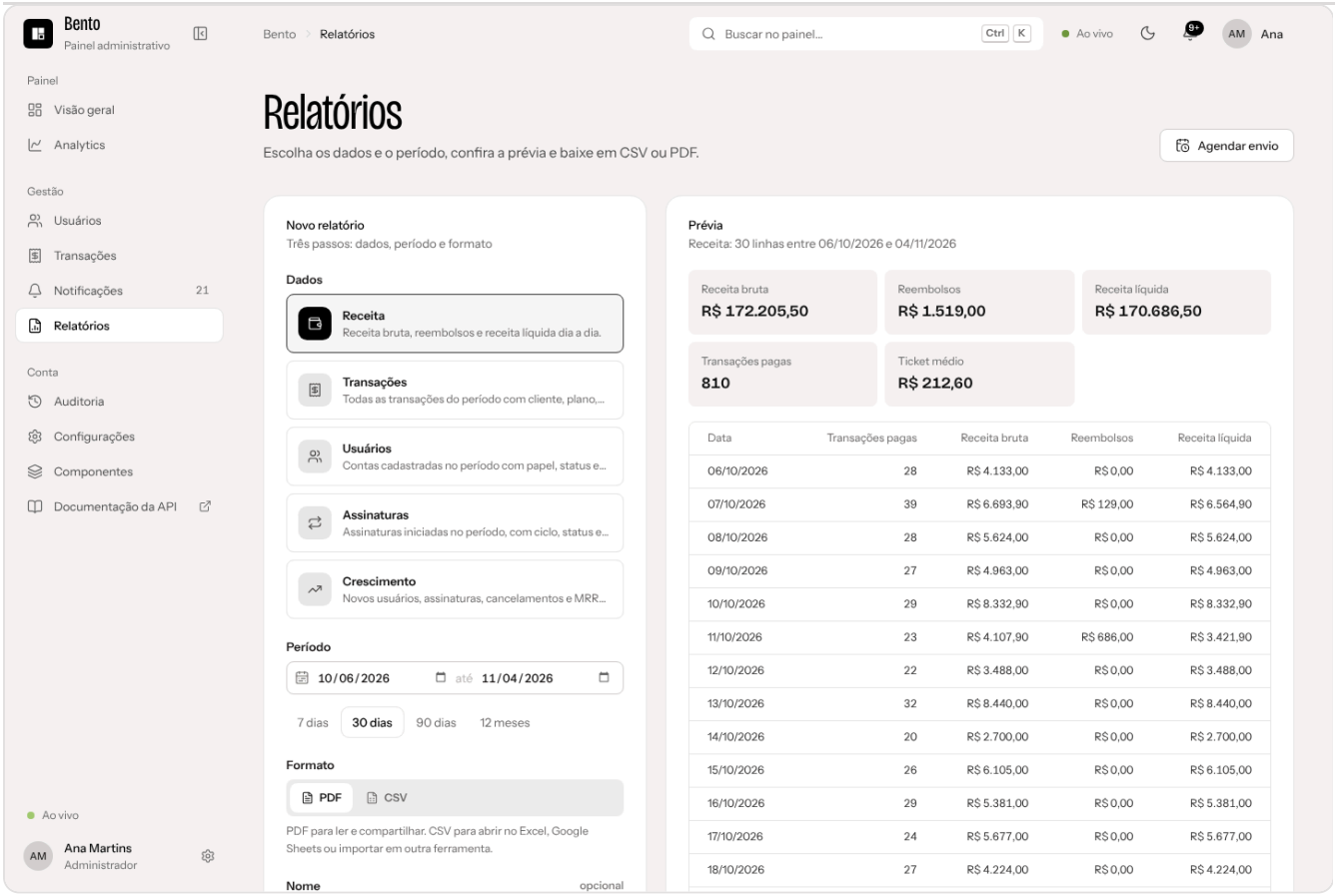


Figura 3.11 Relatórios com prévia, histórico e envios agendados.

3.10 Configurações

Aba	O que tem
Perfil	Nome, e-mail (pede a senha atual para trocar), cargo, telefone, empresa, país e cidade
Aparência	Tema claro, escuro ou do sistema, 16 paletas, densidade confortável ou compacta e menu recolhido. Salva no navegador e na conta, então vale em qualquer computador
Preferências	Página inicial, linhas por página, animações, atalhos de uma tecla e primeiros passos (seção 3.11)
Segurança	Troca de senha (encerra as outras sessões) e lista de sessões ativas com navegador, sistema, IP e último uso, com opção de encerrar uma ou todas
Chaves de API	Criação de chaves com escopo de leitura ou de escrita. O segredo aparece uma vez; o Bento guarda só o hash
Integrações	Webhook, Slack, Discord, Google Analytics e Stripe, com teste de conexão, o último erro no cartão e o histórico de entregas (seção 10.4)
Empresa	Nome da empresa, moeda, fuso e meta mensal de receita (só administradores)
Status do sistema	Estado do servidor, só para quem tem `configuracoes.sistema` (veja abaixo)
Manutenção	Verificações, modo de manutenção, backups, retenção de dados e monitoramento, só para quem tem `configuracoes.sistema` (capítulo 12)

Copyright (©) 2026 Erik Pimenta

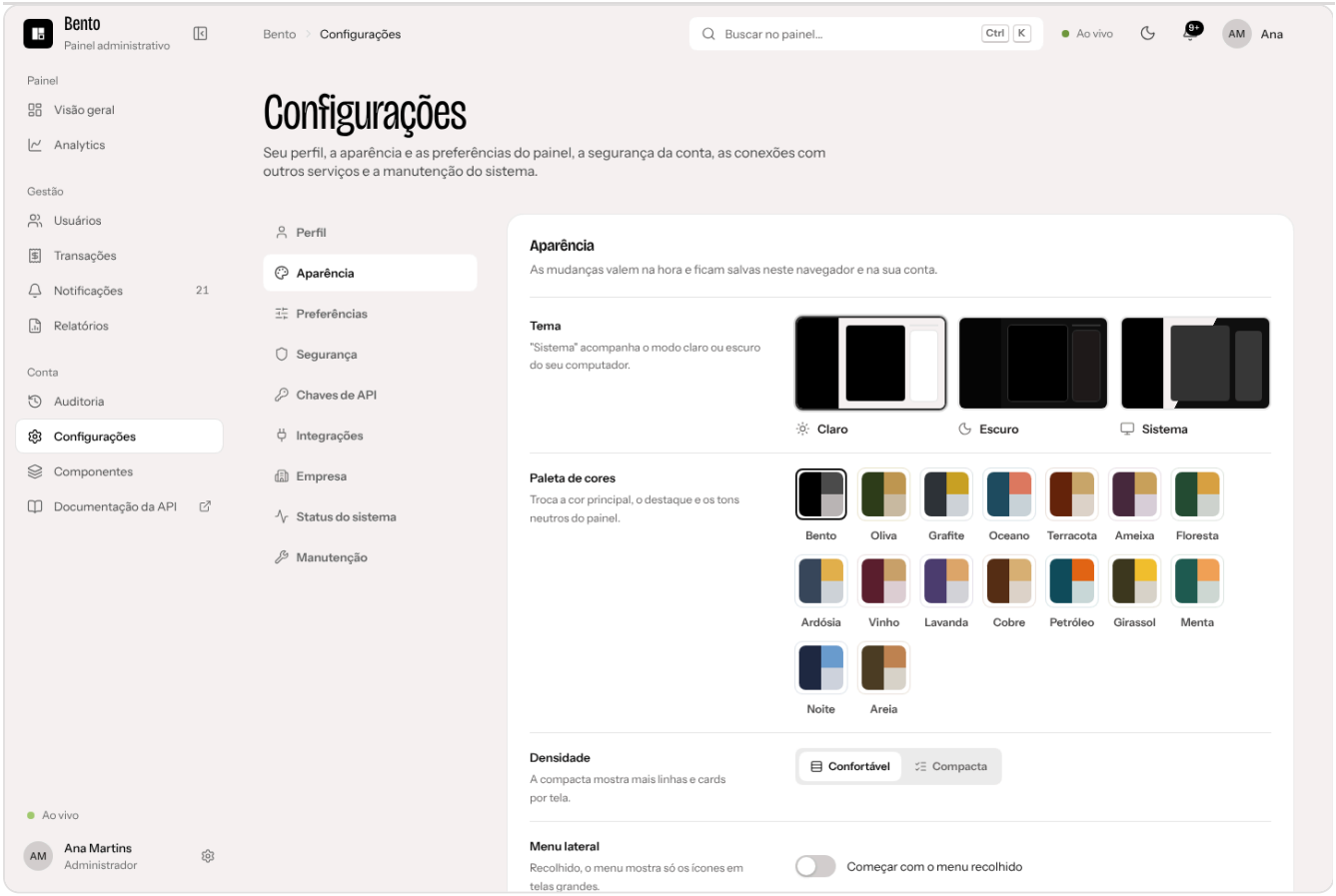


Figura 3.12 Aparência com tema, paletas e densidade.

Aba Status do sistema

A aba mostra o estado do servidor no momento, lido de `GET /api/v1/sistema/status`, e se atualiza a cada 15 segundos enquanto está aberta. O botão **Atualizar** busca os números de novo.

Indicador	O que mostra
Versão e Node.js	Versão do Bento em execução, lida do arquivo `VERSION`, e do Node.js
Banco	PostgreSQL ou PGlite, a latência de uma consulta simples e o tamanho do banco
Tempo no ar e memória	Desde quando o processo está rodando, memória total (RSS) e heap usado
Requisições atendidas	Total de requisições desde o início do processo
Tempo real	Conexões de tempo real abertas nesta instância
Modo	Produção, desenvolvimento ou manutenção
Registros	Contagem de linhas das principais tabelas, inclusive notas internas e entregas das integrações
Migrações	Arquivos de migração aplicados, com a data de cada um

Copyright (©) 2026 Erik Pimenta

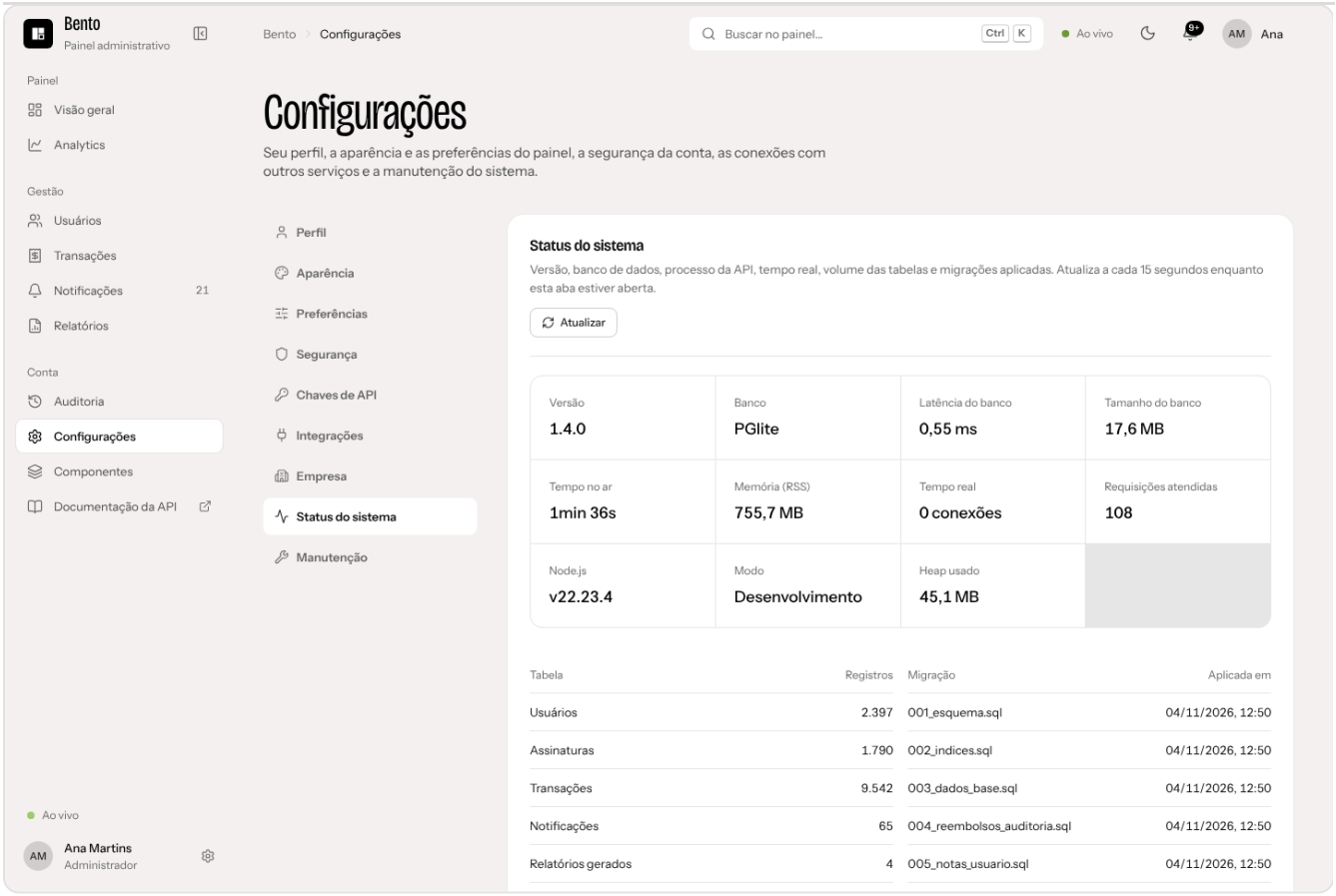


Figura 3.13 Aba Status do sistema com versão, banco, processo, tabelas e migrações.

Aba Manutenção

Reúne o que antes exigia acesso ao servidor: as verificações do diagnóstico, com erros e avisos primeiro e as demais recolhidas; o interruptor do modo de manutenção com a mensagem para a equipe; a lista de backups com **Fazer backup agora** e o download de cada arquivo; a tabela da retenção de dados com o que seria removido e **Limpar agora**; e os endereços de monitoramento. O capítulo 12 explica cada parte.

Copyright (©) 2026 Erik Pimenta

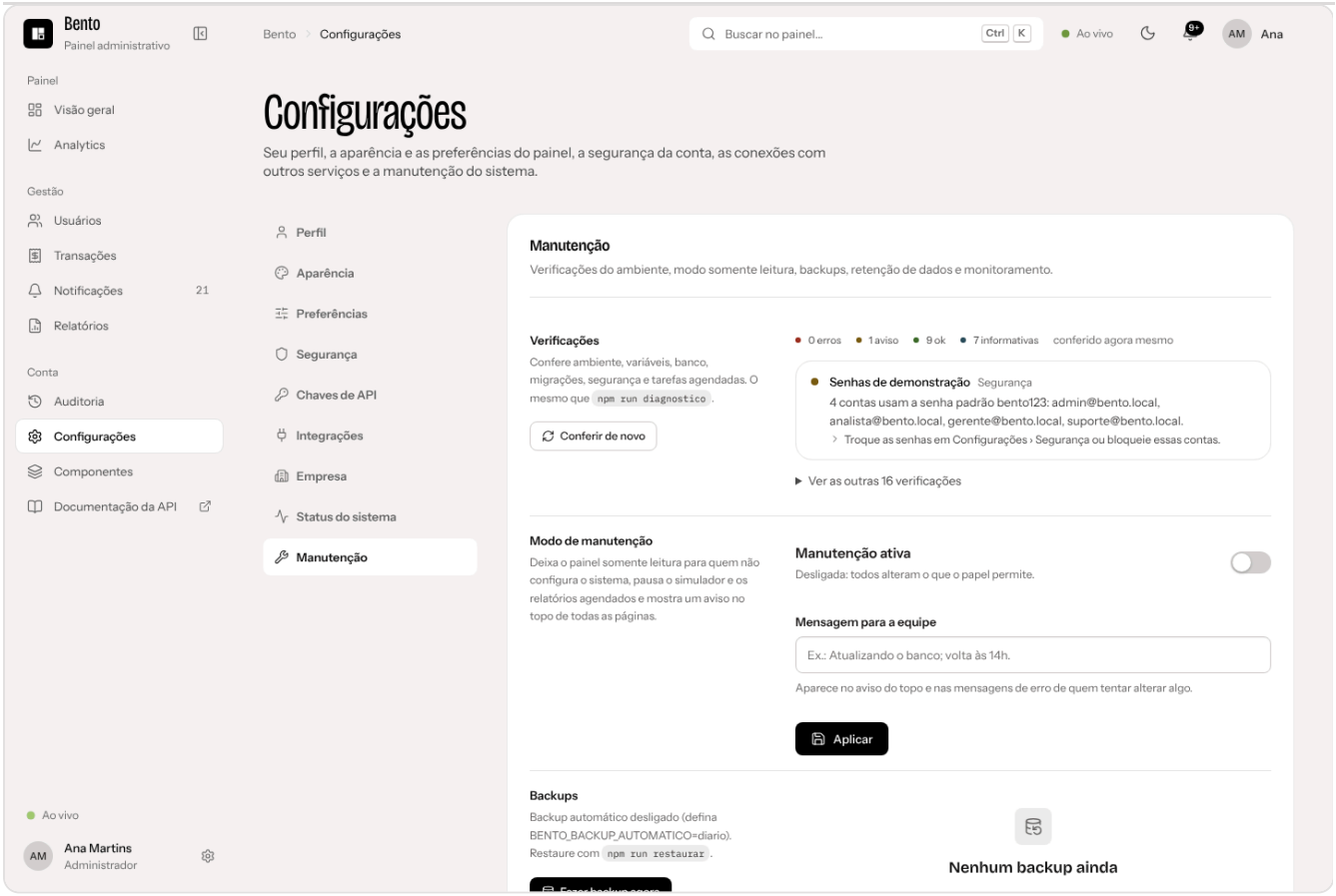


Figura 3.14 Aba Manutenção com as verificações, o modo de manutenção e os backups.

3.11 Preferências

Cada pessoa ajusta como o painel se comporta para ela. As preferências ficam na conta, então valem em qualquer navegador, e são salvas assim que você muda uma opção.

Preferência	O que faz	Padrão
Página inicial	Para onde o painel leva você depois de entrar: visão geral, analytics, usuários, transações, notificações, relatórios ou auditoria, entre as que você pode ver	Visão geral
Linhas por página	Quantas linhas as tabelas de usuários, transações e auditoria mostram ao abrir: 10, 25, 50 ou 100	25
Animações	Seguir o sistema ou reduzir sempre: desliga transições, gráficos animados e rolagens suaves	Seguir o sistema
Atalhos de uma tecla	Liga ou desliga `/`, `?` e `g` + letra, para quem usa leitor de tela ou comandos por voz. `Ctrl` + `K` continua valendo	Ligados
Primeiros passos	Mostra ou esconde o guia da visão geral (só para quem configura o sistema)	Mostrar

Na mesma aba, **Ver as novidades** abre a janela com o que mudou nesta versão, que aparece sozinha uma vez por versão em cada navegador, e **Limpar recentes** esvazia a lista da paleta de comandos.

Copyright (©) 2026 Erik Pimenta

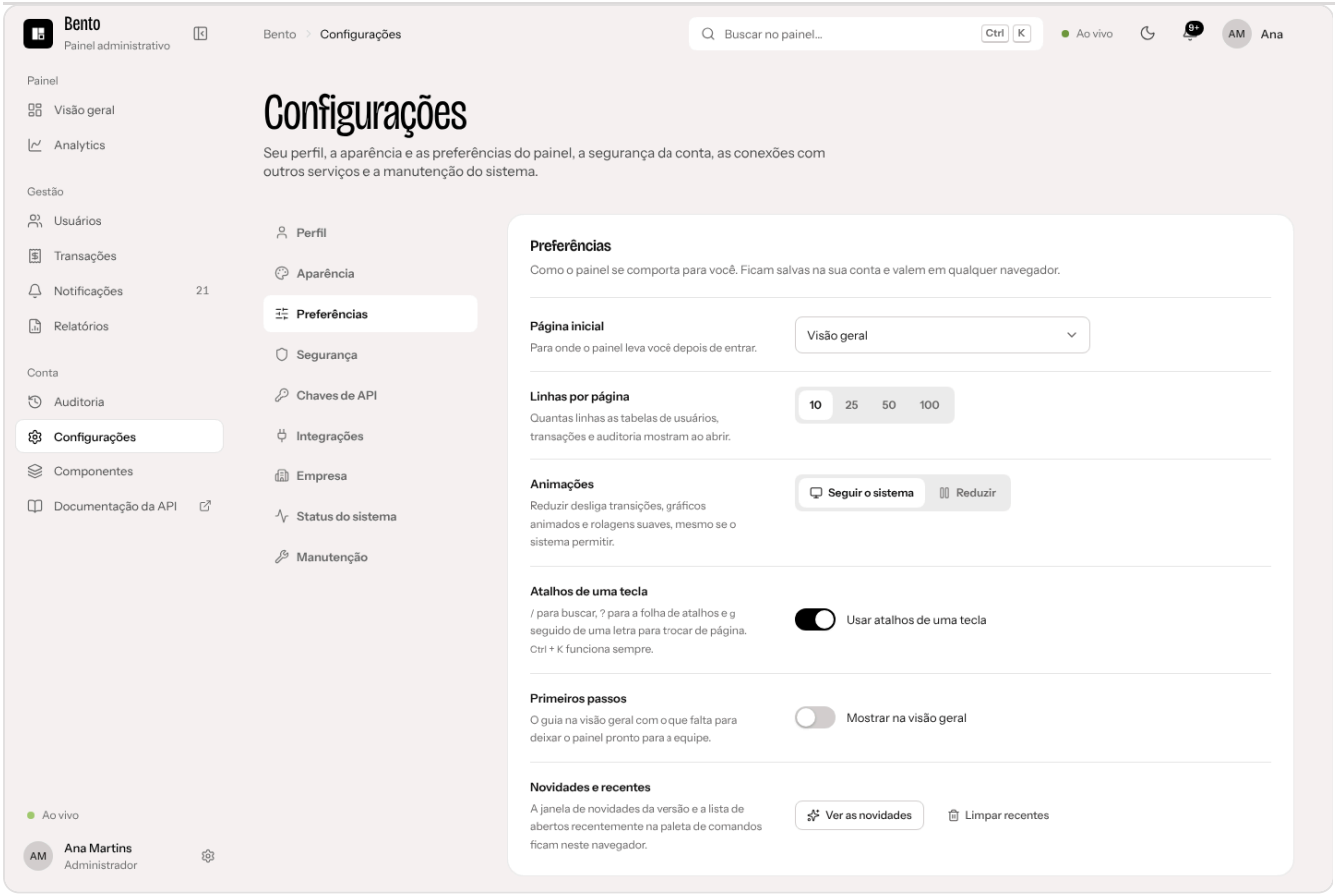


Figura 3.15 Preferências: página inicial, linhas por página, animações, atalhos e primeiros passos.

3.12 Componentes, novidades e página não encontrada

A página Componentes mostra toda a biblioteca em Tailwind CSS com exemplos funcionando: base e cores, botões, emblemas, formulários, cartões, indicadores, alertas, gavetas e diálogos, abas, progresso, avatares, listas e linha do tempo, carregamento e estados vazios, o kit de interface (acordeão, preços, fatura, kanban, calendário, controle deslizante, campo de etiquetas, árvore, lista de arquivos, comentários, passo a passo, página de status, registro de mudanças, cartões de perfil, gráficos em CSS, filtros e seleção avançados, banners, páginas de erro, boas-vindas, pagamento, uso do plano, equipe, sobreposições, relatório para impressão e modelos de grade bento) e, desde a 1.4.0, o grupo **Operação e manutenção**, com a faixa de manutenção, as verificações, o histórico de entregas, a importação e a lista de backups.

Use a página como catálogo: copie a marcação do exemplo, cole na sua página e ajuste o conteúdo. As classes funcionam em qualquer paleta e nos dois temas.

Copyright (©) 2026 Erik Pimenta

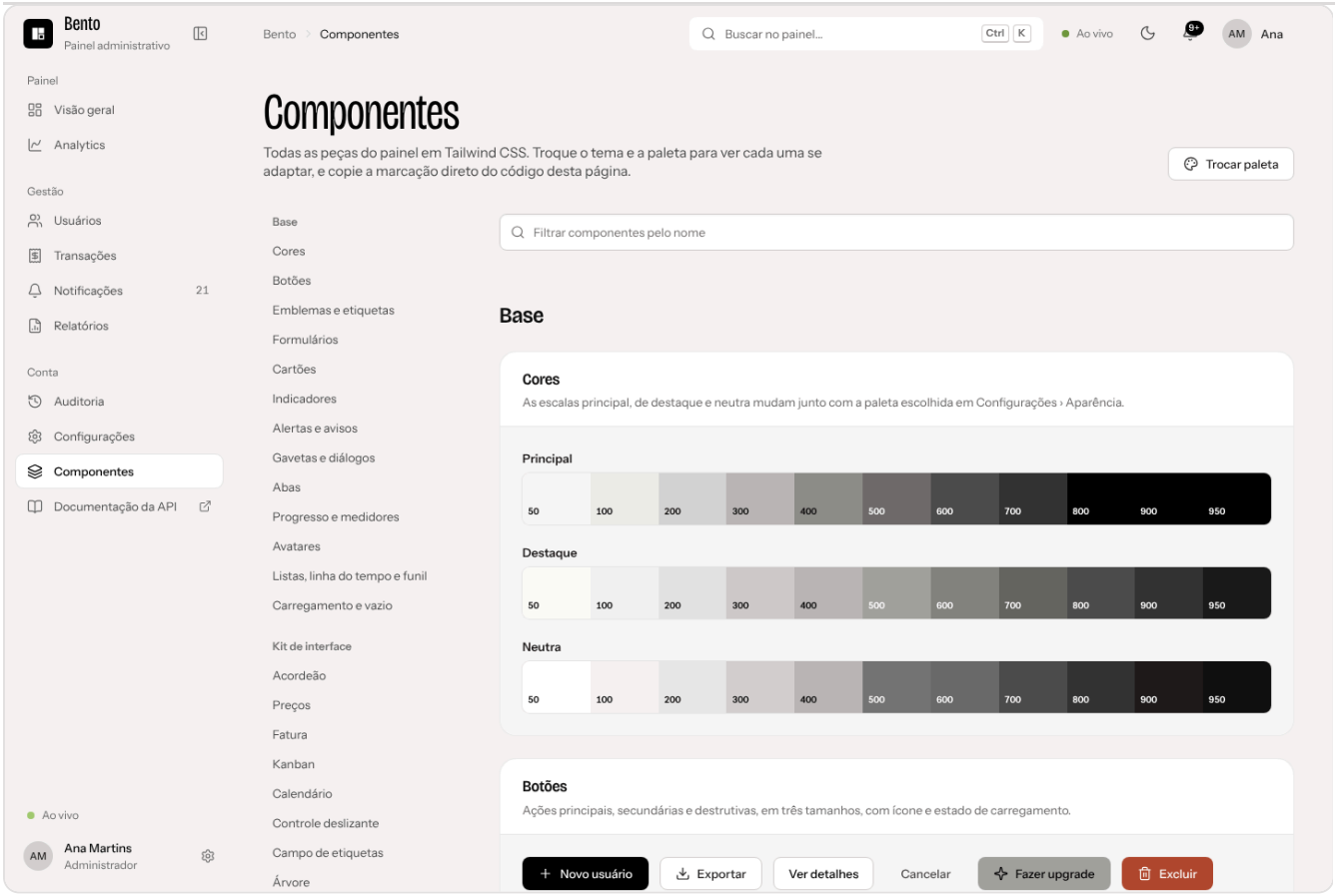


Figura 3.16 Biblioteca de componentes.

Um endereço que não existe no painel abre a página **não encontrada**, com status HTTP 404, o caminho pedido, os atalhos para as páginas principais e o botão de voltar. Antes, o servidor redirecionava qualquer endereço desconhecido para a visão geral.

Copyright (©) 2026 Erik Pimenta

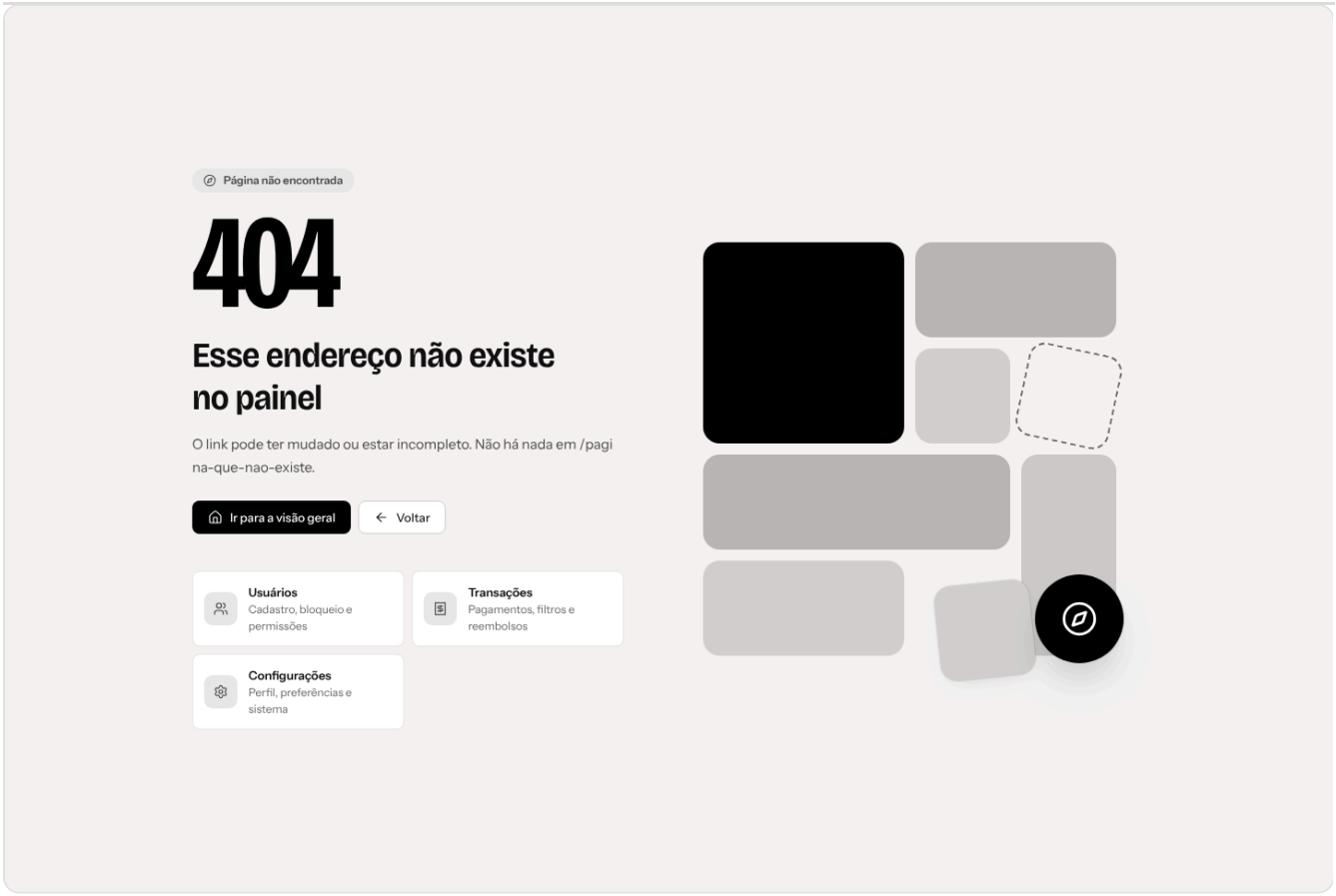


Figura 3.17 Página não encontrada, no mesmo desenho das páginas de erro do kit.

3.13 No celular

Todas as páginas se reorganizam no tablet e no celular: a grade bento passa de 12 para 6 colunas e depois para uma, as tabelas rolam na horizontal dentro do próprio cartão, as gavetas ocupam a tela inteira, a faixa de manutenção quebra o botão para a linha de baixo e o menu vira uma gaveta lateral.

Copyright (©) 2026 Erik Pimenta

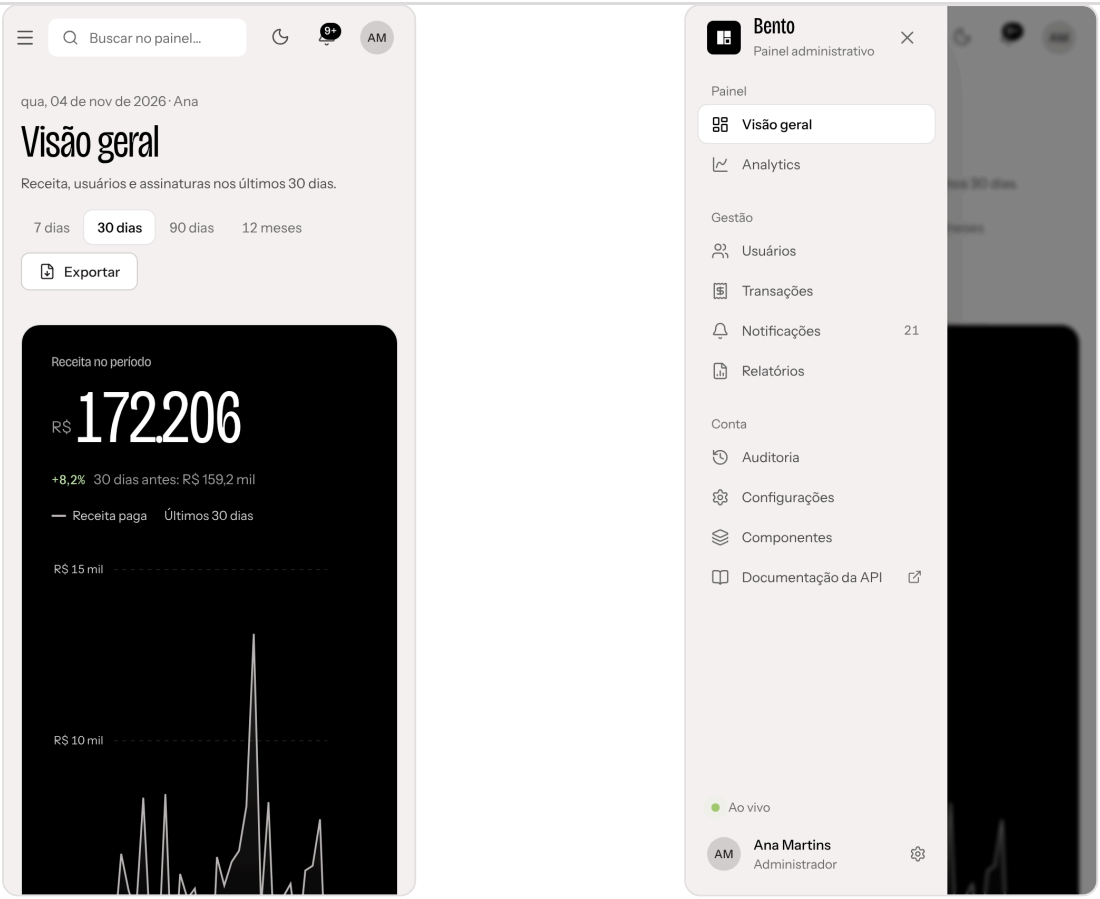


Figura 3.18 Visão geral e menu no celular.

Copyright (©) 2026 Erik Pimenta

04

Interface em Tailwind CSS

Todo o visual do Bento está em Tailwind CSS 4, escrito direto nos arquivos .css. Este capítulo mostra onde fica cada coisa e como mudar cores, grade e componentes sem quebrar o resto.

4.1 Como o CSS é organizado

O ponto de entrada é `web/src/css/bento.css`. Ele importa o Tailwind e depois os arquivos do projeto, sempre nesta ordem, para que cada camada possa usar a anterior:

Pasta	Conteúdo	Quando mexer
`tema/`	Variantes personalizadas, escalas de cor, paletas, fontes, tamanhos, raios, sombras e animações	Para mudar a identidade visual
`base/`	Estilos do documento, tipografia, campos de formulário e regras de impressão	Raramente
`layout/`	Casca (menu e cabeçalho), grade bento, cabeçalho de página e tela de entrada	Para mudar a estrutura das páginas
`componentes/`	Os componentes usados pelo painel, inclusive `operacao.css` (faixa de manutenção, verificações, entregas, importação, backups e novidades)	Para ajustar um componente existente
`kit/`	Os grupos do kit de interface e os temas dos gráficos	Para adicionar componentes novos
`paginas/`	Ajustes que valem para uma página só	Para detalhes de uma página
`utilitarios/`	Utilitários extras criados com `@utility`	Para atalhos reutilizáveis

Os componentes ficam em `@layer components` e são montados com `@apply`, então continuam sendo classes do Tailwind: dá para combinar `class="botao botao-primario w-full"` e qualquer utilitário vence o componente quando necessário. O código CSS não tem comentários: a organização em pastas e os nomes das classes contam o que cada bloco faz.

4.2 Identidade “caixa única”

Um bento é uma caixa só, dividida em compartimentos. Em cada página, os blocos ficam dentro de uma única caixa de cantos arredondados e dividem paredes de 1 px, em vez de flutuar como cartões soltos. Tudo o que fica fora dela (menu, cabeçalho e título da página) fica impresso no fundo, sem bordas. O bloco principal é a “tampa”: o único compartimento escuro. O desenho inteiro está em `web/src/css/identidade.css`, o último arquivo importado.

Copyright (©) 2026 Erik Pimenta

Elemento	Como é
Blocos	Uma caixa com raio de 18 px e paredes de 1 px entre os compartimentos
Bloco principal	A tampa: o único compartimento escuro da página
Fundo, menu e cabeçalho	Liso, em neutra-100, sem bordas; item ativo do menu em branco
Títulos e números	Bricolage Grotesque fina (peso 300) e condensada (largura 75 a 80)
Rótulos	Texto normal em Instrument Sans, sem caixa-alta
Variações	Sinal + ou − e a cor
Status	Ponto de cor e texto neutro
Período e abas	Texto; a opção ativa vira um compartimento branco
Menus e diálogos	Sombra suave e contorno de 1 px

Os materiais ficam em variáveis CSS no começo do arquivo: `--mesa` (fundo), `--caixa` (compartimentos), `--parede` e `--parede-forte` (divisões), `--tampa` (bloco principal), `--texto`, `--texto-2` e `--texto-3` (tons do texto), `--alta`, `--queda`, `--aviso` e `--info` (estados) e `--raio-caixa`. Eles derivam das escalas da paleta, então as 16 paletas e o tema escuro continuam funcionando sem mudar nada. Os componentes novos da 1.4.0 usam só esses materiais.

Os títulos e os números grandes usam os eixos de largura e de tamanho óptico da Bricolage Grotesque, carregados pelo arquivo `standard.css` do Fontsource. Para voltar ao peso normal, troque `font-weight: 300` nas regras do começo de `identidade.css`.

4.3 Tokens de cor

As cores são variáveis CSS declaradas com `@theme` em `tema/cores.css`, o que gera as classes do Tailwind automaticamente (`bg-primaria-800`, `text-neutra-600`, `border-destaque-400` e assim por diante). A paleta padrão, Bento, é monocromática:

Cor	HEX	Papel na interface
Branco	`#FFFFFF`	Compartimentos da caixa e texto sobre a tampa
Cinza claro	`#BAB7B6`	Base das escalas claras: fundo da página (neutra-100), paredes da caixa (neutra-200) e trilhas de gráfico
Chumbo	`#4D4B4B`	Texto secundário, ícones e séries de gráfico
Grafite	`#333232`	Tampa e paredes no tema escuro, estados de foco
Preto	`#000000`	Texto principal, botões primários e a tampa no tema claro

Essas cores formam três escalas de 50 a 950: `primaria` (ações e destaques), `destaque` (acentos e segunda série dos gráficos) e `neutra` (fundos, bordas e texto). Além delas existem `creme` e `tinta`, o claro e o escuro absolutos de cada paleta.

Copyright (©) 2026 Erik Pimenta

Cores de status

Quatro escalas fixas comunicam estado e não mudam com a paleta: `oliva` para sucesso (paga, ativa, conectada, entregue), `ouro` para alerta (pendente, em teste, nova tentativa), `brasa` para erro (falhou, bloqueado, inadimplente) e `anil` para informação (reembolsada). Elas aparecem como um ponto ao lado do texto do status e nunca sozinhas: o texto sempre diz o estado.

4.4 Modo escuro

O modo escuro usa a variante `dark:` ligada à classe `.dark` no elemento `<html>`, declarada em `tema/variantes.css`:

```
@custom-variant dark (&:where(.dark, .dark *));
```

O script `web/public/tema-inicial.js` roda antes de a página aparecer, lê a escolha guardada no `localStorage` (chaves com o prefixo `bento:`) e aplica a classe, a paleta, a densidade e o movimento, sem piscar o tema errado. Com a opção Sistema, o painel segue a preferência do sistema operacional e muda junto se ela mudar.

Ao escrever um componente novo, declare as duas versões lado a lado, ou use os materiais de `identidade.css`, que já mudam sozinhos no tema escuro:

```
.meu-cartao {
  @apply rounded-(--raio-caixa) border border-(--parede) bg-(--caixa) text-(--texto);
}
```

4.5 Paletas

Uma paleta é um bloco que redefine as escalas `primaria`, `destaque` e `neutra` quando o `<html>` tem o atributo `data-paleta`. Como todos os componentes usam essas escalas, trocar a paleta muda o painel inteiro, inclusive os gráficos, sem recarregar.

Paleta	Cor principal	Paleta	Cor principal
Bento (padrão)	`#000000`	Vinho	`#5C1F2E`
Oliva	`#31401A`	Lavanda	`#4B3F72`
Grafite	`#2E3338`	Cobre	`#592D14`
Oceano	`#1F4E5F`	Petróleo	`#0F4C5C`
Terracota	`#65240E`	Girassol	`#3D3A1E`
Ameixa	`#4A2C40`	Menta	`#1E5E52`
Floresta	`#234F33`	Noite	`#1F2A44`
Ardósia	`#3B4A5A`	Areia	`#4B3D26`

Copyright (©) 2026 Erik Pimenta

Criando uma paleta

1. Em `web/src/css/tema/paletas.css`, copie um bloco existente e troque o nome e os 33 valores (11 tons para cada escala). Mantenha o tom 50 quase branco e o 950 quase preto, para o contraste dos dois temas.
2. No mesmo arquivo, adicione as três regras de `.paleta-amostra` com as cores que representam a paleta na tela de aparência.
3. Acrescente o nome à lista `PALETAS` em `web/src/ts/nucleo/tema.ts` e a opção em `web/configuracoes.html`.
4. Na API, inclua o nome na validação de `api/src/modulos/configuracoes/rotas.ts` e `api/src/modulos/comum/consultas.ts`, e crie uma migração nova que atualize a restrição `preferencias_usuario_paleta_check`.

```
[data-paleta="minha"] {
  --color-primaria-50: #F6F7FB;
  --color-primaria-500: #5B6A9A;
  --color-primaria-800: #24315C;
  --color-primaria-950: #0B1024;
}
```

O exemplo mostra só quatro tons por brevidade; declare os onze de cada escala.

4.6 Grade bento

A grade fica em `layout/bento.css`. O contêiner `.bento` tem 1 coluna no celular, 6 a partir de 768 px e 12 a partir de 1280 px, com linhas de altura mínima fixa e preenchimento denso, para que cartões de tamanhos diferentes se encaixem sem buracos. Na identidade “caixa única”, a grade inteira é uma caixa: o espaço entre as colunas tem 1 px e mostra a cor da parede, então os compartimentos vizinhos dividem a mesma linha.

Classe	Tablet (6 col.)	Desktop (12 col.)
`.bento-quarto`	3	3
`.bento-terco`	3	4
`.bento-cinco-doze`	6	5
`.bento-metade`	6	6
`.bento-sete-doze`	6	7
`.bento-dois-tercos`	6	8
`.bento-tres-quartos`	6	9
`.bento-inteiro`	6	12
`.bento-alto` / `.bento-muito-alto`	1 linha	2 / 3 linhas
`.bento-pilha`	2 cartões lado a lado	4 colunas, cartões empilhados
`.bento-kpis`	2 por linha	4 por linha

Copyright (©) 2026 Erik Pimenta

```
<div class="bento">
  <article class="cartao cartao-destaque bento-dois-tercos bento-alto">...</article>
  <div class="bento-pilha">
    <article class="cartao">...</article>
    <article class="cartao">...</article>
  </div>
  <article class="cartao bento-terco">...</article>
  <article class="cartao bento-terco">...</article>
  <article class="cartao bento-terco">...</article>
</div>
```

A seção Modelos de grade bento da página Componentes traz arranjos prontos para vendas, produto, suporte, financeiro e marketing.

4.7 Variantes personalizadas

Além de `dark:`, o Bento declara variantes que reagem ao estado da interface. Elas funcionam como qualquer variante do Tailwind:

Variante	Ativa quando	Exemplo
`recolhida:`	O menu lateral está recolhido	`recolhida:hidden`
`compacta:`	A densidade compacta está ligada	`compacta:py-2`
`aberta:`	Um elemento com `data-aberta="true"` envolve o atual	`aberta:rotate-180`
`ativo:`	Item com `aria-current`, `aria-selected` ou `data-ativo`	`ativo:border-l-tinta`
`ordenado:`	Cabeçalho de tabela com `aria-sort`	`ordenado:text-tinta`
`movimento:`	A pessoa não pediu movimento reduzido	`movimento:animate-surgir`

4.8 Animações e movimento reduzido

As animações respeitam `prefers-reduced-motion`, e todos os elementos interativos têm foco visível pelo teclado. Desde a 1.4.0, a preferência **Animações › Reduzir** grava `data-movimento="reduzido"` no `<html>`, e uma regra de `componentes/operacao.css` zera a duração de animações e transições e desliga a rolagem suave, mesmo que o sistema permita movimento.

No TypeScript, use `movimentoReduzido()` de `nucleo/tema.ts` antes de animar algo por código: os gráficos e a rolagem das tabelas já fazem isso.

4.9 Criando componentes

1. Crie um arquivo em `web/src/css/kit/`, por exemplo `meu-componente.css`, com as classes dentro de `@layer components`.

Copyright (©) 2026 Erik Pimenta

2. Use só as escalas do tema (`primaria` , `destaque` , `neutra` , `creme` , `tinta` e as de status) ou os materiais de `identidade.css` (`--caixa` , `--parede` , `--texto` e `--raio-caixa`), nunca cores fixas, para o componente funcionar em todas as paletas e nos dois temas. Use rótulos em texto normal e números com `tabular-nums` .
3. Antes de criar uma classe, procure se o nome já existe no kit: duas regras com o mesmo nome em arquivos diferentes se misturam.
4. Importe o arquivo em `web/src/css/bento.css` , junto dos outros do kit.
5. Adicione um exemplo em `web/componentes.html` , para que o componente fique documentado no catálogo.

Limite do @apply

No Tailwind 4, `@apply` aceita utilitários e classes criadas com `@utility` , mas não outras classes de componente. Para reaproveitar um conjunto de utilitários em vários componentes, crie um `@utility` , como `selecao-filtro` em `componentes/filtros.css` .

Copyright (©) 2026 Erik Pimenta

05

TypeScript da interface

A interface é escrita em TypeScript com checagem strict, sem framework. Cada página tem um controlador pequeno e tipado que monta a casca, busca os dados na API e liga os componentes.

5.1 Organização

Pasta	Arquivos	Responsabilidade
`nucleo/`	tipos, api, sessao, tema, tempo-real, dom, formato, icones, eventos, armazenamento, visoes, recentes, colunas	Tipos das respostas da API, comunicação com a API, sessão e permissões, tema e movimento, eventos ao vivo, marcação segura, formatação em pt-BR, ícones, visões salvas, itens recentes e colunas ocultas
`componentes/`	tabela, graficos, gaveta, modal, aviso, abas, menu-suspenso, formulario, indicadores, transacao, visoes-salvas, importacao-usuarios	Peças reutilizáveis de interface
`layout/`	inicio, casca, navegacao, busca-global, atalhos, manutencao, novidades	Início de cada página, menu, cabeçalho, paleta de comandos, atalhos, faixa de manutenção e janela de novidades
`paginas/`	Um arquivo por página, inclusive `nao-encontrada`	Regras de cada tela

Os arquivos de `nucleo/` não dependem da página: são funções puras ou pequenos módulos com estado, e é neles que ficam os testes de `web/tests/`.

5.2 Ciclo de uma página

Toda página chama `iniciarPagina`, de `layout/inicio.ts`. A função carrega a sessão (e manda para a tela de entrada se ela tiver expirado), aplica as preferências da conta (tema, paleta, densidade e movimento), monta o menu e o cabeçalho, liga a paleta de comandos e os atalhos, liga a faixa de manutenção, abre a conexão em tempo real, confere a permissão da página e só então chama o seu código. No fim, mostra a janela de novidades se a versão for nova para aquele navegador.

Copyright (©) 2026 Erik Pimenta

```
import { iniciarPagina } from "../layout/inicio.ts";
import { api } from "../nucleo/api.ts";
import { html, renderizar } from "../nucleo/dom.ts";
import type { Pagina } from "../nucleo/tipos.ts";

interface ItemEstoque {
  id: string;
  nome: string;
}

iniciarPagina({
  pagina: "estoque",
  permissao: "painel.ver",
  aoIniciar: async ({ conteudo }) => {
    const dados = await api.obter<Pagina<ItemEstoque>>("/estoque");
    renderizar(conteudo.querySelector("[data-lista]"),
      html`<ul>${dados.itens.map((item) => html`<li>${item.nome}</li>`)}</ul>`);
  },
});
```

O `html` é uma template tag que escapa todo valor interpolado, o que protege contra injeção de HTML. Para inserir marcação confiável de propósito, use `seguro()`.

5.3 Falando com a API

O objeto `api` de `nucleo/api.ts` cobre os métodos HTTP e cuida dos detalhes: prefixo `/api/v1`, JSON, cookies de sessão, o cabeçalho `X-Bento: 1` exigido nas alterações e a renovação automática da sessão quando o acesso expira.

Função	Método HTTP
`api.obter(caminho, consulta)`	GET com parâmetros de consulta
`api.criar(caminho, corpo)`	POST
`api.atualizar(caminho, corpo)`	PATCH
`api.substituir(caminho, corpo)`	PUT
`api.excluir(caminho)`	DELETE
`api.baixar(caminho, consulta)`	GET que salva o arquivo com o nome enviado pela API

Erros chegam como `ErroApi`, com `status`, `codigo`, `detalhes` e `requisicao`, o identificador da requisição lido do corpo ou do cabeçalho `X-Request-Id`. A função `mensagemDeErro(erro)` devolve um texto pronto para mostrar ao usuário; em erros 500 ela acrescenta “Código do erro: …” com os oito primeiros caracteres desse identificador, que você procura no log do servidor (seção 12.6). Quando a API responde `MANUTENCAO`, a mensagem traz o aviso definido por quem ligou o modo.

Copyright (©) 2026 Erik Pimenta

5.4 Tabela de dados

A classe `TabelaDados` monta tabelas com ordenação, busca com espera de digitação, filtros, paginação, seleção de linhas, colunas configuráveis e estados de carregamento e vazio. Ela chama uma função sua para buscar cada página, então funciona com qualquer rota paginada da API: é ela que move as listas de usuários, transações e auditoria.

```
const tabela = new TabelaDados(elemento, {
  colunas: [
    { campo: "nome", titulo: "Nome", ordenavel: true, fixa: true, render: (item) => item.nome },
    { campo: "cidade", titulo: "Cidade", escondidaPorPadrao: true, render: (item) => item.cidade ??
"—" },
    { campo: "criadoEm", titulo: "Cadastro", ordenavel: true, render: (item) =>
dataCurta(item.criadoEm) },
  ],
  ordenacao: { campo: "criadoEm", direcao: "desc" },
  selecionavel: true,
  idColunas: "estoque",
  buscar: (parametros, sinal) => api.obter("/estoque", parametros, { sinal }),
});
```

Os `parametros` trazem `pagina`, `porPagina`, `ordenar`, `direcao`, `q` e os filtros, nos mesmos nomes que a API espera. O `sinal` cancela a busca anterior quando a pessoa continua digitando. Sem `porPagina` nas opções, a tabela usa a preferência **Linhas por página** da conta.

Colunas configuráveis

Com `idColunas`, a tabela ganha o botão **Colunas** no rodapé. As colunas marcadas com `fixa` não podem ser escondidas, as com `escondidaPorPadrao` começam escondidas, e sempre fica pelo menos uma coluna visível. A escolha é guardada no navegador na chave `bento:colunas:<idColunas>`; `nucleo/colunas.ts` normaliza o que foi lido e descarta campos que deixaram de existir, então renomear uma coluna nunca quebra a página.

5.5 Preferências, recentes e armazenamento

As preferências da conta chegam em `GET /auth/eu` e ficam disponíveis em `preferencia(chave, padrao)` de `nucleo/sessao.ts`. Para mudar uma delas, chame a API e depois `atualizarPreferencias()`, que avisa as partes da interface interessadas.

Função	Para que serve
`preferencia("itensPorPagina", 25)`	Lê uma preferência com valor padrão
`movimentoReduzido()`	Diz se a pessoa pediu animações reduzidas, no painel ou no sistema
`registrarRecente(dono, item)`	Coloca um usuário ou transação no topo de **Abertos recentemente** (até 8, sem repetir)
`listarRecentes(dono)` e `limparRecentes(dono)`	Leem e esvaziam a lista de uma pessoa
`ler`, `gravar`, `lerJson` e `gravarJson`	Acessam o `localStorage` com o prefixo `bento:` e sem quebrar em navegação privada

Copyright (©) 2026 Erik Pimenta

Tudo o que fica no navegador usa `nucleo/armazenamento.ts`: aparência local, menu recolhido, visões salvas, colunas ocultas, itens recentes e a última versão de novidades vista. Se o navegador bloquear o armazenamento, a página continua funcionando com os valores padrão.

Os atalhos de uma tecla consultam a preferência `atalhosTeclado` a cada tecla, então desligá-los em Preferências vale na hora, sem recarregar.

5.6 Gráficos

A classe `Grafico` envolve o ApexCharts: recebe o elemento, uma função que monta as opções a partir dos dados e das cores do tema, e redesenha sozinha quando o tema ou a paleta mudam. O tema dos gráficos segue a identidade do painel: linhas retas (`stroke.curve: "straight"`), traço fino e grade discreta. Com movimento reduzido, as animações dos gráficos ficam desligadas.

```
const grafico = new Grafico(elemento, (dados, cores) => ({
  chart: { type: "line", height: 260 },
  stroke: { curve: "straight", width: 1.5 },
  series: [{ name: "Receita", data: dados.valores }],
  xaxis: { categories: dados.rotulos },
  yaxis: { labels: { formatter: eixoMoeda } },
  colors: [cores.primaria],
}));
await grafico.renderizar(dados);
```

Para gráficos pequenos sem biblioteca, `faisca()` desenha a linha de tendência dos indicadores em SVG, `barrasMini()` desenha barras e `medidor()` desenha o anel da meta.

5.7 Gavetas, diálogos e avisos

- `new Gaveta({ titulo, subtitulo, largura })` cria uma gaveta lateral com o elemento nativo `<dialog>`, com foco preso dentro dela e fechamento por `Esc`.
- `confirmar({ titulo, texto, tipo, confirmar })` pede confirmação e devolve uma promessa; com `tipo: "perigo"`, o botão fica no estilo de ação destrutiva. O reembolso e o modo de manutenção usam diálogos desse tipo.
- `mostrarSegredo({ titulo, texto, segredo })` mostra uma senha temporária ou chave de API com botão de copiar.
- `avisar({ tipo, titulo, texto })`, `avisoSucesso()` e `avisoErro()` mostram avisos temporários no canto da tela.
- `abrirImportacaoUsuarios({ papeis, aoImportar })` abre a gaveta de importação de planilhas, e `abrirNovidades()` abre a janela com as novidades da versão.

5.8 Criando uma página nova

1. Copie um arquivo HTML da pasta `web` (por exemplo `notificacoes.html`), troque o título, o conteúdo de `#conteudo` e o script do fim para `/src/ts/paginas/estoque.ts`.
2. Adicione o nome ao vetor `paginas` de `web/vite.config.ts`, para o build incluir a página.

Copyright (©) 2026 Erik Pimenta

3 Adicione a rota em `PAGINAS` de `api/src/estatico.ts`, para a API servir a página construída em `/estoque`. Endereços que não estão nessa lista recebem a página 404.

4 Inclua o item em `NAVEGACAO` de `web/src/ts/layout/navegacao.ts`, com ícone, rótulo, endereço e permissão. O item aparece também na paleta de comandos; para um atalho `g` + letra, registre a letra em `layout/atalhos.ts`. Para que a página possa ser a inicial, acrescente o id a `PAGINAS_INICIAIS` em `api/src/modulos/comum/consultas.ts` e à restrição da coluna `pagina_inicial` em uma migração nova.

5 Crie o controlador em `web/src/ts/paginas/` chamando `iniciarPagina`, e os estilos específicos em `web/src/css/paginas/`, importados em `bento.css`.

Copyright (©) 2026 Erik Pimenta

06

API

Tudo que o painel faz passa por uma API REST em /api/v1. Ela pode ser usada por outros sistemas com uma chave de API, e a documentação interativa fica em /api/v1/docs.

6.1 Convenções

- Todas as rotas começam com `/api/v1`. Corpos e respostas são JSON, com nomes de campos em português e camelCase.
- Valores em dinheiro vêm em centavos inteiros no campo `valor`, acompanhados de `moeda` (`"BRL"` por padrão). Datas e horas seguem a ISO 8601.
- Listas aceitam `pagina` (a partir de 1), `porPagina` (padrão 10, máximo 100), `ordenar`, `direcao` (`asc` ou `desc`) e `q` para busca, e respondem com `{ itens, total, pagina, porPagina, paginas }`.
- Toda resposta traz o cabeçalho `X-Request-Id`. Se você enviar um `X-Request-Id` próprio (de 8 a 80 caracteres entre letras, números, ponto, dois-pontos, hífen e sublinhado), a API usa o seu, o que liga os logs do Bento aos do seu proxy ou sistema.

Erros

Todo erro tem o mesmo formato, com uma mensagem pronta em português:

```
{ "erro": { "codigo": "VALIDACAO", "mensagem": "email: e-mail inválido", "detalhes": [ ... ] } }
```

Código	Status	Quando acontece
`NAO_AUTENTICADO`	401	Sem sessão ou com acesso expirado
`CREDENCIAIS`	401	E-mail ou senha incorretos
`SEM_PERMISSAO`	403	A conta não tem a permissão da rota
`SEM_ACESSO_PAINEL`	403	O papel da conta não acessa o painel (clientes)
`CSRF`	403	Alteração por cookie sem o cabeçalho `X-Bento`
`NAO_ENCONTRADO`	404	O registro não existe, ou as métricas estão desligadas
`CONFLITO`	409	E-mail já cadastrado, ação sobre a própria conta, reembolso de transação que não está paga e casos parecidos
`VALIDACAO`	422	Corpo ou parâmetros inválidos; `detalhes` traz cada campo

Copyright (©) 2026 Erik Pimenta

Código	Status	Quando acontece
`BLOQUEADO`	423	A conta está bloqueada
`LIMITE`	429	Muitas requisições ou tentativas de login
`INTERNO`	500	Erro inesperado no servidor; o corpo traz `requisicao` com o identificador registrado no log
`MANUTENCAO`	503	O painel está em modo de manutenção e a rota altera dados (seção 12.2)

6.2 Autenticação e sessões

- O login em `POST /auth/entrar` cria dois cookies httpOnly: `bento_sessao`, com um JWT de acesso válido por 15 minutos, e `bento_renovacao`, com um token aleatório restrito a `/api/v1/auth`. Quando o acesso expira, a interface chama `POST /auth/renovar`, que gira o token de renovação; reaproveitar um token antigo falha.
- Com **Lembrar de mim**, a sessão dura 30 dias; sem, 12 horas. Sessões encerradas ou expiradas há mais de `BENTO_RETENCAO_SESSOES` dias são apagadas pela limpeza diária.
- Cada requisição confere a sessão no banco. Bloquear a conta, trocar a senha ou encerrar a sessão tem efeito imediato.
- Cinco senhas erradas seguidas suspendem o login da conta por 15 minutos e geram uma notificação de segurança.
- Pedidos que alteram dados com cookie precisam do cabeçalho `X-Bento: 1`. Outros sites não conseguem enviar esse cabeçalho, o que impede ataques de falsificação de requisição.

Chaves de API

Para integrar outro sistema, crie uma chave em Configurações › Chaves de API e envie no cabeçalho `Authorization: Bearer bnt_...`. A chave age com as permissões de quem a criou. O escopo **leitura** libera só pedidos GET; **escrita** libera também as alterações. Chaves dispensam o cabeçalho `X-Bento`.

Limites

Cada IP pode fazer 300 requisições por minuto. O login aceita 10 tentativas por minuto e a renovação, 60. Algumas ações têm limite próprio por minuto: importação de usuários (20), reenvio de entregas (20), teste de integração (10), limpeza (6) e backup (3). As sondas de saúde e as métricas não entram no limite. Acima dele a API responde 429 com o código `LIMITE`.

6.3 Rotas de saúde, sessão, visão geral, analytics e auditoria

Método	Rota	Permissão	O que faz
GET	/saude	pública	Status, tipo de banco, versão, tempo no ar e se está em manutenção
GET	/saude/vivo	pública	Sonda de vida: responde enquanto o processo estiver de pé
GET	/saude/pronto	pública	Sonda de prontidão: 200 com banco no ar e migrações em dia; 503 com os motivos

Copyright (©) 2026 Erik Pimenta

Método	Rota	Permissão	O que faz
GET	/metricas	token	Métricas do Prometheus, com `Authorization: Bearer` e o valor de `BENTO_METRICAS_TOKEN`
POST	/auth/entrar	pública	Login com email, senha e lembrar
POST	/auth/sair	sessão	Encerra a sessão e limpa os cookies
POST	/auth/renovar	sessão	Renova o acesso e gira o token
GET	/auth/eu	sessão	Conta, permissões, preferências, dados da empresa e estado da manutenção
GET	/visao-geral?periodo=30d	painel.ver	KPIs (7d, 30d, 90d ou 12m), receita mensal, planos, canais, meta, transações e atividades
GET	/analytics?inicio&fim&agrupar	analytics.ver	Resumo e séries por dia, semana ou mês, funil, canais, dispositivos, países, coortes e mapa de calor
GET	/busca?q	painel.ver	Até 5 usuários e 5 transações (mínimo 2 caracteres)
GET	/atividades	auditoria.ver	Registro de atividades paginado, com os filtros usuario, acao, q, inicio e fim
GET	/atividades/exportar	auditoria.ver	CSV com os mesmos filtros (até 10.000 linhas)
GET	/atividades/pessoas	auditoria.ver	Equipe com acesso ao painel, para o filtro de pessoa

O filtro `acao` aceita o prefixo do tipo (`auth` , `usuario` ou `usuarios` , `assinatura` , `transacao` , `relatorio` , `notificacao` , `integracao` , `perfil` ou `seguranca` e `sistema`) ou a ação completa (`usuario.bloqueado`), e até dez valores separados por vírgula. `inicio` e `fim` são dias no formato AAAA-MM-DD, no fuso configurado.

6.4 Rotas de usuários e transações

Método	Rota	Permissão	O que faz
GET	/usuarios	usuarios.ver	Lista com q, status, papel, plano, ordenação e contagens por status
POST	/usuarios	usuarios.criar	Cadastra; sem senha, devolve uma senha temporária uma vez
GET	/usuarios/importar/modelo	usuarios.importar	Planilha CSV de exemplo
POST	/usuarios/importar	usuarios.criar e usuarios.importar	Confere ou importa contas de uma planilha CSV
GET	/usuarios/{id}	usuarios.ver	Conta, assinatura, últimas transações e atividades, sessões ativas e contagem de notas

Copyright (©) 2026 Erik Pimenta

Método	Rota	Permissão	O que faz
PATCH	/usuarios/{id}	usuarios.editar	Edita dados; mudar o papel exige usuarios.permissoes
DELETE	/usuarios/{id}	usuarios.excluir	Exclui (não vale para a própria conta)
POST	/usuarios/{id}/bloquear	usuarios.bloquear	Bloqueia com motivo e encerra as sessões
POST	/usuarios/{id}/desbloquear	usuarios.bloquear	Desbloqueia
POST	/usuarios/{id}/redefinir-senha	usuarios.editar	Gera uma senha temporária
GET	/usuarios/{id}/permissoes	usuarios.ver	Papel, permissões do papel, concedidas, negadas e efetivas
PUT	/usuarios/{id}/permissoes	usuarios.permissoes	Define papel, concedidas e negadas
GET	/usuarios/{id}/notas	usuarios.ver	Até 200 notas, fixadas primeiro
POST	/usuarios/{id}/notas	usuarios.anotar	Cria uma nota (texto de 2 a 2.000 caracteres e fixada)
PATCH	/usuarios/{id}/notas/{nota}	usuarios.anotar	Altera texto ou fixada; só o autor ou quem controla permissões
DELETE	/usuarios/{id}/notas/{nota}	usuarios.anotar	Remove; só o autor ou quem controla permissões
POST	/usuarios/acoes-em-massa	da ação	Bloquear, desbloquear, ativar ou excluir várias contas
GET	/usuarios/exportar	usuarios.ver	CSV com os mesmos filtros da lista
GET	/papeis	usuarios.ver	Papéis com permissões e número de usuários
GET	/permissoes	usuarios.ver	Catálogo de permissões
GET	/transacoes	transacoes.ver	Lista com q, status, método, tipo, datas e ordenação; devolve também o resumo do filtro
GET	/transacoes/resumo	transacoes.ver	Total, valor pago, reembolsado, taxa de falha e contagens por status
GET	/transacoes/{id}	transacoes.ver	Detalhes com a assinatura ligada e os dados do reembolso
GET	/transacoes/exportar	transacoes.ver	CSV com os mesmos filtros
POST	/transacoes/{id}/reembolsar	transacoes.reembolsar	Reembolsa uma transação paga com o motivo; outras respondem 409

Copyright (©) 2026 Erik Pimenta

Importação

`POST /usuarios/importar` recebe `{ "csv": "...", "simular": true, "papelPadrao": "cliente", "statusPadrao": "ativo" }`. O `csv` é o texto da planilha, até 900 KB e 2.000 linhas. Com `simular: true` (o padrão) nada é gravado: a resposta traz `total`, `criar`, `ignorar` e `erros`, as colunas reconhecidas e ignoradas, e as linhas com status e motivo, até 500 delas. Com `simular: false`, as linhas válidas são gravadas em uma transação e `criados` diz quantas contas entraram. E-mails já cadastrados entram como ignorados, nunca como erro.

Reembolso

`POST /transacoes/{id}/reembolsar` recebe `{ "motivo": "..." }`, com 3 a 300 caracteres. Só aceita transações com status `paga`; nos outros casos responde 409, e um motivo fora do tamanho responde 422. Em uma transação do banco, muda o status para `reembolsada` e grava `reembolsadoEm`, `reembolsadoPor` e `reembolsoMotivo`; depois registra `transacao.reembolsar` na auditoria, publica o evento `transacao` em tempo real e cria uma notificação.

6.5 Rotas de notificações e relatórios

Método	Rota	Permissão	O que faz
GET	/notificacoes	sessão	Lista (todas ou não lidas, por categoria) com o total não lido
GET	/notificacoes/contagem	sessão	Número de não lidas
GET	/notificacoes/fluxo	sessão	Eventos em tempo real (text/event-stream)
POST	/notificacoes/{id}/ler	sessão	Marca como lida
POST	/notificacoes/ler-todas	sessão	Marca todas como lidas
DELETE	/notificacoes/{id}	sessão	Dispensa só para quem pediu
POST	/notificacoes	notificacoes.enviar	Publica um aviso para todos ou para uma pessoa
GET	/notificacoes/preferencias	sessão	Categorias que a pessoa recebe
PUT	/notificacoes/preferencias	sessão	Salva as categorias
GET	/relatorios/tipos	relatorios.ver	Tipos com as colunas de cada um
GET	/relatorios/previa?tipo&inicio&fim	relatorios.ver	Até 25 linhas, total e resumo
GET	/relatorios	relatorios.ver	Histórico paginado
POST	/relatorios	relatorios.gerar	Gera em CSV ou PDF e guarda no histórico
GET	/relatorios/{id}/baixar	relatorios.ver	Baixa o arquivo
DELETE	/relatorios/{id}	relatorios.gerar	Remove do histórico
GET	/relatorios/agendados	relatorios.ver	Envios agendados
POST	/relatorios/agendados	relatorios.agendar	Cria um agendamento

Copyright (©) 2026 Erik Pimenta

Método	Rota	Permissão	O que faz
PATCH	/relatorios/agendados/{id}	relatorios.agendar	Pausa ou retoma
DELETE	/relatorios/agendados/{id}	relatorios.agendar	Remove

6.6 Rotas de configurações e integrações

Método	Rota	Permissão	O que faz
GET	/configuracoes/perfil	sessão	Dados da própria conta
PATCH	/configuracoes/perfil	sessão	Edita o perfil; trocar o e-mail pede a senha atual
GET	/configuracoes/preferencias	sessão	Aparência e preferências de uso (também em /configuracoes/aparencia)
PUT	/configuracoes/preferencias	sessão	Salva só os campos enviados (também em /configuracoes/aparencia)
POST	/configuracoes/seguranca/senha	sessão	Troca a senha e encerra as outras sessões
GET	/configuracoes/seguranca/sessoes	sessão	Sessões ativas
DELETE	/configuracoes/seguranca/sessoes/{id}	sessão	Encerra uma sessão
DELETE	/configuracoes/seguranca/sessoes	sessão	Encerra todas, menos a atual
GET	/configuracoes/chaves-api	sessão	Chaves da própria conta
POST	/configuracoes/chaves-api	sessão	Cria uma chave; o segredo aparece uma vez
DELETE	/configuracoes/chaves-api/{id}	sessão	Revoga
GET	/configuracoes/sistema	sessão	Nome da empresa, moeda, fuso, meta e idioma
PUT	/configuracoes/sistema	configuracoes.sistema	Salva os dados da empresa
GET	/integracoes	configuracoes.integracoes	Integrações com campos (segredos mascarados)
PATCH	/integracoes/{id}	configuracoes.integracoes	Ativa, desativa e configura
POST	/integracoes/{id}/testar	configuracoes.integracoes	Testa a conexão e registra a entrega de teste
GET	/integracoes/{id}/entregas	configuracoes.integracoes	Histórico de entregas paginado, com o filtro status e o resumo

Copyright (©) 2026 Erik Pimenta

Método	Rota	Permissão	O que faz
POST	/integracoes/{id}/entregas/{entrega}/reenviar	configuracoes.integracoes	Coloca a entrega na fila para sair agora

O corpo de `PUT /configuracoes/preferencias` aceita `tema`, `paleta`, `densidade`, `sidebarRecolhida`, `paginaInicial` (`visao-geral`, `analytics`, `usuarios`, `transacoes`, `notificacoes`, `relatorios` ou `auditoria`), `itensPorPagina` (10, 25, 50 ou 100), `movimento` (`sistema` ou `reduzido`), `atalhosTeclado` e `primeirosPassosOcultos`. Esta rota continua aceita durante o modo de manutenção.

6.7 Rotas de sistema e operação

Todas exigem `configuracoes.sistema`, menos a leitura do estado da manutenção, que vale para qualquer sessão.

Método	Rota	O que faz
GET	/sistema/status	Versão, banco e latência, tempo no ar, memória, conexões de tempo real, modo, backup, métricas, registros e migrações
GET	/sistema/diagnostico	As mesmas verificações de `npm run diagnostico`, com status ok, info, aviso ou erro
GET	/sistema/primeiros-passos	Os passos do guia da visão geral, com o que já está pronto
GET	/sistema/manutencao	Estado do modo de manutenção: ativo, mensagem, desde quando e por quem (qualquer sessão)
PUT	/sistema/manutencao	Liga ou desliga, com `{ "ativo": true, "mensagem": "..." }` (mensagem de até 300 caracteres)
GET	/sistema/backups	Backups na pasta do servidor, com a frequência automática e quantos são mantidos
POST	/sistema/backups	Grava um backup agora e responde 201 com nome, tabelas, registros e tamanho
GET	/sistema/backups/{nome}	Baixa um backup (`application/gzip`) e registra o download na auditoria
GET	/sistema/limpeza	Prévia do que a retenção removeria agora, por categoria
POST	/sistema/limpeza	Aplica a retenção agora e registra o resultado na auditoria

Copyright (©) 2026 Erik Pimenta

6.8 Exemplos

Com cookie de sessão (curl)

```
curl -c sessao.txt -H "Content-Type: application/json" -H "X-Bento: 1" \
  -d '{"email":"admin@bento.local","senha":"bento123"}' \
  http://localhost:8080/api/v1/auth/entrar

curl -b sessao.txt "http://localhost:8080/api/v1/visao-geral?periodo=90d"

curl -b sessao.txt -H "X-Bento: 1" -H "Content-Type: application/json" \
  -d '{"motivo":"Cobrança em duplicidade"}' \
  http://localhost:8080/api/v1/transacoes/ID_DA_TRANSACAO/reembolsar

curl -b sessao.txt -H "X-Bento: 1" -H "Content-Type: application/json" \
  -d '{"ativo":true,"mensagem":"Atualização do banco até as 22h."}' \
  -X PUT http://localhost:8080/api/v1/sistema/manutencao
```

Importação simulada (curl e jq)

```
jq -Rs '{csv: ., simular: true, papelPadrao: "cliente"}' contas.csv |
  curl -b sessao.txt -H "X-Bento: 1" -H "Content-Type: application/json" \
    --data-binary @- http://localhost:8080/api/v1/usuarios/importar
```

Com chave de API (TypeScript)

```
interface PaginaTransacoes {
  itens: { codigo: string; valor: number; status: string }[];
  total: number;
}

const resposta = await fetch("https://painel.suaempresa.com/api/v1/transacoes?
status=paga&porPagina=100", {
  headers: { Authorization: "Bearer " + process.env.BENTO_CHAVE },
});
const { itens, total } = (await resposta.json()) as PaginaTransacoes;
```

Documentação interativa

Em `/api/v1/docs` a API publica todas as rotas com parâmetros, esquemas e exemplos, e permite testá-las no navegador com a sessão atual. A especificação OpenAPI em JSON fica em `/api/v1/docs/json`, pronta para gerar clientes em outras linguagens, e já declara os três esquemas de acesso: cookie de sessão, chave de API e token de métricas. A paleta de comandos tem um atalho para abri-la.

6.9 Adicionando uma rota

1. Crie a pasta do módulo em `api/src/modulos/` com um `rotas.ts` (e um `servico.ts` se a regra for grande).
2. Declare a rota com o esquema Zod de entrada, a etiqueta da documentação e o `preHandler` com `app.autenticar` e `exigir("permissao")`.

Copyright (©) 2026 Erik Pimenta

3. Registre a função em `api/src/app.ts`, junto das outras, dentro do prefixo `/api/v1`.
4. Se a rota altera dados que não devem mudar durante a manutenção, nada a fazer: o bloqueio vale para todo POST, PUT, PATCH e DELETE. Se ela precisar continuar liberada, inclua o caminho em `ISENTAS`, em `api/src/operacao/manutencao.ts`.
5. Escreva um teste em `api/test/`; a função `criarAmbiente()` de `auxiliar.ts` cria a API com um banco em memória já preenchido e aceita sobrescrever a configuração.

```
export async function rotasEstoque(app: FastifyInstance): Promise<void> {
  app.get('/estoque', {
    schema: { tags: ['Estoque'], summary: 'Itens em estoque', querystring: paginacaoSimples },
    preHandler: [app.autenticar, exigir('painel.ver')],
  }, async () => {
    const { linhas } = await app.banco.consultar('select id, nome from estoque order by nome');
    return { itens: linhas };
  });
}
```

Copyright (©) 2026 Erik Pimenta

07

Permissões

O acesso no Bento é controlado por papéis com permissões, mais exceções por pessoa. A interface esconde o que a pessoa não pode usar, e a API confere tudo de novo em cada rota.

7.1 Papéis

Papel	Código	Para quem
Administrador	`admin`	Donos do sistema: acesso total, inclusive dados da empresa, status do sistema, manutenção e permissões
Gerente	`gerente`	Gerencia usuários (inclusive a importação), transações e reembolsos, relatórios, integrações e auditoria, sem alterar o sistema
Analista	`analista`	Consulta métricas, analytics, usuários e transações e gera relatórios
Suporte	`suporte`	Atende clientes: consulta, edita, bloqueia e anota nas contas
Cliente	`cliente`	Contas da plataforma, sem acesso ao painel (o login responde 403)

7.2 Matriz de permissões

Permissão	O que libera	Adm.	Ger.	Anal.	Sup.
`painel.ver`	Acessa o painel e os indicadores principais	■	■	■	■
`analytics.ver`	Consulta gráficos, filtros por período e coortes	■	■	■	
`usuarios.ver`	Lista, pesquisa e abre o detalhe dos usuários	■	■	■	■
`usuarios.criar`	Cria contas novas	■	■		
`usuarios.importar`	Cadastra várias contas de uma planilha CSV	■	■		
`usuarios.editar`	Altera dados cadastrais e redefine senhas	■	■		■
`usuarios.bloquear`	Bloqueia e desbloqueia contas	■	■		■
`usuarios.anotar`	Escreve, fixa e remove notas internas	■	■		■
`usuarios.excluir`	Remove contas definitivamente	■			
`usuarios.permissoes`	Muda o papel e as permissões individuais	■			

Copyright (©) 2026 Erik Pimenta

Permissão	O que libera	Adm.	Ger.	Anal.	Sup.
`transacoes.ver`	Consulta e exporta transações	■	■	■	■
`transacoes.reembolsar`	Devolve o valor de transações pagas, com o motivo na auditoria	■	■		
`notificacoes.enviar`	Publica avisos para a equipe	■	■		
`relatorios.ver`	Consulta o histórico e baixa relatórios	■	■	■	
`relatorios.gerar`	Gera relatórios em CSV e PDF	■	■	■	
`relatorios.agendar`	Cria e pausa relatórios recorrentes	■	■	■	
`configuracoes.integracoes`	Conecta webhooks, Slack, Discord e outros serviços, e vê as entregas	■	■		
`configuracoes.sistema`	Dados da empresa, status do sistema, manutenção, backups e retenção	■			
`auditoria.ver`	Consulta o registro de atividades da plataforma	■	■		

Clientes não têm nenhuma permissão. A matriz é lida das migrações: as regras base estão em `api/migracoes/003_dados_base.sql`, e as permissões `transacoes.reembolsar`, `usuarios.anotar` e `usuarios.importar` foram incluídas por `004_reembolsos_auditoria.sql`, `005_notas_usuario.sql` e `006_operacao_preferencias.sql`.

7.3 Exceções por pessoa

As permissões efetivas de uma pessoa são as do papel, mais as concedidas e menos as negadas na aba Permissões do usuário:

```
efetivas = permissões do papel ∪ concedidas − negadas
```

Assim dá para deixar um analista exportar transações sem mudar o papel de todos os analistas, dar a um suporte específico o poder de reembolsar, ou tirar a importação de um gerente. Algumas regras valem sempre: ninguém bloqueia nem exclui a própria conta, quem não controla permissões só altera contas de nível menor que o seu, e só quem controla permissões cadastra ou importa administradores e gerentes.

Na interface, use `pode("relatorios.gerar")` de `nucleo/sessao.ts` para mostrar ou esconder botões: é assim que o botão **Reembolsar** só aparece para quem tem `transacoes.reembolsar`. Na API, `exigir("relatorios.gerar")` no `preHandler` da rota.

7.4 Criando uma permissão

1. Crie uma migração nova em `api/migracoes/`, com o próximo número livre (por exemplo `007_estoque.sql`), que insira a permissão em `permissoes` e os papéis que a recebem em `papel_permissoes`.
2. Proteja as rotas com `exigir("estoque.ver")`.
3. Use `pode("estoque.ver")` na interface e a propriedade `permissao` no item do menu.

Copyright (©) 2026 Erik Pimenta

```
insert into permissoes (codigo, modulo, nome, descricao, ordem) values
  ('estoque.ver', 'Estoque', 'Ver estoque', 'Consulta os itens em estoque.', 90)
on conflict (codigo) do nothing;

insert into papel_permissoes (papel, permissao) values
  ('admin', 'estoque.ver'), ('gerente', 'estoque.ver')
on conflict (papel, permissao) do nothing;
```

Copyright (©) 2026 Erik Pimenta

08

Tempo real

Transações, reembolsos, cadastros, notificações e o modo de manutenção aparecem no painel no momento em que acontecem, sem recarregar a página. O Bento usa Server-Sent Events, que funcionam em HTTP comum e atravessam proxies sem configuração especial.

8.1 Eventos

Depois do login, a interface abre uma conexão em `GET /api/v1/notificacoes/fluxo`. A API envia `retry: 5000` logo no início, um comentário `: ping` a cada 25 segundos para manter a conexão aberta, e estes eventos:

Evento	Conteúdo	Quem usa
`notificacao`	A notificação nova, já filtrada para a pessoa	Central do cabeçalho e página de notificações
`contagem`	`{ naoLidas }`	Número no sino e no menu
`transacao`	A transação paga ou reembolsada, com cliente e plano	Transações recentes da visão geral e página de transações
`usuario`	O usuário recém-cadastrado (só para quem tem `usuarios.ver`)	Atividades e lista de usuários
`sistema`	`{ manutencao }` com o estado novo do modo de manutenção	Faixa de manutenção em todas as páginas e aba Manutenção

Para consumir o fluxo em outro sistema, basta um `EventSource` no navegador ou qualquer cliente SSE com o cookie de sessão. As conexões abertas em cada instância aparecem na aba Status do sistema e na métrica `bento_tempo_real_conexoes`.

8.2 Várias instâncias

Com PostgreSQL, cada evento é publicado com `pg_notify` no canal `bento_eventos`, e cada instância da API mantém uma conexão dedicada com `LISTEN` que repassa o evento aos navegadores conectados nela. Por isso você pode rodar várias instâncias atrás de um balanceador sem perder eventos. A conexão de escuta se refaz sozinha em 3 segundos se cair.

O evento `sistema` também atualiza o estado guardado em memória por cada instância: ligar a manutenção em uma delas passa a recusar alterações em todas no mesmo instante. Ao subir, cada instância lê o estado do banco, então uma instância nova já nasce em manutenção se o modo estiver ligado.

Copyright (©) 2026 Erik Pimenta

Com PGlite, que roda dentro de um único processo, os eventos passam por um emissor em memória com o mesmo contrato.

PgBouncer

Se usar PgBouncer em modo transação, aponte a conexão de escuta direto para o PostgreSQL: `LISTEN` não funciona por um pool de transação.

8.3 Reconexão e indicador

O indicador no cabeçalho mostra **Ao vivo**, **Conectando** ou **Reconectando**. Se a conexão cair, a interface renova a sessão e tenta de novo com espera crescente (2, 4, 8 e até 30 segundos); ao voltar para a aba depois de um tempo, reabre a conexão e atualiza os números.

8.4 Simulador de atividade

Com `BENTO_SIMULADOR=true` (padrão), a API cria transações de assinantes em intervalos aleatórios em torno de `BENTO_SIMULADOR_INTERVALO` segundos (padrão 25; o intervalo real varia entre 60% e 140% desse valor), às vezes pendentes ou recusadas, e um cadastro novo a cada cinco ciclos. Cada evento gera notificação, atividade e disparo para as integrações ativas, exatamente como um evento real. Durante o modo de manutenção o simulador fica parado.

O simulador existe para demonstrar o painel. Desligue em produção com `BENTO_SIMULADOR=false`; o diagnóstico avisa se ele estiver ligado com `NODE_ENV=production`.

Copyright (©) 2026 Erik Pimenta

09

Relatórios

Os relatórios transformam os dados do painel em arquivos para planilhas, contabilidade ou apresentação. Cada um tem colunas fixas, prévia antes de gerar e histórico para baixar de novo.

9.1 Tipos e colunas

Tipo	Uma linha por	Colunas
Receita	Dia do período	Data, transações pagas, receita bruta, reembolsos, receita líquida
Transações	Transação	Código, data, cliente, e-mail, plano, método, status, valor
Usuários	Usuário cadastrado no período	Nome, e-mail, papel, status, plano, país, cadastro
Assinaturas	Assinatura iniciada no período	Cliente, e-mail, plano, ciclo, status, valor, início, cancelamento
Crescimento	Mês	Mês, novos usuários, assinaturas novas, cancelamentos, MRR no fim do mês, crescimento do MRR

Cada relatório traz também um resumo (totais, médias e taxas) que aparece na prévia e no topo do PDF.

9.2 Formatos

- **CSV** em UTF-8 com BOM e ponto e vírgula como separador, para abrir direto no Excel em português. Valores em reais com vírgula decimal e datas no formato dd/mm/aaaa. As exportações de usuários, transações e auditoria usam o mesmo formato, e células que começam com `=`, `+`, `-` ou `@` ganham um apóstrofo para não virar fórmula.
- **PDF** em A4 com a marca do Bento, título, período, data de geração, quadro de resumo e tabela com cabeçalho repetido a cada página e numeração no rodapé, nas cores da paleta monocromática.

O arquivo fica guardado no próprio banco, então qualquer instância da API consegue entregá-lo sem disco compartilhado. O nome segue o padrão `bento-receita-2026-09-22-a-2026-10-22.pdf`. Relatórios gerados há mais de `BENTO_RETENCAO_RELATORIOS` dias (90 por padrão) saem do histórico na limpeza diária; os agendamentos continuam e geram arquivos novos.

Copyright (©) 2026 Erik Pimenta

9.3 Envios agendados

Frequência	Quando roda	Períodos possíveis
Diária	Todo dia às 7h	Últimos 7 dias, últimos 30 dias ou mês anterior
Semanal	Toda segunda-feira às 7h	Os mesmos
Mensal	Todo dia 1º às 7h	Os mesmos

O horário segue `BENTO_FUSO`. Um agendador interno verifica a cada minuto os envios vencidos e reserva cada um com uma atualização condicional no banco, então só uma instância gera o arquivo mesmo com várias rodando. Quem criou o agendamento recebe uma notificação com o link do relatório pronto, e as integrações ativas recebem o evento `relatorio.gerado`. Durante o modo de manutenção os envios esperam e saem no primeiro ciclo depois dele; envios com mais de 10 minutos de atraso aparecem no diagnóstico e na métrica `bento_agendamentos_atrasados`.

9.4 Criando um tipo de relatório

1. Em `api/src/modulos/relatorios/dados.ts`, acrescente o tipo com nome, descrição e colunas (campo, título e formato: texto, moeda, número, data ou percentual).
2. Escreva a consulta que devolve as linhas e o resumo do período.
3. Crie uma migração que inclua o tipo novo nas restrições `relatorios_tipo_check` e `relatorios_agendados_tipo_check`.
4. A interface lê os tipos de `GET /relatorios/tipos`, então o novo tipo aparece sozinho na tela de relatórios.

Copyright (©) 2026 Erik Pimenta

10

Integrações

As integrações enviam os eventos do negócio para outros sistemas no momento em que acontecem: uma URL sua, um canal do Slack ou do Discord. Cada envio fica registrado, com novas tentativas automáticas quando o destino falha.

10.1 Provedores e campos

Integração	Campos	O teste faz
Webhook	URL de destino (http ou https) e segredo de assinatura (12 a 200 caracteres)	Um POST real com evento de teste, assinado
Slack	URL do webhook de entrada (hooks.slack.com)	Uma mensagem real no canal
Discord	URL do webhook do canal (discord.com/api/webhooks)	Uma mensagem real no canal
Google Analytics	ID de medição (G-XXXXXXX) e segredo da API de medição	Valida o formato dos campos
Stripe	Chave publicável (pk_), chave secreta (sk_ ou rk_) e segredo do webhook (whsec_)	Valida o formato dos campos

Os envios têm limite de 5 segundos e não seguem redirecionamentos. Se um destino falhar de vez, a integração fica com status de erro e a última mensagem aparece no cartão dela, sem atrapalhar o painel. Ativar, desativar, configurar e reenviar ficam registrados na auditoria.

10.2 Eventos enviados

Evento	Quando
`transacao.paga`	Uma transação foi paga
`usuario.criado`	Uma conta nova foi criada, pelo painel ou por cadastro
`usuario.bloqueado`	Uma conta foi bloqueada
`relatorio.gerado`	Um relatório ficou pronto, gerado à mão ou por agendamento

10.3 Webhook assinado

O webhook recebe um POST com o corpo JSON abaixo e dois cabeçalhos: `X-Bento-Evento`, com o nome do evento, e `X-Bento-Assinatura`, com `sha256=` seguido do HMAC-SHA256 do corpo calculado com o seu segredo.

Copyright (©) 2026 Erik Pimenta

```
{
  "evento": "transacao.paga",
  "resumo": "Paula Lima pagou R$ 129,00 (Profissional)",
  "criadoEm": "2026-10-22T14:03:11.402Z",
  "dados": { "id": "...", "codigo": "TX-009214", "valor": 12900, "moeda": "BRL" }
}
```

Confira a assinatura antes de confiar no conteúdo. Em Node.js:

```
import { createHmac, timingSafeEqual } from "node:crypto";

function assinaturaValida(corpoBruto, cabecalho, segredo) {
  const esperado = "sha256=" + createHmac("sha256", segredo).update(corpoBruto).digest("hex");
  const a = Buffer.from(esperado);
  const b = Buffer.from(cabecalho ?? "");
  return a.length === b.length && timingSafeEqual(a, b);
}
```

Use o corpo exatamente como chegou, antes de convertê-lo em objeto, para que o HMAC bata. Como uma entrega pode ser repetida (novas tentativas e reenvio), trate o evento de forma idempotente, por exemplo guardando o `dados.id` já processado.

10.4 Histórico de entregas e novas tentativas

Cada evento enviado a uma integração vira uma entrega na tabela `entregas_integracao`, com o evento, o resumo, a carga enviada, o status, o número de tentativas, o código HTTP, o tempo de resposta e o erro, se houver. No cartão da integração, o botão **Entregas** abre uma gaveta com o histórico, os filtros por status e os números de entregues, pendentes e com falha.

Status	O que significa
Entregue	O destino respondeu com 2xx
Pendente	A última tentativa falhou e há outra marcada; a gaveta mostra quando
Falhou	As quatro tentativas falharam, o destino foi recusado pela proteção de rede ou um teste falhou (testes não são repetidos)

- **Novas tentativas.** Quando o destino não responde ou devolve um erro, o agendador tenta de novo depois de 1, 5 e 30 minutos, até quatro tentativas no total. Entregas de teste não são repetidas, e destinos bloqueados pela proteção contra SSRF falham na hora.
- **Reenvio.** O botão **Reenviar** de uma entrega entregue ou com falha coloca o mesmo evento na fila para sair no próximo ciclo com a mesma carga. O reenvio entra na auditoria como `integracao.reenvio`.
- **Monitoramento.** As métricas `bento_entregas_pendentes`, `bento_entregas_falhas_24h` e `bento_integracoes_com_erro` mostram o estado de todas as integrações, e o diagnóstico avisa quando alguma está com erro.
- **Retenção.** O histórico é apagado depois de `BENTO_RETENCAO_ENTREGAS` dias (30 por padrão), exceto entregas pendentes.

Copyright (©) 2026 Erik Pimenta

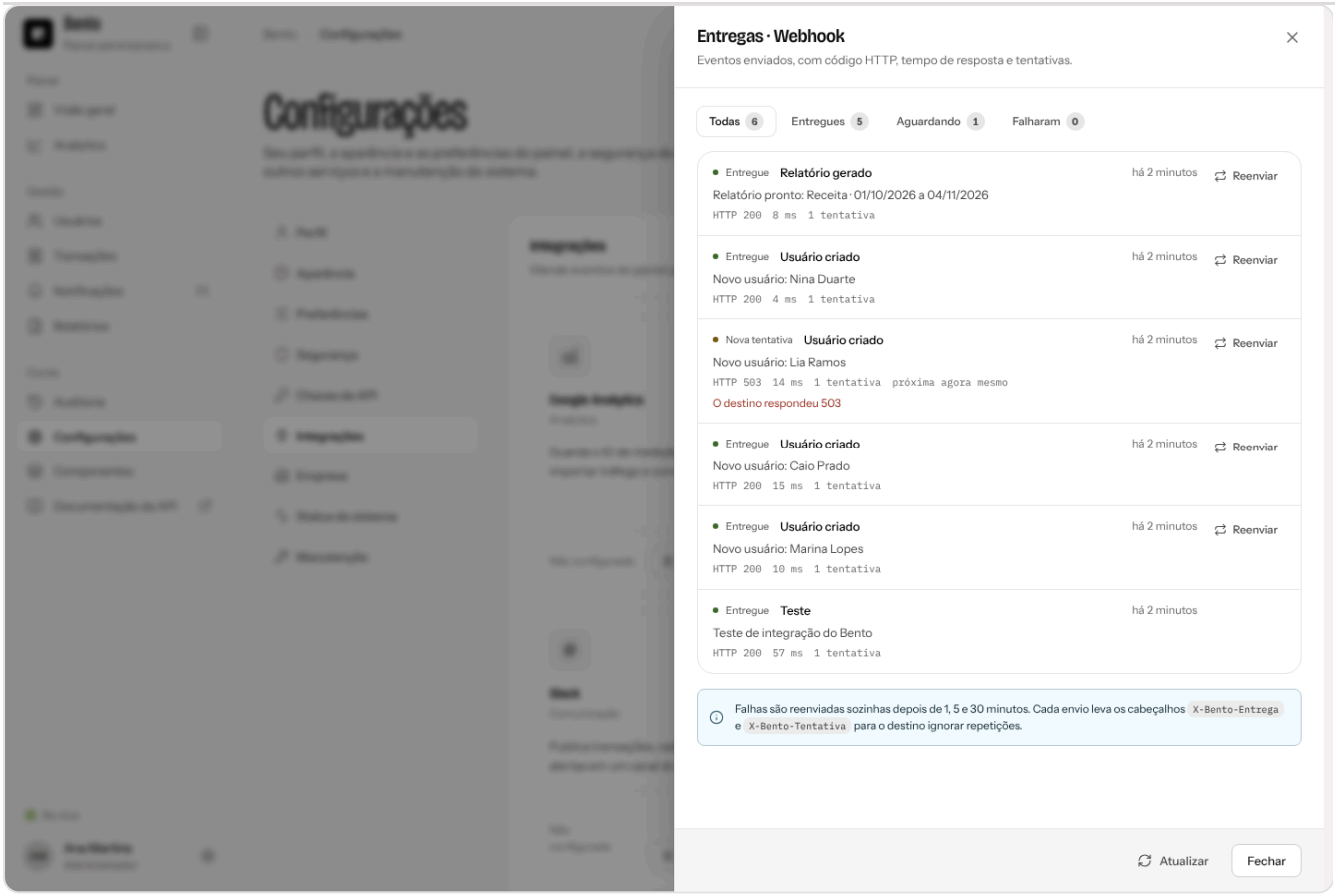


Figura 10.1 Gaveta de entregas do webhook, com código HTTP, tempo de resposta e tentativas.

10.5 Segredos protegidos

Campos do tipo segredo são cifrados com AES-256-GCM antes de ir para o banco, com uma chave derivada de `BENTO_SEGREDO_JWT`. A API nunca devolve o valor: a interface recebe só os quatro últimos caracteres, como `••••1234`. Ao editar uma integração, deixar um segredo em branco mantém o atual. As cargas guardadas no histórico de entregas não contêm os segredos da integração.

Troca do segredo da aplicação

Se você trocar `BENTO_SEGREDO_JWT`, os segredos já salvos não podem mais ser lidos. Abra cada integração ativa e informe os segredos de novo.

Copyright (©) 2026 Erik Pimenta

11

Configuração e segurança

Todo o comportamento do servidor é ajustado por variáveis de ambiente, lidas do arquivo .env na raiz do projeto ou do próprio ambiente. Nenhuma é obrigatória para rodar localmente, e todas são conferidas na inicialização.

11.1 Variáveis de ambiente

Servidor e banco

Variável	Padrão	O que faz
`BENTO_PORTA`	8080	Porta HTTP do servidor (1 a 65535)
`BENTO_HOST`	0.0.0.0	Interface de rede em que o servidor escuta
`DATABASE_URL`	vazio	Conexão do PostgreSQL. Vazio usa o PGlite embutido
`BENTO_DADOS`	dados/pglite	Pasta do PGlite; o valor `memoria` guarda tudo em memória
`BENTO_POOL`	10	Conexões no pool do PostgreSQL (1 a 200)
`BENTO_WEB`	web/dist	Pasta da interface construída que a API serve
`BENTO_LOG`	info	Nível de log: fatal, error, warn, info, debug, trace ou silent
`BENTO_FUSO`	America/Sao_Paulo	Fuso das agregações por dia, dos filtros de período e do agendador
`NODE_ENV`	vazio	Com `production`, endurece as checagens de segurança (padrão da imagem Docker)

Segurança e acesso

Variável	Padrão	O que faz
`BENTO_SEGREDO_JWT`	gerado	Assina as sessões e cifra os segredos das integrações. Sem ele, é gerado e salvo em `dados/segredo`. Em produção, precisa de 32 caracteres ou mais
`BENTO_HTTPS`	false	Cookies Secure, HSTS e atualização de requisições inseguras
`BENTO_ORIGENS`	vazio	Outras origens que podem chamar a API com credenciais, completas e separadas por vírgula

Copyright (©) 2026 Erik Pimenta

Variável	Padrão	O que faz
`BENTO_PROXY`	false	Confia no `X-Forwarded-For` de um proxy reverso
`BENTO_INTEGRACOES_REDE_INTERNA`	vazio	Com `1`, permite webhooks para localhost e redes internas (desliga a proteção contra SSRF)
`BENTO_METRICAS_TOKEN`	vazio	Liga `/api/v1/metricas` e define o token exigido; use 16 caracteres ou mais
`BENTO_ADMIN_EMAIL`	vazio	E-mail do administrador criado na inicialização, se ainda não existir
`BENTO_ADMIN_SENHA`	vazio	Senha desse administrador (mínimo 8 caracteres)
`BENTO_ADMIN_NOME`	Administrador	Nome desse administrador

Demonstração

Variável	Padrão	O que faz
`BENTO_SEMEAR`	auto	`nao` desliga os dados de demonstração em banco vazio
`BENTO_SIMULADOR`	true	Gera transações e cadastros de demonstração
`BENTO_SIMULADOR_INTERVALO`	25	Intervalo médio do simulador, em segundos (5 a 3600)

Backup e retenção

Variável	Padrão	O que faz
`BENTO_BACKUP_AUTOMATICO`	desligado	`diario` ou `semanal` liga o backup automático (o `.env.example` e o Docker Compose usam `diario`)
`BENTO_BACKUP_MANTER`	7	Quantos backups automáticos guardar; os mais antigos são apagados (1 a 365)
`BENTO_BACKUP_PASTA`	dados/backups	Pasta dos backups, relativa à raiz do projeto ou absoluta
`BENTO_RETENCAO_NOTIFICACOES`	180	Dias que as notificações ficam guardadas; `0` guarda para sempre
`BENTO_RETENCAO_RELATORIOS`	90	Dias que o arquivo de um relatório gerado fica disponível; `0` guarda para sempre
`BENTO_RETENCAO_AUDITORIA`	0	Dias que a auditoria fica guardada; `0` (padrão) guarda para sempre
`BENTO_RETENCAO_SESSOES`	30	Dias que sessões encerradas ou expiradas continuam no banco (mínimo 1)
`BENTO_RETENCAO_ENTREGAS`	30	Dias que o histórico de entregas das integrações fica guardado (mínimo 1)

Copyright (©) 2026 Erik Pimenta

Docker Compose

Variável	Padrão	O que faz
`BENTO_DB_NOME`	bento	Banco criado pelo Docker Compose
`BENTO_DB_USUARIO`	bento	Usuário do banco no Docker Compose
`BENTO_DB_SENHA`	gerada	Senha do banco no Docker Compose, criada pelos scripts de inicialização

11.2 Validação da configuração

A configuração é lida uma vez, na inicialização, e cada variável é conferida: números fora do intervalo, opções que não existem e valores que não são `true` ou `false` viram avisos com o nome da variável e o valor esperado, e o Bento usa o padrão daquela variável. Os avisos aparecem no log ao subir, no `npm run diagnostico` e na aba Manutenção.

Alguns casos impedem a inicialização, para não subir um servidor inseguro ou quebrado:

- `BENTO_SEGREDO_JWT` com o valor de exemplo, ou com menos de 32 caracteres, quando `NODE_ENV=production`;
- `BENTO_ADMIN_EMAIL` que não é um e-mail válido, ou `BENTO_ADMIN_SENHA` com menos de 8 caracteres;
- uma migração que falha (a transação desfaz tudo e o log mostra o erro).

Para conferir sem subir

Rode `npm run diagnostico`. Ele lê o mesmo `.env`, abre o banco, confere as migrações e a segurança e termina com código 1 se houver algum erro, o que permite usá-lo em scripts de implantação.

11.3 Dados da empresa

Nome da empresa, moeda, fuso e meta mensal ficam no banco e são editados em Configurações › Empresa. A meta mensal alimenta o medidor da visão geral e a linha de meta do gráfico de receita. Cada alteração entra na auditoria. Trocar o nome da empresa conclui o primeiro item do guia de primeiros passos.

11.4 Segurança aplicada

- Senhas com bcrypt; tokens de sessão e chaves de API guardados só como hash SHA-256.
- Cabeçalhos de segurança com Helmet, incluindo política de conteúdo que só permite recursos da própria origem.
- Cookies httpOnly e SameSite=Lax, com Secure quando `BENTO_HTTPS=true`.
- Proteção contra falsificação de requisição pelo cabeçalho `X-Bento`, limites de requisição por IP e suspensão temporária após senhas erradas.
- Validação de toda entrada com Zod e consultas SQL sempre parametrizadas, inclusive na importação de planilhas, que grava com `jsonb_to_recordset`.
- Permissão própria para ações de dinheiro e de massa: reembolsar exige `transacoes.reembolsar`; importar exige `usuarios.importar` e respeita a regra de níveis para administradores e gerentes.
- Exportações e importações passam pelas mesmas permissões e filtros da tela e têm limite de linhas e de tamanho.
- Status do sistema, diagnóstico, backups e retenção restritos a `configuracoes.sistema`, sem expor variáveis de ambiente, segredos ou senhas. Os backups só são baixados pelo nome exato de um arquivo listado, e cada

Copyright (©) 2026 Erik Pimenta

download entra na auditoria.

- Métricas desligadas por padrão e, quando ligadas, protegidas por token comparado em tempo constante.
- Modo de manutenção aplicado no servidor, não só na interface: alterações recebem 503 mesmo por chave de API.
- Registro de atividades sem chave estrangeira obrigatória, para o histórico continuar mesmo depois de excluir uma conta.

11.5 Auditoria de segurança da versão 1.1.0

Antes do lançamento da 1.1.0, a aplicação passou por uma auditoria de segurança. Os achados e o que foi feito com cada um:

#	Achado	Severidade	Situação
01	**Escalada de privilégio.** O papel Suporte podia redefinir a senha do administrador e entrar como ele. Agora quem não tem `usuarios.permissoes` só altera contas de nível menor que o seu, e desbloquear pelo PATCH de status exige `usuarios.bloquear`.	crítica	corrigido
02	**SSRF nos webhooks.** URLs para localhost, IPs internos (em decimal, hexadecimal e IPv6 mapeado), 169.254.x.x, redes privadas e CGNAT são recusadas ao salvar e ao enviar; o envio não segue redirecionamentos; URL com usuário e senha é recusada.	alta	corrigido
03	**Injeção de fórmula no CSV.** Células de texto que começam com `=`, `+`, `-`, `@`, tabulação ou retorno de carro ganham um apóstrofo.	média	corrigido
04	**IDOR em relatórios.** Só o autor ou quem tem `configuracoes.sistema` apaga relatórios e apaga ou pausa agendamentos.	média	corrigido
05	**Enumeração de usuários no login.** E-mails inexistentes passam pelo mesmo bloqueio temporário.	baixa	corrigido
06	**Redirecionamento aberto.** Links de avisos como `//site` e o parâmetro `?voltar=` com endereços externos são recusados.	baixa	corrigido
07	**Eventos de usuários no tempo real.** O fluxo SSE não manda eventos de usuários para quem não tem `usuarios.ver`.	baixa	corrigido
08	**Caminhos no servidor estático.** O servidor responde 404 para `..`, barra invertida e byte nulo no caminho.	baixa	corrigido

Os casos verificados viraram testes automatizados em `api/test/seguranca.test.ts`, que rodam a cada envio no GitHub Actions. Na 1.4.0 a integração contínua passou a rodar também `npm audit --omit=dev --audit-level=high`, que interrompe o fluxo se alguma dependência de produção tiver vulnerabilidade alta ou crítica.

Riscos conhecidos

DNS rebinding entre a checagem do endereço e o envio do webhook: um domínio pode responder com um IP público na checagem e com um interno no envio. Para destinos críticos, use um proxy de saída que bloqueie redes internas.

O bloqueio por tentativas pode ser usado para travar por 15 minutos a conta de outra pessoa, bastando errar a senha dela cinco vezes. Um administrador pode redefinir a senha, e o limite por IP reduz o abuso.

Copyright (©) 2026 Erik Pimenta

12

Operação e manutenção

A 1.4.0 traz as ferramentas para manter o Bento no ar sem abrir o banco à mão: diagnóstico, modo de manutenção, backups, retenção de dados, sondas de saúde, métricas e identificador de requisição. Quase tudo existe em dois lugares: no terminal e na aba Configurações › Manutenção.

12.1 Diagnóstico

`npm run diagnostico` confere o ambiente e mostra cada verificação com o status **ok**, **info**, **aviso** ou **erro**, agrupadas em Ambiente, Configuração, Banco de dados, Segurança e Operação. Com `-- --json`, a saída sai em JSON, para scripts. O comando termina com código 1 quando há algum erro.

Grupo	O que confere
Ambiente	Versão do Node.js (22 ou mais nova), modo de execução e se a interface construída foi encontrada
Configuração	Avisos das variáveis de ambiente
Banco de dados	Conexão e latência, tipo de banco, pasta do PGlite gravável e migrações pendentes ou desconhecidas
Segurança	Segredo das sessões, HTTPS e cookies, administradores ativos e contas da equipe com a senha de demonstração
Operação	Métricas, simulador em produção, política de retenção, backup automático em dia, integrações com erro e relatórios agendados atrasados

```
npm run diagnostico
docker compose exec bento node api/dist/cli.js diagnostico
```

Copyright (©) 2026 Erik Pimenta

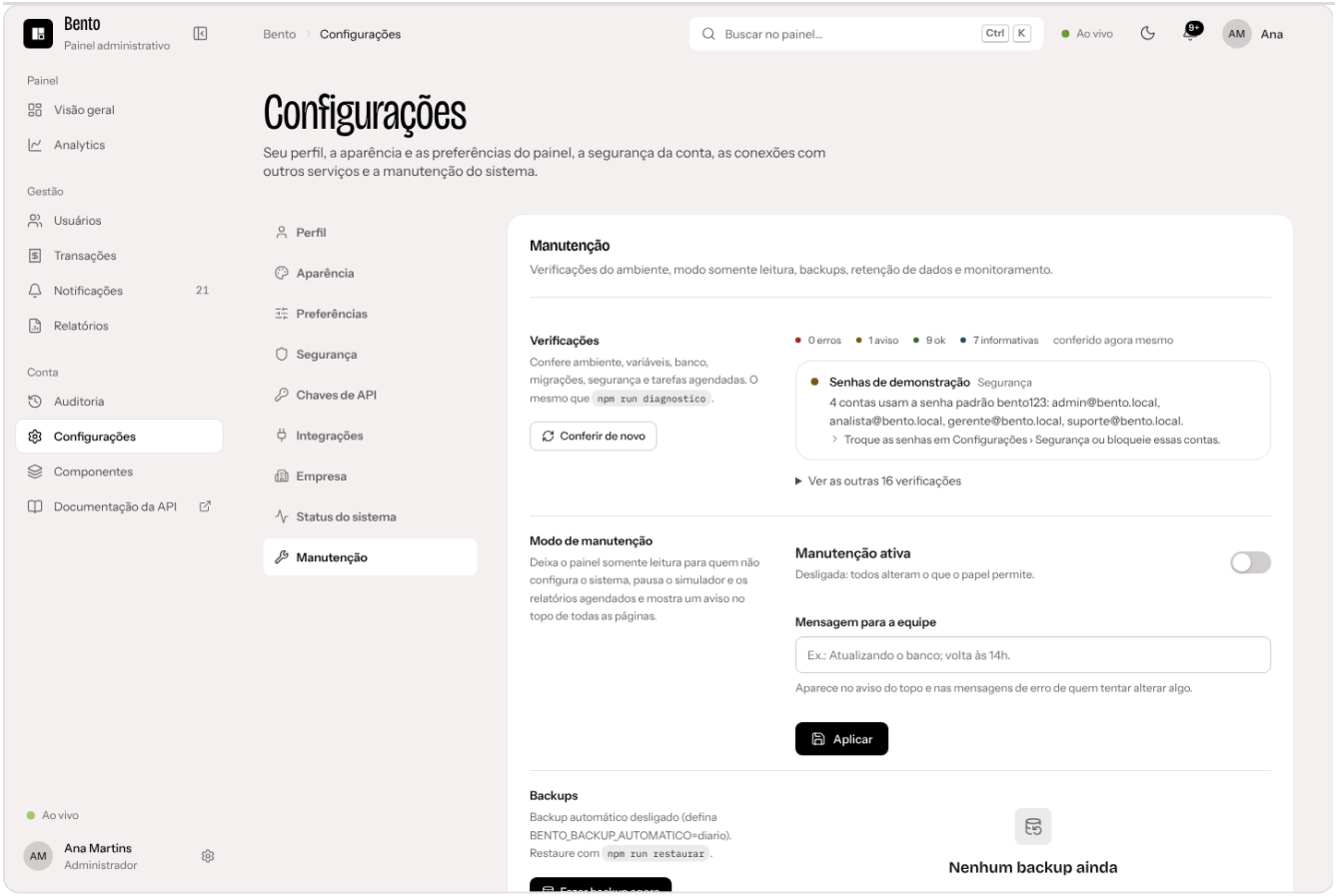


Figura 12.1 As verificações na aba Manutenção, com erros e avisos primeiro.

12.2 Modo de manutenção

O modo de manutenção deixa o painel em somente leitura enquanto você atualiza o servidor, migra dados ou investiga um problema. Ele é ligado em Configurações › Manutenção, com uma mensagem opcional de até 300 caracteres, ou por `PUT /api/v1/sistema/manutencao`.

- Todas as páginas mostram a faixa **Painel em manutenção** abaixo do cabeçalho, com a mensagem, quem ligou e desde quando. Quem tem `configuracoes.sistema` vê também o botão **Encerrar**.
- A API recusa POST, PUT, PATCH e DELETE com 503 e o código `MANUTENCAO`, inclusive por chave de API. Consultas, exportações e downloads continuam funcionando.
- Continuam liberados: entrar, sair e renovar a sessão, marcar notificações como lidas, salvar a aparência e as preferências e tudo o que é feito por quem tem `configuracoes.sistema`.
- Os relatórios agendados e o simulador esperam; as entregas das integrações, a retenção e o backup automático continuam.
- O estado fica no banco (`configuracoes_sistema`, chave `manutencao`), sobrevive a reinícios e vale para todas as instâncias ao mesmo tempo (seção 8.2). Ligar e desligar entram na auditoria.

Copyright (©) 2026 Erik Pimenta

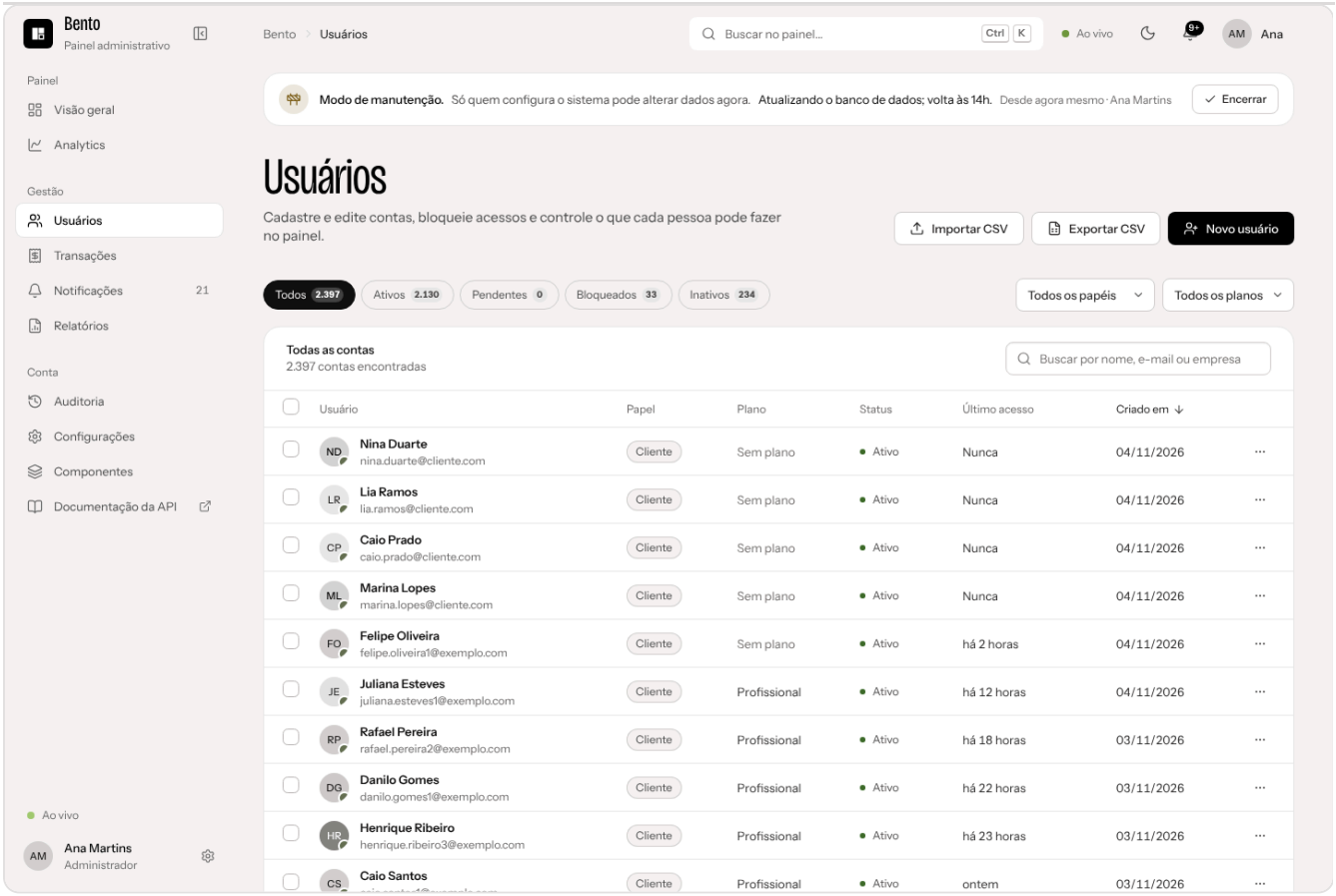


Figura 12.2 Faixa de manutenção na página de transações.

12.3 Backup e restauração

Um backup do Bento é um arquivo `bento-backup-AAAAMMDD-HHMMSS.ndjson.gz`: JSON em linhas, compactado com gzip. A primeira linha é o cabeçalho (versão do Bento, tipo de banco, data, migrações aplicadas, contagem de cada tabela e valor das sequências); depois vêm os registros de cada tabela em lotes, na ordem das chaves estrangeiras; a última linha marca o fim. O mesmo arquivo restaura em PGlite ou em PostgreSQL.

Comando	O que faz
`npm run backup`	Grava um backup em `BENTO_BACKUP_PASTA`
`npm run backup -- --pasta /mnt/copias`	Grava em outra pasta
`npm run restaurar -- arquivo.ndjson.gz`	Pede confirmação e substitui todos os dados pelos do backup
`npm run restaurar -- arquivo.ndjson.gz --sim`	Restaura sem perguntar, para scripts

- **Consistente.** O backup é lido em uma única transação somente leitura, então reflete um instante só, mesmo com o painel em uso.
- **Pela interface.** Em Configurações › Manutenção, **Fazer backup agora** grava um arquivo e a lista mostra os backups com data, tamanho e o botão de baixar.
- **Automático.** Com `BENTO_BACKUP_AUTOMATICO=diario` ou `semanal`, o agendador grava um backup no intervalo escolhido e apaga os automáticos mais antigos, mantendo `BENTO_BACKUP_MANTER`. Backups manuais não são

Copyright (©) 2026 Erik Pimenta

apagados.

- **Restauração.** Em uma transação, apaga o esquema, recria as tabelas com as migrações que o backup tinha, insere os registros, acerta as sequências e depois aplica as migrações mais novas. Se algo falhar, nada muda. Um backup feito por uma versão mais nova do Bento é recusado.

> **PGlite e o servidor no ar**
>
> O PGlite não aceita dois processos no mesmo banco. Com ele, os comandos de terminal se recusam a rodar enquanto o servidor estiver no ar; use o botão da aba Manutenção para fazer backup e pare o servidor para restaurar. Com PostgreSQL, os comandos rodam com o servidor ligado: para restaurar, ligue antes o modo de manutenção.

Guarde cópias fora do servidor. Com Docker, os backups ficam no volume `bento_dados-bento`; para copiar um arquivo para a máquina, use `docker compose cp bento:/app/dados/backups ./backups`.

12.4 Retenção de dados

Uma vez por dia o agendador apaga o que passou do prazo, com as regras abaixo. A limpeza é reservada no banco, então roda em uma instância só.

Categoria	Prazo	Variável
Sessões encerradas ou expiradas	30 dias	`BENTO_RETENCAO_SESSOES`
Notificações	180 dias	`BENTO_RETENCAO_NOTIFICACOES`
Arquivos de relatórios gerados	90 dias	`BENTO_RETENCAO_RELATORIOS`
Histórico de entregas das integrações	30 dias	`BENTO_RETENCAO_ENTREGAS`
Registros da auditoria	sem limite	`BENTO_RETENCAO_AUDITORIA`

`npm run limpar -- --simular` mostra quanto seria removido sem apagar nada, e `npm run limpar` aplica as regras na hora. Na aba Manutenção, a tabela de retenção mostra a mesma prévia, com o espaço ocupado, e o botão **Limpar agora**. Cada limpeza que remove algo entra na auditoria como `sistema.limpeza_executada`, com o número por categoria.

12.5 Saúde e métricas

Rota	Para que serve
`/api/v1/saude/vivo`	Sonda de vida (liveness): 200 enquanto o processo responde. Não consulta o banco
`/api/v1/saude/pronto`	Sonda de prontidão (readiness): 200 com o banco no ar e as migrações em dia; 503 com os motivos quando não, inclusive durante o encerramento
`/api/v1/saude`	Resumo para pessoas: banco, versão, tempo no ar e manutenção
`/api/v1/metricas`	Métricas do Prometheus, com token

Copyright (©) 2026 Erik Pimenta

A imagem Docker e o Docker Compose usam `/saude/pronto` na verificação de saúde. Ao receber `SIGTERM`, o servidor passa a responder 503 na prontidão, termina as requisições em andamento e fecha o banco; o Docker Compose espera até 20 segundos por isso.

Com `BENTO_METRICAS_TOKEN` definido, o Prometheus coleta `/api/v1/metricas`:

```
scrape_configs:
  - job_name: bento
    metrics_path: /api/v1/metricas
    authorization:
      credentials: troque-pelo-valor-de-BENTO_METRICAS_TOKEN
    static_configs:
      - targets: ["painel.suaempresa.com"]
```

Métrica	O que mede
`bento_requisicoes_total`	Requisições por método, rota e status
`bento_requisicao_duracao_segundos`	Histograma do tempo de resposta por rota
`bento_info`	Versão do Bento, tipo de banco e versão do Node.js
`bento_tempo_no_ar_segundos`, `bento_memoria_bytes`	Processo
`bento_tempo_real_conexoes`	Conexões de tempo real nesta instância
`bento_manutencao`	1 durante o modo de manutenção
`bento_banco_disponivel`	1 quando o banco respondeu à coleta
`bento_usuarios`, `bento_sessoes_ativas`, `bento_notificacoes`	Contas por status, sessões abertas e notificações guardadas
`bento_relatorios_bytes`, `bento_agendamentos_atrasados`	Espaço dos relatórios e envios atrasados
`bento_entregas_pendentes`, `bento_entregas_falhas_24h`, `bento_integracoes_com_erro`	Saúde das integrações

As rotas aparecem agrupadas pelo modelo (`/api/v1/usuarios/:id`), nunca pelo endereço com identificadores, para que o número de séries não cresça.

12.6 Logs e identificador de requisição

Os logs saem em JSON na saída padrão, no nível de `BENTO_LOG`, e cada linha de uma requisição traz o `reqId`. É o mesmo valor devolvido no cabeçalho `X-Request-Id` e, em erros 500, no campo `erro.requisicao`. Na interface, a mensagem de erro mostra os oito primeiros caracteres desse identificador como **Código do erro**.

Quando alguém da equipe mandar um código, procure no log:

```
docker compose logs bento | grep 3f9c2a1b
```

Copyright (©) 2026 Erik Pimenta

Para ligar os logs do proxy aos do Bento, configure o proxy para gerar e repassar um `X-Request-Id`; a API usa o valor recebido em vez de criar outro.

12.7 Tarefas automáticas

O agendador interno roda a cada minuto, em todas as instâncias, e cada tarefa é reservada no banco para rodar em uma só:

Tarefa	Quando
Relatórios agendados	No horário de cada envio, fora do modo de manutenção
Entregas das integrações	A cada minuto, para as entregas pendentes cujo horário chegou
Retenção de dados	Uma vez a cada 24 horas
Backup automático	A cada 24 horas (`diario`) ou 7 dias (`semanal`), se ligado

Uma tarefa que falha é registrada no log com o nome dela e não impede as outras.

Copyright (©) 2026 Erik Pimenta

13

Testes, build e CI

O projeto vem com testes automatizados para a API e para o núcleo da interface, checagem de tipos, cobertura e um fluxo de integração contínua que sobe tudo contra um PostgreSQL de verdade.

13.1 Comandos

Comando	O que faz
`npm run dev`	API com recarga automática e Vite em http://localhost:5173
`npm run build`	Gera `web/dist` e `api/dist`
`npm start`	Sobe a versão construída em http://localhost:8080
`npm test`	Testes da API (87) e do núcleo da interface (23)
`npm run cobertura`	Testes da API com relatório de cobertura
`npm run verificar`	Checagem de tipos strict da interface e da API, sem gerar arquivos
`npm run migrar`	Aplica as migrações pendentes
`npm run semear`	Cria os dados de demonstração em um banco vazio
`npm run admin`	Cria o administrador definido em `BENTO_ADMIN_*`
`npm run diagnostico`	Confere ambiente, configuração, banco e segurança
`npm run backup`	Grava um backup completo
`npm run restaurar -- <arquivo>`	Restaura um backup
`npm run limpar`	Aplica a retenção de dados (`-- --simular` só mostra)
`npm run versao`	Confere ou muda a versão em todos os arquivos

Todos os comandos de banco passam por `api/src/cli.ts`, que também roda direto com `node api/dist/cli.js <comando>`, a forma usada dentro do contêiner. Sem comando, ele mostra a ajuda.

Copyright (©) 2026 Erik Pimenta

13.2 O que os testes cobrem

API (87 testes): login e recusa de senha errada e de clientes, sessão obrigatória, CSRF, renovação girando o token, chave de API somente leitura, permissões do papel e individuais, listas com paginação, ordenação, filtros e validação, bloqueio com encerramento de sessões, reembolso, auditoria, notas internas, status do sistema, visão geral, analytics, relatórios em CSV e PDF, agendamentos e notificações. Na 1.4.0 entraram:

- `operacao.test.ts`: sondas de vida e prontidão, `X-Request-Id`, métricas do Prometheus só com o token certo, diagnóstico, modo de manutenção, retenção, primeiros passos, preferências novas, status do sistema, tarefas que rodam uma vez por intervalo, avisos de configuração e segredo de exemplo recusado em produção;
- `backup.test.ts`: formato do arquivo, restauração completa em outro banco com binários, identidades e sequências, arquivos inválidos ou incompletos recusados sem alterar nada, e gravação, listagem, download e poda pela API;
- `importacao-entregas.test.ts`: leitura de CSV (delimitador, aspas, quebras de linha e BOM), prévia sem gravar, importação com auditoria e notificação, permissão e cabeçalho obrigatório, e o ciclo de entregas assinadas com nova tentativa, limite de tentativas, reenvio e entrega de teste no histórico.

Cada arquivo de teste usa um banco PGlite em memória próprio.

Interface (23 testes): escape de HTML na template tag, formatação em português, navegação por atalhos e comandos, visões salvas e, em `web/tests/preferencias.test.ts`, itens recentes, colunas ocultas, página inicial permitida e o código curto dos erros 500.

Os testes usam o executor nativo do Node.js; o tsx carrega os arquivos TypeScript.

13.3 Integração contínua

O fluxo `.github/workflows/ci.yml` roda a cada envio para a `main`, em pull requests e sob demanda, e cancela execuções antigas do mesmo ramo:

- **Interface:** instala, confere a versão em todos os arquivos, checa os tipos, roda os testes e constrói o Vite.
- **API:** checa os tipos, audita as dependências de produção, roda os testes com cobertura, compila, e contra um PostgreSQL 18 de serviço roda `migrar`, `semear`, `backup`, `restaurar` e `diagnostico`; depois sobe a API, espera a prontidão e faz requisições reais de saúde, métricas, login, visão geral e usuários.
- **Docker:** constrói a imagem de produção.

O Dependabot (`.github/dependabot.yml`) abre pedidos semanais de atualização do npm, agrupados em interface, API e ferramentas, e mensais das Actions e da imagem Docker. O ApexCharts fica de fora de propósito (seção 15.1).

13.4 Versão e convenções

A versão do projeto mora no arquivo `VERSION`. A API lê esse arquivo para a documentação, a sonda de saúde, o status, as métricas e os backups. Para lançar uma versão nova:

```
npm run versao -- 1.5.0
npm run versao -- --conferir
```

O primeiro comando grava a versão em `VERSION`, nos três `package.json` e no `package-lock.json`; o segundo confere se todos batem, e é o que a CI roda. Lembre também de atualizar `VERSAO_NOVIDADES` e a lista em `web/src/ts/layout/novidades.ts`, para a janela de novidades aparecer.

Copyright (©) 2026 Erik Pimenta

O código não tem comentários: nomes descritivos em português, funções curtas e tipos explícitos contam o que cada parte faz, e este manual guarda o porquê. O `.nvmrc` fixa o Node.js 22 para o nvm e o fnm.

Copyright (©) 2026 Erik Pimenta

14

Solução de problemas

Os problemas abaixo são os mais comuns ao instalar, operar e adaptar o Bento, com a causa e o que fazer. Antes de tudo, rode npm run diagnostico: ele aponta a maioria deles.

14.1 Instalação e inicialização

A porta 8080 já está em uso

Outro programa usa a porta. Defina `BENTO_PORTA=8090` (ou outra livre) no `.env` e inicie de novo. Com Docker, a porta publicada muda junto.

“Defina BENTO_DB_SENHA no arquivo .env”

O Docker Compose não encontrou o `.env`. Rode `iniciar.cmd` ou `iniciar.sh`, que criam o arquivo, ou copie `.env.example` para `.env` e preencha a senha e o segredo.

“BENTO_SEGREDO_JWT é curto ou é o valor de exemplo”

Com `NODE_ENV=production` (o padrão da imagem Docker), a API não sobe com um segredo fraco. Gere um valor com `openssl rand -hex 32` e coloque em `BENTO_SEGREDO_JWT`. Os scripts de inicialização já fazem isso na primeira vez.

O npm reclama da versão do Node.js

O projeto exige Node.js 22 ou mais novo. Confira com `node -v`; com nvm ou fnm, rode `nvm use` na pasta do projeto, que lê o `.nvmrc`.

“A API não respondeu” ao abrir o Vite

Em desenvolvimento, a interface em 5173 depende da API em 8080. Use `npm run dev`, que sobe as duas, em vez de `npx vite` sozinho.

A API não sobe depois de atualizar

A migração nova roda sozinha ao iniciar. Se ela falhar, nada muda e a API não sobe; o log mostra o erro. Confira se o banco não foi alterado à mão e rode `npm run migrar` para ver a mensagem completa.

O log mostra avisos de configuração

Uma variável tem um valor que o Bento não entende, e o padrão foi usado no lugar. A mensagem diz qual variável e o que ela aceita; corrija o `.env` e reinicie.

Copyright (©) 2026 Erik Pimenta

14.2 Dados e acesso

Quero apagar tudo e voltar aos dados de demonstração

Com PGlite, pare o servidor e apague a pasta `dados/pglite` (os backups em `dados/backups` podem ficar). Com Docker, rode `docker compose down -v` e suba de novo. A semente roda sozinha no banco vazio.

Esqueci a senha do administrador

Outro administrador pode usar **Redefinir senha** na gaveta do usuário. Se não houver outro, defina `BENTO_ADMIN_EMAIL`, `BENTO_ADMIN_SENHA` e `BENTO_ADMIN_NOME` com um e-mail novo, inicie o servidor, entre com essa conta e redefina a senha da antiga.

"Muitas tentativas sem sucesso"

Depois de cinco senhas erradas seguidas, o login daquela conta fica suspenso por 15 minutos. Espere o prazo ou peça a um administrador para redefinir a senha.

Todo mundo saiu da conta de repente

O segredo das sessões mudou. Isso acontece quando `BENTO_SEGREDO_JWT` é trocado ou quando a pasta `dados/` foi apagada sem o segredo estar definido no `.env`. Defina um segredo fixo para evitar.

O botão Reembolsar ou Importar CSV não aparece

Reembolsar só aparece em transações pagas e para quem tem `transacoes.reembolsar`. **Importar CSV** exige `usuarios.criar` e `usuarios.importar`. Por padrão, as duas são de administradores e gerentes; outras pessoas podem receber uma exceção na aba Permissões.

A importação marcou linhas como ignoradas

O e-mail já existe no Bento ou se repete na planilha. A prévia mostra o motivo de cada linha; edite a conta existente em vez de importar de novo.

Os acentos da planilha saíram errados

O Bento tenta UTF-8 e, se o arquivo não for UTF-8, lê como Windows-1252, a codificação do Excel em português. Se mesmo assim sair errado, salve a planilha como **CSV UTF-8** no Excel ou no LibreOffice.

Auditoria, Status do sistema ou Manutenção não aparecem

A página Auditoria exige `auditoria.ver`; as abas Status do sistema e Manutenção exigem `configuracoes.sistema`, que por padrão só administradores têm.

A exportação veio vazia ou cortada

O CSV usa exatamente os filtros da tela. Limpe os filtros ou amplie o período; acima de 10.000 linhas, divida a exportação em períodos menores.

Copyright (©) 2026 Erik Pimenta

14.3 Interface, tempo real e integrações

Os atalhos com g não funcionam

Eles ficam desligados enquanto um campo está em edição e quando a preferência **Atalhos de uma tecla** está desligada. Clique fora do campo ou aperte `Esc` e confira em Configurações › Preferências; `Ctrl` + `K` funciona em qualquer situação.

Uma coluna sumiu da tabela

Ela foi escondida pelo botão **Colunas**, no rodapé da tabela. Marque a coluna de novo ou use **Restaurar o padrão**. A escolha vale para aquele navegador.

O indicador fica em “Reconectando” atrás de um proxy

O proxy está segurando a resposta. Desligue o buffer na rota `/api/v1/notificacoes/fluxo` (`proxy_buffering off` no Nginx, `flush_interval -1` no Caddy) e aumente o tempo limite de leitura para mais de 30 segundos.

O webhook para um endereço interno é recusado

URLs para localhost, IPs internos e redes privadas são recusadas para evitar SSRF. Se o destino interno é intencional, defina `BENTO_INTEGRACOES_REDE_INTERNA=1` no `.env`.

O teste do webhook falha

A URL precisa ser acessível a partir do servidor do Bento e responder em até 5 segundos com status 2xx, sem redirecionamento. Abra **Entregas** no cartão da integração: o código HTTP, o tempo e a mensagem de erro de cada tentativa ficam ali.

Um evento chegou duas vezes no meu sistema

Uma entrega foi repetida por uma nova tentativa (o destino demorou mais de 5 segundos e respondeu depois) ou por um reenvio. Trate os eventos de forma idempotente pelo `dados.id`.

Um gráfico ficou com as cores erradas depois de mudar a paleta

Os gráficos leem as cores das variáveis CSS ao desenhar. Se você criou uma paleta, confira se ela declara os onze tons de `primaria`, `destaque` e `neutra`.

14.4 Operação

Tudo dá “O painel está em manutenção”

O modo de manutenção está ligado. Quem tem `configuracoes.sistema` encerra pela faixa ou pela aba Manutenção. Sem acesso à interface, rode `PUT /api/v1/sistema/manutencao` com `{ "ativo": false }` usando uma chave de API de escrita de um administrador.

“O Bento está rodando com o banco embutido”

Os comandos de terminal não abrem o PGlite com o servidor no ar. Pare o servidor, rode o comando e suba de novo, ou use a aba Manutenção para backups e limpezas.

Copyright (©) 2026 Erik Pimenta

O contêiner fica “unhealthy”

A sonda `/api/v1/saude/pronto` está respondendo 503. Rode `curl http://localhost:8080/api/v1/saude/pronto`: a resposta lista os motivos, como banco fora do ar ou migrações pendentes.

O backup automático não aparece

Confira `BENTO_BACKUP_AUTOMATICO` (`diario` ou `semanal`) e se a pasta de `BENTO_BACKUP_PASTA` é gravável; o diagnóstico mostra as duas coisas. O primeiro backup automático sai no primeiro minuto depois de o servidor subir.

“O backup foi feito por uma versão mais nova do Bento”

Atualize o Bento para a mesma versão do backup, ou uma mais nova, antes de restaurar.

O Prometheus recebe 401 ou 404

404 indica que `BENTO_METRICAS_TOKEN` não está definido no servidor. 401 indica que o token enviado no `Authorization: Bearer` não confere.

Copyright (©) 2026 Erik Pimenta

15

Licenças

O Bento é distribuído sob a licença MIT. Os componentes de terceiros mantêm as próprias licenças, todas permissivas.

15.1 Componentes de terceiros

Componente	Uso no projeto	Licença
Tailwind CSS	Estilos e componentes	MIT
Vite	Servidor de desenvolvimento e build	MIT
ApexCharts 4.7.0	Gráficos interativos	MIT
Lucide	Ícones	ISC
Instrument Sans, Bricolage Grotesque, IBM Plex Mono (via Fontsource)	Tipografia	OFL-1.1
Fastify e plugins oficiais	Servidor da API	MIT
Zod	Validação	MIT
node-postgres (pg)	Driver do PostgreSQL	MIT
PGlite	PostgreSQL embutido	Apache-2.0
bcrypt.js	Hash de senhas	BSD-3-Clause
PDFKit	Relatórios em PDF	MIT
TypeScript, tsx	Linguagem e execução em desenvolvimento	Apache-2.0, MIT

ApexCharts

O ApexCharts está fixado na versão 4.7.0, a última publicada sob a licença MIT. As versões a partir da 5.1 adotaram uma licença dupla que exige compra para empresas com receita anual acima de US$ 2 milhões. Por isso o Dependabot ignora esse pacote. Confira a licença antes de atualizar.

O PostgreSQL roda como serviço externo pelo Docker e não é redistribuído no repositório. Slack, Discord, Google Analytics e Stripe são marcas dos seus donos e aparecem apenas como destinos de integração.

Copyright (©) 2026 Erik Pimenta

15.2 Licença do Bento

Copyright (©) 2026 Erik Pimenta

O código é distribuído sob a licença MIT: você pode usar, copiar, modificar, mesclar, publicar, distribuir, sublicenciar e vender cópias, inclusive para fins comerciais, desde que mantenha o aviso de copyright e o texto da licença em todas as cópias ou partes substanciais. O software é fornecido sem garantia de qualquer tipo. O texto completo está no arquivo `LICENSE`.